AegisMesh

AI 에이전트 보안 위험 대응 멀티 에이전트 플랫폼 PRD

인포그래픽 「Security Risks in AI Agents」의 10개 위험 분류 70개 세부 항목을 빠짐없이 독립 실행 에이전트로 구현하고, 독립·연계·즉시 사용 세 가지 운용 모드를 모두 지원하는 멀티 에이전트 보안 플랫폼의 제품 요구사항 정의서

작성일 2026-09-17

분석 대상 도식: Security Risks in AI Agents (Rushika Rai)

표준 근거: OWASP GenAI LLM Top 10 2026 · OWASP Top 10 for Agentic Applications 2026 · MITRE ATLAS · NIST AI RMF 1.0

실측 기준일: 2026-09-17 (GitHub REST API 직접 조회 245개 저장소)

목차

1. 개요

1.1 이 문서가 다루는 것 1.2 왜 항목 단위 에이전트인가 1.3 핵심 발견 1.4 문서 구성

2. 출처와 라이선스

2.1 분석 대상 이미지 2.2 전사 원칙 2.3 오픈소스 출처 표기 원칙 2.4 표준·규제 출처 2.5 선행 문서와의 관계

3. 도식 전수 분석

3.1 전사 결과 요약 3.2 계열별 배치로 본 도식 3.3 D1. Prompt Injection Attacks

3.4 D2. Data Leakage Risks 3.5 D3. Tool Misuse & Abuse

3.6 D4. Model Hallucination Risks 3.7 D5. Access Control Failures

3.8 D6. Autonomous Agent Overreach 3.9 D7. Supply Chain Vulnerabilities

3.10 D8. Memory & Context Exploits 3.11 D9. Infrastructure-Level Risks

3.12 D10. Governance & Compliance Gaps 3.13 항목 추적표 3.14 도식의 네 가지 성격

3.15 도식의 공백

4. 표준 매핑

4.1 OWASP LLM Top 10 4.2 OWASP Top 10 for Agentic Applications

4.3 도메인별 표준 식별자 4.4 규제 매핑 4.5 통제 매핑을 코드로 유지하는 이유

5. 목표 시스템

5.1 제품 정의 5.2 운용 3모드 5.3 세 모드가 같은 산출물을 쓰는 방법 5.4 설계 원칙 5.5 원칙 DP8 이 필요한 이유

6. 기능 요구사항

6.1 요구사항 표기 규칙 6.2 FR-D1. 프롬프트 인젝션 공격 6.3 FR-D2. 데이터 유출 위험

6.4 FR-D3. 도구 오남용 6.5 FR-D4. 모델 환각 위험 6.6 FR-D5. 접근 통제 실패

6.7 FR-D6. 자율 에이전트 과잉행동 6.8 FR-D7. 공급망 취약점 6.9 FR-D8. 메모리·컨텍스트 악용

6.10 FR-D9. 인프라 계층 위험 6.11 FR-D10. 거버넌스·컴플라이언스 공백 6.12 FR-X. 도식 공백 보강 요구사항

6.13 FR-P. 플랫폼 요구사항 6.14 우선순위 집계

7. 비기능 요구사항

7.1 NFR-Q 판정 품질 7.2 NFR-L 지연 7.3 NFR-A 가용성과 강등 7.4 NFR-I 격리

7.5 NFR-S 자체 보안 7.6 NFR-P 확장성 · NFR-O 운영성 · NFR-C 이식성 7.7 NFR-D 데이터 보호

8. 아키텍처

8.1 7계층 구조 8.2 요청 경로와 4관문 8.3 에이전트 공통 골격 8.4 에이전트 실행 형태 8.5 배포 토폴로지

8.6 실패 모드와 강등

9. 에이전트 카탈로그

9.1 카탈로그 읽는 법 9.2 AG-D1 스쿼드 9.3 AG-D2 스쿼드 9.4 AG-D3 스쿼드 9.5 AG-D4 스쿼드

9.6 AG-D5 스쿼드 9.7 AG-D6 스쿼드 9.8 AG-D7 스쿼드 9.9 AG-D8 스쿼드 9.10 AG-D9 스쿼드

9.11 AG-D10 스쿼드 9.12 AG-X 보강 에이전트 9.13 AG-P 플랫폼 에이전트 9.14 에이전트 수량 집계

10. 기술 스택

10.1 선정 기준 10.2 D1 프롬프트 인젝션 공격 스택 10.3 D2 데이터 유출 위험 스택 10.4 D3 도구 오남용 스택

10.5 D4 모델 환각 위험 스택 10.6 D5 접근 통제 실패 스택 10.7 D6 자율 에이전트 과잉행동 스택

10.8 D7 공급망 취약점 스택 10.9 D8 메모리·컨텍스트 악용 스택 10.10 D9 인프라 계층 위험 스택

10.11 D10 거버넌스·컴플라이언스 공백 스택 10.12 플랫폼·공통 스택 10.13 라이선스 5등급

10.14 이전·개명·인수 목록 10.15 아카이브·정체 저장소

11. 독립 구동, 연계, 즉시 사용

11.1 세 모드의 계약 11.2 agent.yaml 규격 11.3 등록 7단계 11.4 프로파일 다섯 종
11.5 누락 검증을 빌드 게이트로 11.6 즉시 사용 화면의 정보 구조
12. 데이터 모델, API, 프로토콜
12.1 Finding 12.2 핵심 엔티티 12.3 REST API 12.4 MCP 와 A2A 12.5 관측 규약
12.6 증적 원장
13. 보안, 법적, 윤리 고려사항
13.1 이중 용도 통제 13.2 오픈소스 라이선스 리스크 13.3 개인정보와 데이터 보호 13.4 판정의 공정성과 설명 책임
13.5 알려진 오탐·미탐 특성
14. 도식 검증
14.1 판정표 14.2 판정 집계 14.3 도식에 대한 종합 평가
15. 지표, 로드맵, 리스크
15.1 성공 지표 15.2 단계별 로드맵 15.3 성숙도 단계 15.4 리스크 등록부 15.5 다음 결정이 필요한 사항
부록 A. 용어
부록 B. 출처 총람
B.1 원본 도식 B.2 표준·규제 문서 B.3 실측 방법
부록 C. 사용자 즐겨찾기 교차
부록 D. 이미지·그림 출처
부록 E. 한계

1. 개요

1.1 이 문서가 다루는 것

이 문서는 첨부된 인포그래픽 「Security Risks in AI Agents」(작성자 Rushika Rai)를 기술 요구사항으로 옮긴 제품 요구사항 정의서다. 도식은 중앙의 보안 아이콘에서 열 갈래로 뻗은 방사형 구조이고, 각 갈래는 위험 분류 하나와 그 아래 세부 위험 일곱 개로 이루어진다. 따라서 도식이 담은 위험 항목은 분류 10개와 세부 항목 70개, 합계 80개다. 이 문서는 그 80개를 하나도 빠뜨리지 않고 기능 요구사항과 에이전트 명세로 전개하는 것을 첫째 목표로 삼는다.

목표 시스템의 이름은 AegisMesh 이다. 방패(Aegis)와 격자(Mesh)를 합친 이름으로, 열 개 위험 영역을 각각 담당하는 독립 에이전트들이 서로 느슨하게 연결된 격자 형태로 동작한다는 설계 의도를 담았다. 단일 거대 보안 제품이 아니라, 항목 하나하나가 홀로 돌아가는 작은 에이전트로 구현되고 필요할 때만 서로를 호출한다.

1.2 왜 항목 단위 에이전트인가

- **책임 경계가 곧 배포 경계다.** 프롬프트 인젝션 탐지와 클라우드 오구성 점검은 실행 주기도, 데이터 등급도, 담당 조직도 다르다. 한 프로세스에 묶으면 한쪽의 장애와 오탐이 다른 쪽을 끌고 내려간다.
- **의존성이 충돌한다.** 레드팀 도구와 정책 엔진, 개인정보 탐지기와 추론 서버는 파이썬·Go·Rust 런타임과 라이브러리 버전이 서로 다르다. 항목별 독립 컨테이너는 취향이 아니라 기술적 필연이다.
- **부분 도입이 현실이다.** 대부분의 조직은 열 개 영역을 동시에 도입하지 않는다. 오늘 필요한 두세 개만 켜고, 나중에 붙일 수 있어야 한다.
- **증적은 항목 단위로 요구된다.** 규제 대응에서 감사자는 통제 항목 단위로 증적을 묻는다. 에이전트 경계와 통제 항목 경계를 일치시키면 증적 수집이 부수 효과로 따라온다.

1.3 핵심 발견

도식을 구현 가능한 명세로 옮기기 위해 2026-09-17 기준으로 표준 문서와 245개 오픈소스 저장소를 직접 조회했다. 그 과정에서 도식을 그대로 따르면 실패하는 지점 여섯 가지를 확인했다.

1. **도식의 분류 체계는 2025년 표준을 따른다.** OWASP 는 2026-08-04 에 GenAI LLM Top 10 2026 을 발행하면서 10개 항목 중 7개의 번호를 바꾸고, 2025판 LLM07 System Prompt Leakage 를 LLM08 Hidden Context Exposure 로 재정의해 범위를 넓혔다. 도식의 D1-07 System prompt leakage 를 LLM07 로 매핑하면 현행 표준과 어긋난다. 4장에 2025 대 2026 대조표를 둔다.
2. **도식은 단일 에이전트를 전제한다.** OWASP 가 2025-12-09 공개하고 2026년 판으로 확정한 Agentic Applications Top 10(ASI01~ASI10) 가운데 ASI07 에이전트 간 통신, ASI08 연쇄 실패, ASI09 사람-에이전트 신뢰 악용, ASI10 이탈 에이전트가 도식에 없다. 멀티 에이전트를 지향하는 이 문서에서는 이 공백을 그대로 둘 수 없어 보강 항목 X01~X04 로 추가했다.
3. **도식 항목에 대응하던 대표 오픈소스 네 개가 죽었다.** protectai/rebuff 는 2024-01-25 이후 커밋이 없는 아카이브 저장소이고, protectai/llm-guard 는 2026-07-08 에 아카이브됐다. Azure/PyRIT 는 2026-09-16 아카이브 후 microsoft/PyRIT(4,485★)로 옮겨 갔고, lakeraai/pint-benchmark 도 아카이브됐다. 인젝션 방어 1순위는 현재 활성 저장소인 NVIDIA/garak, promptfoo, NVIDIA-NeMo/Guardrails 조합이다.
4. **저장소 이전이 아홉 건 이상 있었다.** 특히 MCP 보안 점검의 사실상 표준이던 invariantlabs-ai/mcp-scan 은 snyk/agent-scan(3,058★)로 이관됐다. 상용 보안 업체가 에이전트 보안 도구를 흡수하는 흐름이므로 라이선스 변경 가능성을 전제로 고정 버전을 쓰는 편이 안전하다. 전체 목록은 10장에 둔다.
5. **방어 계층 1순위 후보들이 오픈소스가 아니다.** 프롬프트 인젝션 분류기의 사실상 기준선인 meta-llama/PurpleLlama 의 Prompt Guard 와 Llama Guard 는 Llama Community License 를 따르는 비OSI 산출물이다. 관측 계층도 Arize Phoenix 가 Elastic License 2.0,

Langfuse 가 MIT 에 ee 디렉터리 상용 조합이며 LICENSE 저작권자가 ClickHouse, Inc. 다. 재판매·호스팅 사업 모델이라면 기본값을 Apache-2.0 계열로 잡아야 한다.

6. **시크릿 저장소의 기본값을 바꿔야 한다.** hashicorp/vault 와 hashicorp/boundary 의 LICENSE 파일은 BUSL-1.1 이고 Licensor 가 International Business Machines Corporation (IBM) 으로 적혀 있다. AegisMesh 의 기본 시크릿 백엔드는 openbao/openbao(MPL-2.0)로 둔다.

1.4 문서 구성

장	제목	내용
1	개요	목적, 항목 단위 에이전트 설계 근거, 핵심 발견 6건
2	출처와 라이선스	원본 도식 출처, 인용 원칙, 선행 문서와의 관계
3	도식 전수 분석	10개 분류 70개 세부 항목 전문 전사, 추적표, 성격 재분류, 공백 10건
4	표준 매핑	OWASP GenAI LLM Top 10 2026, ASI 2026, MITRE ATLAS, NIST, 규제
5	목표 시스템	제품 정의, 운용 3모드, 설계 원칙
6	기능 요구사항	FR-D 70건, FR-X 10건, FR-P 16건
7	비기능 요구사항	판정 품질을 최상위로 둔 NFR 체계
8	아키텍처	7계층, 요청 경로 4관문, 에이전트 공통 골격, 배포 토폴로지
9	에이전트 카탈로그	도메인 에이전트 70종 + 보강 10종 + 플랫폼 12종 = 92종
10	기술 스택	영역별 실측 저장소표, 라이선스 5등급, 이전·아카이브 목록
11	독립·연계·즉시 사용	agent.yaml 규격, 등록 절차, 프로파일, 누락 검증 CI
12	데이터 모델·API·프로토콜	Finding 스키마, REST·MCP·A2A, OpenTelemetry
13	보안·법적·윤리	이중 용도 통제, 라이선스 리스크, 레드팀 윤리
14	도식 검증	도식 표기 대비 실측 판정표
15	지표·로드맵·리스크	성공 지표, 단계별 로드맵, 리스크 등록부
부록	A~E	용어, 출처 총람, 즐겨찾기 교차, 이미지 출처, 한계

2. 출처와 라이선스

2.1 분석 대상 이미지

제목	Security Risks in AI Agents
표기된 작성자	Rushika Rai (도식 상단 배지 및 중앙 워터마크에 동일 표기)
형식	세로형 인포그래픽. 중앙 아이콘에서 열 갈래 화살표가 뻗는 방사형 마인드맵
구성	분류 10개, 분류별 세부 항목 7개(합계 70개), 제목 2행, 작성자 배지 1, 중앙 아이콘 1, 화살표 10, 워터마크 1
입수 경로	사용자가 대화에 직접 첨부. 원 게시물 URL 은 확인되지 않음
원본 URL	[미확인] – 이미지 안에 URL·도메인·게시 일자 표기가 없다
저작권	도식의 저작권은 표기된 작성자에게 있다. 이 문서는 도식을 복제하지 않고, 표기된 텍스트 항목을 인용해 분석한다
이 문서의 사용 방식	도식의 텍스트 항목을 요구사항 식별자로 전사하고, 도식을 재현한 그림 1은 자체 제작한 재구성도다

도식 이미지 자체는 이 문서에 삽입하지 않는다. 그림 1은 도식의 구조와 표기를 근거로 새로 그린 재구성도이며, 원본의 색·배치·아이콘을 복제하지 않는다. 항목 텍스트는 분석과 매핑을 위해 원문 그대로 인용한다.

2.2 전사 원칙

1. **원문 표기를 그대로 남긴다.** 영문 표기는 도식에 적힌 철자와 대소문자를 유지한다. 예를 들어 도식의 Lack monitoring 은 문법적으로는 Lack of monitoring 이 자연스럽지만 원문 표기를 고치지 않는다.
2. **한글은 번역이 아니라 해석이다.** 한글 명칭은 국내 실무에서 통용되는 용어로 옮기되, 원문과 1대1 대응을 유지한다.
3. **도식에 없는 내용은 추가 표시한다.** 도식에 없는 항목은 X 접두사를 붙여 보강 항목으로 분리하고, 3.5 절에 근거를 적는다.
4. **도식의 오류나 낡음은 판정한다.** 도식 표기를 그대로 두되 14장 검증표에서 일치·부분일치·낡음·공백으로 판정한다. 판정 대상은 도식에 실제로 적힌 표기로 한정한다.

2.3 오픈소스 출처 표기 원칙

- **모든 저장소는 실측한다.** 스타 수·라이선스·기본 브랜치 최신 커밋·최신 릴리스는 2026-09-17 에 GitHub REST API 로 직접 조회했다. 기억이나 추정으로 적은 수치는 없다.
- **이전된 저장소는 현행 경로로 적는다.** 옛 경로는 10장 이전 목록에 남긴다.
- **라이선스는 SPDX 식별자를 우선한다.** API 가 NOASSERTION 을 반환하는 저장소는 LICENSE 파일 본문을 직접 읽어 판정했다. BUSL·SSPL·ELv2·FSL 처럼 OSI 승인이 아닌 라이선스는 그 사실을 명시한다.
- **사용자 즐겨찾기 교차는 별표로 표시한다.** github.com/WisemanLim?tab=stars 목록 5,832건과 교차해 겹치는 저장소 뒤에 별표 하나를 붙였다. 교차 목록 전체는 부록 C 에 둔다.
- **활성 여부는 기본 브랜치 최신 커밋으로 판단한다.** 전 브랜치를 반영하는 pushed_at 은 활발함을 과대평가하므로 쓰지 않았다.

2.4 표준·규제 출처

구분	문서	판본·일자	확인 방법
위험 분류	OWASP GenAI LLM Top 10 2026	2026-08-04 발행	GenAI-Security-Project/GenAI-LLM-Top10 저장소 2026/final 디렉터리 직접 조회
위험 분류	OWASP Top 10 for LLM Applications 2025	2025-01-27 (2.0.0)	OWASP/www-project-top-10-for-large-language-model-applications 저장소 2_0_vulns
에이전트 위험	OWASP Top 10 for Agentic Applications (ASI) 2026	2025-12-09 공개	위 2026 저장소의 mappings/asi-2026.json 및 initiatives/agent_security_initiative

위협 지식	MITRE ATLAS	2026.06 매핑본	GenAI-LLM-Top10 mappings/mitre-atlas-2026.06.json
위협 지식	MITRE ATT&CK	v19.1 매핑본	GenAI-LLM-Top10 mappings/mitre-attack-v19.1.json
약점 분류	CWE	4.20 매핑본	GenAI-LLM-Top10 mappings/cwe-4.20.json
위험 관리	NIST AI RMF 1.0 / NIST AI 600-1	매핑본 수록	GenAI-LLM-Top10 mappings/nist-ai-rmf-1.0.json, nist-ai-600-1.json
클라우드 통제	CSA AI Controls Matrix	v1.1 매핑본	GenAI-LLM-Top10 mappings/csa-aicm-v1.1.json
점수 체계	OWASP AIVSS	v0.8 매핑본	GenAI-LLM-Top10 mappings/owasp-aivss-v0.8.json
통제 표준	ISO/IEC 42001, ISO/IEC 23894, ISO/IEC 27001	현행	표준 본문(유료) – 조항 번호만 인용
규제	EU AI Act (Regulation (EU) 2024/1689)	2024-08-01 발효	관보 본문. 적용 시점은 제113조
규제	개인정보보호법(대한민국)	현행	국가법령정보센터
프로토콜	Model Context Protocol	2026-07-28 개정	modelcontextprotocol/modelcontextprotocol 릴리스 태그
프로토콜	Agent2Agent (A2A)	v1.0.1 (2026-05-28)	a2aproject/A2A 릴리스
관측 규약	OpenTelemetry Semantic Conventions	v1.44.0 (2026-08-04)	open-telemetry/semantic-conventions 릴리스

2.5 선행 문서와의 관계

같은 저장 위치에 2026-09-15 작성한 AgentSentry PRD 가 있다. 두 문서는 대상 도식이 다르고 접근 축도 다르다. 중복을 피하기 위해 경계를 다음과 같이 둔다.

구분	AgentSentry PRD (2026-09-15)	AegisMesh PRD (본 문서)
원본 도식	Controls 7종 x Guardrails 7종 2열 도식	Security Risks in AI Agents 10분류 x 7세부 방사형 도식
출발점	방어 수단(무엇을 설치할 것인가)	위험 분류(무엇을 막을 것인가)
구성 단위	통제 항목과 가드레일 항목	위험 항목별 탐지·차단 에이전트
범위	요청 경로 위의 심층 방어	위험 10개 영역 전체(인프라·거버넌스 포함)
관계	본 문서의 D3·D5 영역과 상당 부분 겹친다	겹치는 영역은 AgentSentry 의 통제 정의를 재사용하고 중복 구현하지 않는다

실제 배치에서는 AgentSentry 가 정의한 게이트웨이·정책 결정점을 그대로 쓰고, 본 문서는 그 위에서 위험 항목별 판정 에이전트를 꽂는 방식을 택한다. 8장 아키텍처의 4관문 구조가 그 접점이다.

3. 도식 전수 분석

3.1 전사 결과 요약

도식에서 읽어 낸 표기를 모두 옮겼다. 위험을 지시하는 텍스트 항목은 분류 10개와 세부 항목 70개이고, 나머지는 제목·작성자·아이콘·화살표 같은 장식 요소다. 아래 집계가 이 문서의 누락 검증 기준선이다.

구성 요소	개수	문서에서의 처리
위험 분류(방사형 갈래의 중심 라벨)	10	도메인 D1~D10 으로 전사. 각각 에이전트 스쿼드 하나에 대응
세부 위험 항목(갈래마다 7개)	70	D1-01 ~ D10-07 로 전사. 각각 독립 에이전트 하나에 대응
제목 텍스트	2	1행 Security Risks, 2행 in AI Agents. 문서 제목 근거로만 사용
작성자 배지	1	2.1 절 출처 표기에 반영
중앙 아이콘(방패·자물쇠·체크)	1	시스템 개념도(그림 3)의 중앙 판정 계층으로 해석
방사형 화살표	10	분류와 중심의 관계 표시. 구조 해석에만 사용
워터마크	1	출처 표기에 반영
합계	**95**	이 중 위험 항목 **80개**가 요구사항 전개 대상

Security Risks in AI Agents — 항목 재구성

10개 위험 분류 x 7개 세부 항목 = 70개 (원본 도식의 표기를 그대로 전사)

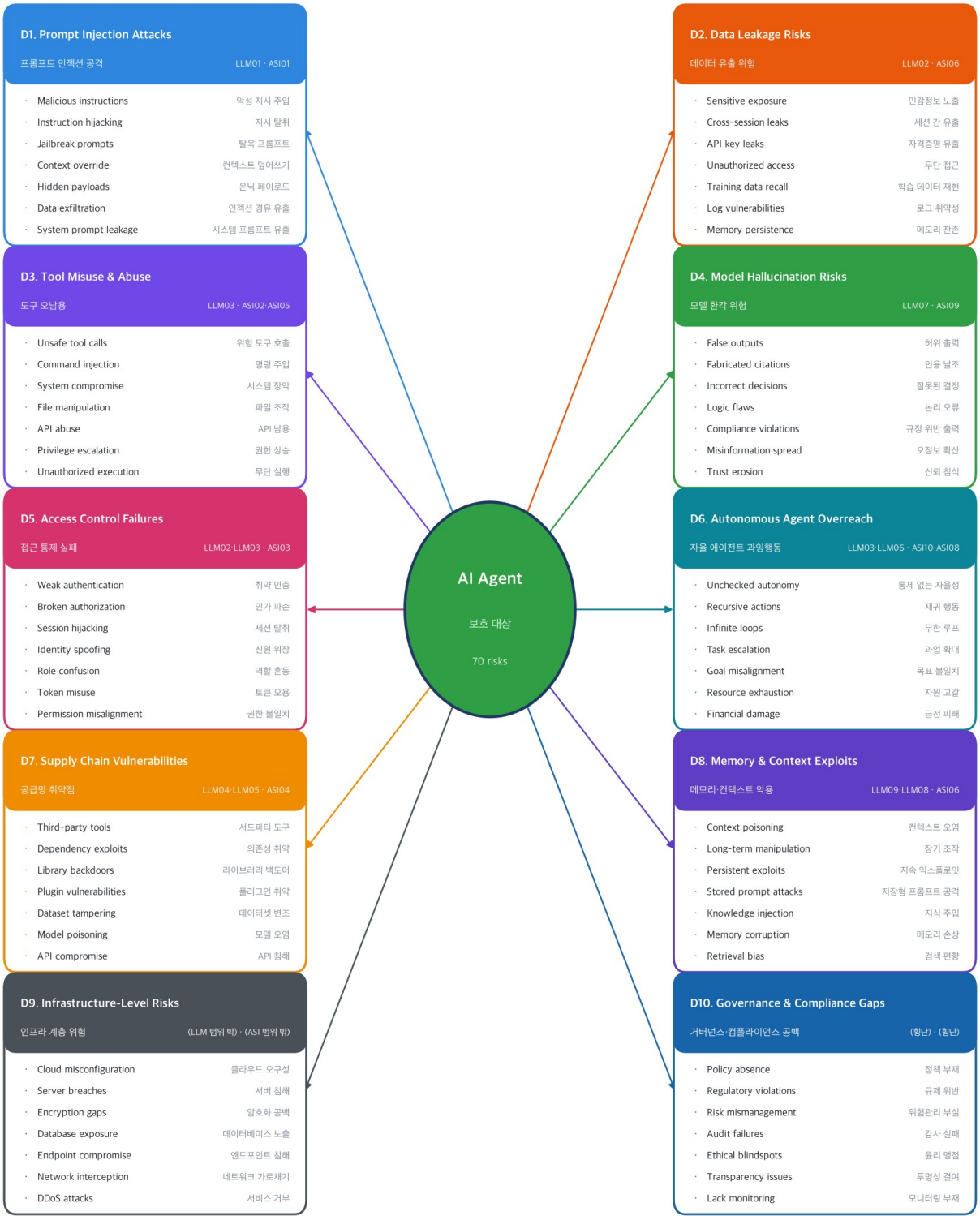


그림 1. 원본 도식 재구성 — 10개 위험 분류와 70개 세부 항목. 원본의 배치·색·아이콘을 복제하지 않고 표기 항목만 재배열했다.

3.2 계열별 배치로 본 도식

원본은 열 갈래를 같은 무게로 늘어놓지만, 실제 방어에서는 요청 경로 위에 인라인으로 놓이는 것과 경로 밖에서 도는 것이 갈린다. 그림 2는 같은 70개 항목을 방어 관문 기준으로 다시 배치한 것이다. 3.14 절의 네 계열이 여기에서 나온다.



그림 2. 도식 항목의 방어 관문 재배치 — 입력 관문, 도구 관문, 출력 관문, 증적 관문 및 상시 점검 영역

3.3 D1. Prompt Injection Attacks – 프롬프트 인젝션 공격

표준 매핑: OWASP GenAI LLM Top 10 2026 LLM01 · OWASP Agentic Top 10 ASI01. 세부 항목 7개를 모두 전사했다.

ID	도식 원문 표기	한글	위협 내용	탐지·차단 방식
D1-01	Malicious instructions	악성 지시 주입	웹 페이지·문서·이메일·도구 응답 등 신뢰할 수 없는 콘텐츠에 심어 둔 문장을 모델이 지시로 해석한다(간접 프롬프트 인젝션).	출처별 신뢰 등급 부여, 데이터/지시 경계 표식(스포트라이팅), 인젝션 분류기 이중 판정
D1-02	Instruction hijacking	지시 탈취	원래 시스템 목표를 덮어써 공격자 목표를 수행하게 만든다. 에이전트는 사용자가 모르는 사이 목표가 바뀐다.	목표 불변식(goal invariant) 서명·대조, 계획 변경 감지, 단계별 목표 일치도 점수
D1-03	Jailbreak prompts	탈옥 프롬프트	안전 정책을 우회하도록 설계된 역할극·인코딩·다단계 템플릿(DAN 계열, GCG 계열 적대 접미사).	탈옥 코퍼스 유사도 매칭 + 전용 분류기 + 거절 일관성 회귀 시험
D1-04	Context override	컨텍스트 덮어쓰기	긴 컨텍스트 후반에 배치한 지시가 앞선 시스템 정책을 무력화한다. 위치 편향을 악용한다.	시스템 지시 재삽입(샌드위치), 위치별 순응도 측정, 컨텍스트 세그먼트 권한 표시
D1-05	Hidden payloads	은닉 페이로드	제로폭 문자·유니코드 태그 블록(ASCII smuggling)·흰 글씨·HTML 주석·이미지 대체텍스트에 지시를 숨긴다.	NFKC 정규화와 비가시 문자 제거, 태그 블록 U+E0000 대역 차단, 렌더 전후 차분 검사
D1-06	Data exfiltration	인젝션 경유 유출	인젝션으로 마크다운 이미지·링크·도구 호출을 유도해 컨텍스트 내용을 외부로 실어 보낸다.	출력 URL 허용목록, 자동 렌더 차단, 이그레스 프록시에서 파라미터 엔트로피 검사
D1-07	System prompt leakage	시스템 프롬프트 유출	시스템 지시·도구 스키마·정책 문구가 추출된다. 2026 개정판은 이를 LLM08 Hidden Context Exposure 로 확장했다.	카나리 토큰 삽입 후 출력 대조, 시스템 지시 유사도 검사, 비밀은 컨텍스트에 두지 않는 설계 원칙 강제

3.4 D2. Data Leakage Risks – 데이터 유출 위험

표준 매핑: OWASP GenAI LLM Top 10 2026 LLM02 · OWASP Agentic Top 10 ASI06. 세부 항목 7개를 모두 전사했다.

ID	도식 원문 표기	한글	위협 내용	탐지·차단 방식
D2-01	Sensitive exposure	민감정보 노출	개인정보·건강정보·영업비밀이 응답에 그대로 실린다. 한국은 개인정보보호법상 처리 근거·파기 의무가 함께 걸린다.	개체명 인식 기반 탐지 후 마스킹·가명화, 신뢰 구역별 노출 정책, 한국어 전용 사전 병행
D2-02	Cross-session leaks	세션 간 유출	프롬프트 캐시·공유 메모리·임베딩 인덱스를 매개로 다른 사용자·테넌트의 데이터가 섞여 나온다.	캐시 키에 주체·테넌트 식별자 포함, 인덱스 네임스페이스 분리, 교차 조회 회귀 시험
D2-03	API key leaks	자격증명 유출	프롬프트·코드·로그·에러 메시지에 API 키와 토큰이 남는다. 에이전트는 이를 다시 읽어 확산시킨다.	커밋·프롬프트·로그 3중 시크릿 스캔, 동적 시크릿 발급으로 정적 키 제거, 유출 시 자동 폐기
D2-04	Unauthorized access	무단 접근	권한 없는 문서·테이블·도구 결과가 검색 단계에서 컨텍스트로 들어온다.	검색 이전 권한 프리필터(관계 기반 인가), 결과 후단 재검증, 접근 결정 감사 기록
D2-05	Training data recall	학습 데이터 재현	미세조정·사전학습에 쓰인 원문이 암기되어 추출되거나, 멤버십 추론으로 포함 여부가 드러난다.	차등 프라이버시 학습, 중복 제거, 추출·멤버십 공격 자동 시험을 배포 게이트로 편입
D2-06	Log vulnerabilities	로그 취약성	관측 도구가 프롬프트·응답 원문을 그대로 적재해 2차 유출 경로가 된다.	수집 파이프라인 단계 마스킹, 페이로드 저장 정책 분리, 보존기한·접근권 분리
D2-07	Memory persistence	메모리 잔존	삭제 요청 이후에도 장기 메모리·벡터 인덱스·백업에 사본이 남는다.	메모리 항목 TTL, 삭제 전파(원본·인덱스·캐시·백업), 삭제 증적 발행

3.5 D3. Tool Misuse & Abuse – 도구 오남용

표준 매핑: OWASP GenAI LLM Top 10 2026 LLM03 · OWASP Agentic Top 10 ASI02·ASI05. 세부 항목 7개를 모두 전사했다.

ID	도식 원문 표기	한글	위협 내용	탐지·차단 방식
D3-01	Unsafe tool calls	위험 도구 호출	파괴적 인자(전체 삭제, 대량 전송, 결제)로 도구를 호출한다.	인자 스키마 검증 + 사전조건 정책 판정 + 드라이런 후 영향 추정, 임계 초과 시 사람 승인
D3-02	Command injection	명령 주입	도구 인자에 셸 메타문자를 섞어 임의 명령을 실행한다.	셸 미경유 실행, 인자 허용목록, 위험 패턴 차단, 실행 전 정적 검사
D3-03	System compromise	시스템 장악	도구 경유 원격 코드 실행으로 호스트를 장악한다 (ASI05).	microVM·사용자 공간 커널 격리, 워크로드별 1회용 샌드박스, 이그레스 기본 차단
D3-04	File manipulation	파일 조작	경로 탈출·심볼릭 링크로 허용 범위 밖 파일을 읽고 쓴다.	경로 정규화·체이닝 검사, 읽기 전용 마운트, seccomp 로 시스템 호출 축소
D3-05	API abuse	API 남용	정상 권한 안에서 호출 빈도·크기를 남용해 비용과 부하를 유발한다.	주체별 레이트리밋·쿼터·동시성 상한, 비용 단위 과금 관측
D3-06	Privilege escalation	권한 상승	도구를 연쇄 호출해 원래 부여된 범위를 넘는 권한을 획득한다.	호출마다 토큰 다운스코핑, 위임 체인 기록, 상승 경로 정적 분석
D3-07	Unauthorized execution	무단 실행	등록되지 않았거나 변조된 도구·MCP 서버·스킬이 실행된다.	도구 레지스트리 서명 검증, 설치 전 정적 스캔, 런타임 해시 대조

3.6 D4. Model Hallucination Risks – 모델 환각 위험

표준 매핑: OWASP GenAI LLM Top 10 2026 LLM07 · OWASP Agentic Top 10 (대응 없음). 세부 항목 7개를 모두 전사했다.

ID	도식 원문 표기	한글	위협 내용	탐지·차단 방식
D4-01	False outputs	허위 출력	근거 없는 사실 주장을 자신 있게 생성한다.	근거성 판정기로 문장 단위 검증, 근거 미확보 문장 표시 또는 차단
D4-02	Fabricated citations	인용 날조	존재하지 않는 논문·조항·URL 을 인용한다.	인용 식별자 실재 확인, 인용문-원문 대조, 미검증 인용 자동 제거
D4-03	Incorrect decisions	잘못된 결정	환각에 근거한 결정이 실제 행동(결제, 배포, 통지)으로 이어진다.	결정 신뢰도 임계값 게이트, 임계 미만 시 사람 승인 경유
D4-04	Logic flaws	논리 오류	형식은 맞지만 추론 단계가 어긋난다. 수치·단위·조건 분기에서 잦다.	제약 디코딩으로 형식 고정, 검증자 재실행, 자기일관성 표본 비교
D4-05	Compliance violations	규정 위반 출력	금지된 조언·표현·미고지 광고 등 규정 위반 문구를 생성한다.	정책 룰 엔진 판정, 도메인 금칙 사전, 위반 시 재작성 또는 차단
D4-06	Misinformation spread	오정보 확산	잘못된 출력이 다른 에이전트·문서·인덱스로 전파되어 고착된다.	배포 전 게이트, 출처 표기 강제, 전파 경로 추적과 소급 정정

D4-07	Trust erosion	신뢰 침식	반복된 오류로 사용자가 시스템 전체를 불신하게 된다. 정량 지표 없이 방치되기 쉽다.	불확실성 명시, 사용자 피드백 루프, 신뢰 지표 상시 관측과 회귀 경보

3.7 D5. Access Control Failures – 접근 통제 실패

표준 매핑: OWASP GenAI LLM Top 10 2026 LLM02·LLM03 · OWASP Agentic Top 10 ASI03. 세부 항목 7개를 모두 전사했다.

ID	도식 원문 표기	한글	위협 내용	탐지·차단 방식
D5-01	Weak authentication	취약 인증	정적 API 키·공유 비밀로 에이전트를 인증한다.	OIDC·mTLS 기반 인증, 워크로드 신원 자동 발급·회전
D5-02	Broken authorization	인가 파손	인가 판단이 애플리케이션 코드에 흩어져 누락과 우회가 생긴다.	정책 결정점 외부화, 관계 기반 인가 모델, 정책 단위 시험
D5-03	Session hijacking	세션 탈취	탈취한 베어러 토큰으로 타인 세션을 사용한다.	소유 증명 토큰(DPoP·mTLS 바인딩), 짧은 수명, 이상 위치·기기 감지
D5-04	Identity spoofing	신원 위장	다른 에이전트를 사칭해 신뢰 관계를 악용한다.	에이전트 카드 서명 검증, 상호 인증, 신원-능력 바인딩
D5-05	Role confusion	역할 혼동	사용자 권한과 에이전트 서비스 권한이 뒤섞여 대리 범위가 흐려진다.	주체·대리자 분리 표기, 위임 체인 명시, 유효 권한은 교집합으로 산정
D5-06	Token misuse	토큰 오용	한 용도로 발급된 토큰이 다른 대상에 재사용된다.	수신자 제한, 1회성·짧은 수명, 사용 이력 감사와 이상 탐지
D5-07	Permission misalignment	권한 불일치	선언된 권한과 실제 사용 권한이 시간이 지나며 어긋난다(권한 드리프트).	실사용 권한 수집 후 최소 권한 자동 제안, 미사용 권한 회수

3.8 D6. Autonomous Agent Overreach – 자율 에이전트 과잉행동

표준 매핑: OWASP GenAI LLM Top 10 2026 LLM03·LLM06 · OWASP Agentic Top 10 ASI01. 세부 항목 7개를 모두 전사했다.

ID	도식 원문 표기	한글	위협 내용	탐지·차단 방식
D6-01	Unchecked autonomy	통제 없는 자율성	승인 없이 외부에 영향을 주는 행동을 수행한다.	행동 영향 등급별 자율 레벨 정의, 등급 초과 시 사람 승인 경유
D6-02	Recursive actions	재귀 행동	에이전트가 자기 자신 또는 하위 에이전트를 반복 생성해 폭증한다.	호출 깊이·팬아웃 상한, 생성 예산, 계보 추적
D6-03	Infinite loops	무한 루프	종료 조건을 만족하지 못해 같은 계획을 반복한다.	상태 해시 반복 감지, 진전 없음 판정, 실행 타임아웃과 내구 실행 재개
D6-04	Task escalation	과업 확대	주어진 범위를 넘는 하위 과업을 스스로 추가한다.	과업 범위 계약 명시, 범위 밖 계획 차단, 범위 변경은 승인 사건으로 기록
D6-05	Goal misalignment	목표 불일치	지표를 만족시키되 의도를 벗어난 방식으로 목표를 달성한다.	목표 불변식 검사, 금지 수단 명시, 정렬 평가 세트 상시 실행
D6-06	Resource exhaustion	자원 고갈	토큰·시간·동시성·저장소를 소진해 서비스와 예산을 무너뜨린다(LLM06).	주체별 토큰·시간·동시성 쿼터, 백프레셔, 초과 시 강등 실행
D6-07	Financial damage	금전 피해	결제·주문·환불 등 되돌리기 어려운 금전 행동을 잘못 수행한다.	지출 상한과 승인 임계, 되돌릴 수 없는 행동의 2인 승인, 보상 트랜잭션 설계

3.9 D7. Supply Chain Vulnerabilities – 공급망 취약점

표준 매핑: OWASP GenAI LLM Top 10 2026 LLM04·LLM05 · OWASP Agentic Top 10 ASI04. 세부 항목 7개를 모두 전사했다.

ID	도식 원문 표기	한글	위협 내용	탐지·차단 방식
D7-01	Third-party tools	서드파티 도구	심사 없이 외부 MCP 서버·스킬·플러그인을 연결한다.	등록 전 정적·동적 심사, 서명·출처 확인, 레지스트리 승인 워크플로
D7-02	Dependency exploits	의존성 취약	라이브러리 취약점이 에이전트 런타임으로 그대로 들어온다.	SBOM 생성과 취약점 대조, 빌드 게이트, 취약 버전 자동 차단
D7-03	Library backdoors	라이브러리 백도어	설치 스크립트·난독화 코드로 악성 행위를 심은 패키지를 사용한다.	패키지 휴리스틱 탐지, 설치 시 동적 행위 관찰, 신규·저신뢰 패키지 격리
D7-04	Plugin vulnerabilities	플러그인 취약	플러그인이 과도한 권한을 요구하거나 프롬프트 주입	권한 선언 강제, 플러그인 샌드박스, 프롬프트 표면

			통로가 된다.	스캔
D7-05	Dataset tampering	데이터셋 변조	학습·RAG 데이터가 조용히 바뀌어 모델 행동이 오염된다.	데이터 버전 관리와 콘텐츠 해시, 변경 승인, 오염 탐지 통계
D7-06	Model poisoning	모델 오염	가중치 파일 자체가 변조되거나 역직렬화 시 코드를 실행한다.	모델 서명·검증, 안전 직렬화 형식 강제, 역직렬화 스캐너
D7-07	API compromise	API 침해	상위 API 공급자 또는 중간 경로가 침해되어 응답이 조작된다.	이그레스 허용목록과 인증서 고정, 응답 무결성 검증, 공급망 증명 확인

3.10 D8. Memory & Context Exploits – 메모리·컨텍스트 악용

표준 매핑: OWASP GenAI LLM Top 10 2026 LLM09·LLM08 · OWASP Agentic Top 10 ASI06. 세부 항목 7개를 모두 전사했다.

ID	도식 원문 표기	한글	위협 내용	탐지·차단 방식
D8-01	Context poisoning	컨텍스트 오염	검색된 문서·도구 응답에 실린 조작 내용이 현재 판단을 왜곡한다.	출처 신뢰 등급, 컨텍스트 구획 분리, 삽입 콘텐츠 인젝션 스캔
D8-02	Long-term manipulation	장기 조작	여러 세션에 걸쳐 조금씩 메모리를 바꿔 장기 행동을 유도한다.	메모리 쓰기 승인 정책, 변경 이력·차분 검토, 이상 변동 탐지
D8-03	Persistent exploits	지속 익스플로잇	한 번 심긴 악성 지시가 메모리에 남아 매 세션 재실행된다.	저장 메모리 정기 재스캔, 만료 정책, 재실행 전 무해화
D8-04	Stored prompt attacks	저장형 프롬프트 공격	지시문이 데이터로 저장되었다가 나중에 실행된다(저장형 XSS 의 LLM 판).	저장 시점 스캔과 무해화, 읽기 시점 재검사, 실행 가능 텍스트 표식 제거
D8-05	Knowledge injection	지식 주입	인덱싱 파이프라인에 위조 문서를 밀어 넣어 검색 결과를 장악한다.	수집 경로 인증, 문서 서명, 색인 변경 감사와 이상 급증 탐지
D8-06	Memory corruption	메모리 손상	메모리 레코드가 부분 손상·중복·충돌해 잘못된 사실이 고착된다.	체크섬과 불변 로그, 충돌 해소 규칙, 복구 지점 유지
D8-07	Retrieval bias	검색 편향	특정 출처가 과대 대표되어 결론이 한쪽으로 기운다.	검색 품질·다양성 지표 상시 측정, 출처 분포 감사, 리랭커 편향 시험

3.11 D9. Infrastructure-Level Risks – 인프라 계층 위험

표준 매핑: OWASP GenAI LLM Top 10 2026 (LLM 범위 밖) · OWASP Agentic Top 10 (ASI 범위 밖). 세부 항목 7개를 모두 전사했다.

ID	도식 원문 표기	한글	위협 내용	탐지·차단 방식
D9-01	Cloud misconfiguration	클라우드 오구성	공개 버킷·과대 IAM·미암호화 저장소 등 기본 설정이 위험하게 남는다.	클라우드 상태 점검 정기 실행, IaC 정적 검사, 위반 자동 차단
D9-02	Server breaches	서버 침해	런타임 침해로 에이전트 호스트가 장악된다.	커널 이벤트 기반 런타임 탐지, 무결성 감시, 침해 시 자동 격리
D9-03	Encryption gaps	암호화 공백	내부 구간 평문 통신, 저장 데이터 미암호화, 인증서 만료가 남는다.	상호 TLS 기본화, 인증서 자동 발급·회전, 저장 암호화 강제
D9-04	Database exposure	데이터베이스 노출	에이전트가 직접 접속하는 DB 계정이 과대 권한을 갖는다.	DB 접근 게이트웨이 경유, 변경 승인 워크플로, 쿼리 감사
D9-05	Endpoint compromise	엔드포인트 침해	개발자 워크스테이션·러너가 침해되어 에이전트 자격증명이 유출된다.	호스트 관측·무결성 점검, 자격증명 하드웨어 보관, 단기 세션
D9-06	Network interception	네트워크 가로채기	중간자 공격이나 잘못된 라우팅으로 트래픽이 가로채진다.	이그레스 정책 기본 차단, 상호 인증, 네트워크 흐름 관측
D9-07	DDoS attacks	서비스 거부	대량 요청으로 추론 백엔드와 도구를 마비시킨다.	엣지 레이트리밋과 평판 기반 차단, 대기열·우선순위, 자동 확장 한계 설정

3.12 D10. Governance & Compliance Gaps – 거버넌스·컴플라이언스 공백

표준 매핑: OWASP GenAI LLM Top 10 2026 (횡단) · OWASP Agentic Top 10 (횡단). 세부 항목 7개를 모두 전사했다.

ID	도식 원문 표기	한글	위협 내용	탐지·차단 방식
D10-01	Policy absence	정책 부재	무엇을 허용하고 무엇을 막는지 문서와 코드 어디에도	정책을 코드로 선언하고 버전 관리, 기본 거부 베이

			없다.	스라인 배포
D10-02	Regulatory violations	규제 위반	EU AI Act·개인정보보호법·업권 규제 요구를 충족하지 못한다.	규제 통제 항목을 시스템 통제에 매핑하고 증적 자동 수집
D10-03	Risk mismanagement	위험관리 부실	위험 식별·평가·수용 결정이 기록되지 않아 재현되지 않는다.	위험 등록부 운영, 점수 체계 적용, 수용 결정에 책임자와 기한 기록
D10-04	Audit failures	감사 실패	사후에 누가 무엇을 왜 했는지 재구성할 수 없다.	행동 단위 불변 감사 로그, 결정 근거 보관, 재현 가능한 추적 식별자
D10-05	Ethical blindspots	윤리 맹점	특정 집단에 불리한 결과를 지표로 잡아내지 못한다.	공정성 지표 정례 측정, 집단별 성능 분해, 영향 평가 문서화
D10-06	Transparency issues	투명성 결여	모델·데이터·제약이 문서화되지 않아 설명할 수 없다.	시스템·모델 카드 자동 생성, 변경 시 갱신 강제, 이해관계자 공개
D10-07	Lack monitoring	모니터링 부재	운영 중 품질·안전 저하를 감지할 상시 관측이 없다.	안전·품질 지표 상시 수집, 임계 경보, 회귀 시 자동 롤백

3.13 항목 추적표

전사한 80개 항목이 요구사항·에이전트·시험으로 이어지는지 확인하는 추적 기준이다. 실제 대조는 11.5 절의 검증 스크립트가 자동 수행한다.

도식 구성	식별자 범위	기능 요구사항	에이전트	시험 항목	누락
D1. Prompt Injection Attacks	D1-01 ~ D1-07	FR-D1-01 ~ FR-D1-07	AG-D1-01 ~ AG-D1-07	TC-D1-01 ~ TC-D1-07	0
D2. Data Leakage Risks	D2-01 ~ D2-07	FR-D2-01 ~ FR-D2-07	AG-D2-01 ~ AG-D2-07	TC-D2-01 ~ TC-D2-07	0
D3. Tool Misuse & Abuse	D3-01 ~ D3-07	FR-D3-01 ~ FR-D3-07	AG-D3-01 ~ AG-D3-07	TC-D3-01 ~ TC-D3-07	0
D4. Model Hallucination Risks	D4-01 ~ D4-07	FR-D4-01 ~ FR-D4-07	AG-D4-01 ~ AG-D4-07	TC-D4-01 ~ TC-D4-07	0
D5. Access Control Failures	D5-01 ~ D5-07	FR-D5-01 ~ FR-D5-07	AG-D5-01 ~ AG-D5-07	TC-D5-01 ~ TC-D5-07	0
D6. Autonomous Agent Overreach	D6-01 ~ D6-07	FR-D6-01 ~ FR-D6-07	AG-D6-01 ~ AG-D6-07	TC-D6-01 ~ TC-D6-07	0
D7. Supply Chain Vulnerabilities	D7-01 ~ D7-07	FR-D7-01 ~ FR-D7-07	AG-D7-01 ~ AG-D7-07	TC-D7-01 ~ TC-D7-07	0
D8. Memory & Context Exploits	D8-01 ~ D8-07	FR-D8-01 ~ FR-D8-07	AG-D8-01 ~ AG-D8-07	TC-D8-01 ~ TC-D8-07	0
D9. Infrastructure-Level Risks	D9-01 ~ D9-07	FR-D9-01 ~ FR-D9-07	AG-D9-01 ~ AG-D9-07	TC-D9-01 ~ TC-D9-07	0
D10. Governance & Compliance Gaps	D10-01 ~ D10-07	FR-D10-01 ~ FR-D10-07	AG-D10-01 ~ AG-D10-07	TC-D10-01 ~ TC-D10-07	0
보강(도식 공백)	X01 ~ X10	FR-X01 ~ FR-X10	AG-X01 ~ AG-X10	TC-X01 ~ TC-X10	해당 없음
플랫폼	P01 ~ P12	FR-P01 ~ FR-P16	AG-P01 ~ AG-P12	TC-P01 ~ TC-P16	해당 없음
합계	**92개 에이전트**	**96건**	**92종**	**96건**	**0**

3.14 도식의 네 가지 성격

열 개 분류를 그대로 나란히 두면 설계가 어긋난다. 실행 시점과 통제 주체가 서로 다르기 때문이다. 네 계열로 다시 묶으면 어느 관문에 무엇을 놓을지가 정해진다.

계열	도메인	실행 시점	판정 지연 예산	실패 시 기본 동작
C1 요청 경로 실시간	D1 인젝션, D4 환각, D8 컨텍스트	요청·응답 매 건	입력 80ms, 출력 150ms 이내	차단(fail-closed)
C2 행동 경로 실시간	D3 도구 오남용, D5 접근 통제, D6 자율성 과잉	도구 호출 매 건	20ms 이내	차단(fail-closed)
C3 비동기 상시	D2 데이터 유출, D7 공급망, D9 인프라	이벤트·주기 실행	초~분 단위	경보 후 진행(fail-open) 또는 격리
C4 조직·증적	D10 거버넌스	일·주 단위 및 변경 시	분~시간 단위	보고서 생성, 배포 게이트 차단

이 분류는 8장 아키텍처의 4관문(입력 관문, 도구 관문, 출력 관문, 증적 관문)과 1대1로 이어진다. C1·C2 는 요청 경로 위에 인라인으로 놓이므로 지연 예산이 설계 제약이고, C3·C4 는 경로 밖에서 돌기 때문에 정확도를 우선해도 된다. 같은 에이전트 프레임워크를 쓰되 배치 방식이 다르다.

3.15 도식의 공백

도식은 위험 목록으로는 촘촘하지만, 멀티 에이전트 환경과 방어 운영 측면에서 비어 있는 자리가 있다. 아래 열 건을 보강 항목으로 추가하고 6장에서 FR-X01~X10 으로 전개한다. 근거는 대부분 OWASP Agentic Top 10 과 2026 개정 LLM Top 10 에서 나온다.

ID	보강 항목	한글	도식에 없는 이유와 보강 근거
X01	Inter-agent communication security	에이전트 간 통신 보안	도식은 에이전트 하나를 전제한다. 멀티 에이전트의 A2A·MCP 채널 위·변조와 도청이 빠져 있다(ASI07).
X02	Cascading failures	연쇄 실패	한 에이전트의 오류가 다른 에이전트 입력으로 전파되어 증폭되는 경로가 빠져 있다(ASI08).
X03	Human-agent trust exploitation	사람·에이전트 신뢰 악용	에이전트가 사람을 설득해 승인·자격증명·행동을 끌어내는 경로가 빠져 있다(ASI09).
X04	Rogue agents	이탈 에이전트	등록되지 않은 에이전트, 종료되지 않은 좀비 에이전트 탐지가 빠져 있다(ASI10).
X05	Improper output handling	출력 처리 부실	환각은 다루지만 출력이 하위 시스템에서 코드·질의·명령으로 해석되는 위험(LLM10)이 빠져 있다.
X06	Multimodal attack surface	멀티모달 공격면	이미지·오디오·PDF·스프레드시트 내부에 숨긴 지시와 조작이 빠져 있다.
X07	Model and inference-layer risks	모델·추론 계층 위험	모델 추출, 추론 서버 자체 취약점, 양자화·병합 과정의 변조가 빠져 있다.
X08	Incident response and forensics	사고 대응·포렌식	위험 목록만 있고 탐지 이후의 봉쇄·근절·복구·재현 절차가 빠져 있다.
X09	Continuous red teaming	상시 레드팀	일회성 점검이 아니라 배포 파이프라인에 붙는 상시 공격 시험이 빠져 있다.
X10	Cost and SLO observability	비용·서비스 수준 관측	금전 피해만 위험으로 적었을 뿐 방어 자체의 지연·비용·오탐 예산이 빠져 있다.

보강 항목은 도식에 없던 것이므로 14장 검증표에서는 도식의 오류가 아니라 공백으로 판정한다. 도식 자체는 2026년 중반까지 널리 쓰인 위험 지형을 충실히 담고 있으며, 빠진 항목은 대부분 단일 에이전트에서 멀티 에이전트로 넘어가며 새로 부각된 것들이다.

4. 표준 매핑

도식은 표준 문서를 인용하지 않는다. 그러나 구현과 감사에서는 표준 식별자가 없으면 통제를 설명할 수 없다. 이 장은 도식의 80개 항목을 현행 표준 식별자에 붙인다. 매핑은 추정이 아니라 2026 판 저장소에 실제로 들어 있는 매핑 파일을 확인한 뒤 작성했다.

4.1 OWASP LLM Top 10 – 2025 판과 2026 판

2026-08-04 발행된 OWASP GenAI LLM Top 10 2026 은 항목 구성을 크게 재배치했다. 열 항목 중 번호가 그대로인 것은 LLM01 과 LLM02 둘뿐이고, 2025판 LLM07 System Prompt Leakage 는 LLM08 Hidden Context Exposure 로 이름과 범위가 모두 바뀌었다. 저장소도 이관되어 OWASP/www-project-top-10-for-large-language-model-applications 는 2026-08-05 커밋으로 레거시 표시가 붙었고 활성 개발은 GenAI-Security-Project/GenAI-LLM-Top10 에서 이루어진다.

2025 판	항목명(2025)	2026 판	항목명(2026)	변화
LLM01	Prompt Injection	LLM01	Prompt Injection	유지
LLM02	Sensitive Information Disclosure	LLM02	Sensitive Information Disclosure	유지
LLM03	Supply Chain	LLM04	Supply Chain	번호 변경
LLM04	Data and Model Poisoning	LLM05	Data and Model Poisoning	번호 변경
LLM05	Improper Output Handling	LLM10	Improper Output Handling	번호 변경(순위 하락)
LLM06	Excessive Agency	LLM03	Excessive Agency	번호 변경(순위 상승)
LLM07	System Prompt Leakage	LLM08	Hidden Context Exposure	**재정의** — 시스템 프롬프트를 넘어 도구 스키마·정책 문·검색 정책 전체로 확장
LLM08	Vector and Embedding Weaknesses	LLM09	Vector and Embedding Weaknesses	번호 변경
LLM09	Misinformation	LLM07	Misinformation	번호 변경(순위 상승)
LLM10	Unbounded Consumption	LLM06	Unbounded Consumption	번호 변경(순위 상승)

2026 판 LLM08 문서는 숨은 컨텍스트를 비밀로 취급하지 말라고 못 박는다. 원문은 숨은 컨텍스트가 발견 가능하다고 가정해 설계하고, 자격증명·연결 문자열·토큰을 그 안에 넣지 말며, 인가·권한 분리·정책 강제의 보안 경계로 삼지 말라고 적었다. 이 문서의 D1-07 요구사항은 그 원칙을 그대로 반영한다.

4.2 OWASP Top 10 for Agentic Applications (ASI) 2026

2025-12-09 공개된 에이전트 전용 항목이다. 도식이 다루지 않는 멀티 에이전트 고유 위험이 여기에 있다.

ID	항목명	본 문서 대응	도식 포함 여부
ASI01	Agent Goal Hijack	D1-02 지시 탈취, D6-05 목표 불일치	포함
ASI02	Tool Misuse & Exploitation	D3 전체	포함
ASI03	Identity & Privilege Abuse	D5 전체	포함
ASI04	Agentic Supply Chain Vulnerabilities	D7 전체	포함
ASI05	Unexpected Code Execution (RCE)	D3-02 명령 주입, D3-03 시스템 장악	포함
ASI06	Memory & Context Poisoning	D8 전체, D2-07 메모리 잔존	포함
ASI07	Insecure Inter-Agent Communication	**X01 보강 항목**	**공백**
ASI08	Cascading Failures	**X02 보강 항목**	**공백**
ASI09	Human-Agent Trust Exploitation	**X03 보강 항목**	**공백**
ASI10	Rogue Agents	**X04 보강 항목**	**공백**

항목명은 GenAI-LLM-Top10 저장소의 2026/final/mappings/asi-2026.json 에 기록된 표기를 따랐다. 이 파일은 ASI02 를 Tool Misuse & Exploitation, ASI05 를 Unexpected Code Execution (RCE), ASI06 을 Memory & Context Poisoning 으로 적고 있으며, 발표 블로그의 축약 표기와 차이가 있음을 함께 기록하고 있다.

4.3 도메인별 표준 식별자

도메인	OWASP LLM 2026	OWASP ASI 2026	MITRE ATLAS 전술(대표)	NIST AI RMF 기능
D1 프롬프트 인젝션	LLM01	ASI01	AML.TA0011 실행 / AML.TA0005 회피	MEASURE 2.7, MANAGE 4.1
D2 데이터 유출	LLM02	ASI06	AML.TA0010 유출	MAP 5.1, MEASURE 2.10
D3 도구 오남용	LLM03	ASI02, ASI05	AML.TA0011 실행 / AML.TA0012 영향	GOVERN 1.3, MANAGE 2.2
D4 모델 환각	LLM07	(대응 없음)	AML.TA0012 영향	MEASURE 2.3, MEASURE 2.9
D5 접근 통제	LLM02, LLM03	ASI03	AML.TA0004 초기 접근	GOVERN 1.5, MANAGE 2.1
D6 자율성 과잉	LLM03, LLM06	ASI01(부분)	AML.TA0012 영향	GOVERN 1.3, MANAGE 4.2
D7 공급망	LLM04, LLM05	ASI04	AML.TA0002 정찰 / AML.TA0003 자원 개발	MAP 4.1, MANAGE 3.1
D8 메모리·컨텍스트	LLM08, LLM09	ASI06	AML.TA0006 지속성	MEASURE 2.6, MANAGE 2.3
D9 인프라	(범위 밖)	(범위 밖)	ATT&CK 매핑 우선	GOVERN 6.1
D10 거버넌스	(횡단)	(횡단)	(해당 없음)	GOVERN 전 항목

MITRE ATLAS 와 NIST 매핑은 GenAI-LLM-Top10 저장소의 mitre-atlas-2026.06.json, mitre-attack-v19.1.json, nist-ai-rmf-1.0.json, nist-ai-600-1.json 을 근거로 하되, 도메인 단위로 대표 전술만 적었다. 항목 단위 정밀 매핑은 에이전트 매니페스트의 standards 필드에 기계 판독 가능한 형태로 넣는다(11.2 절).

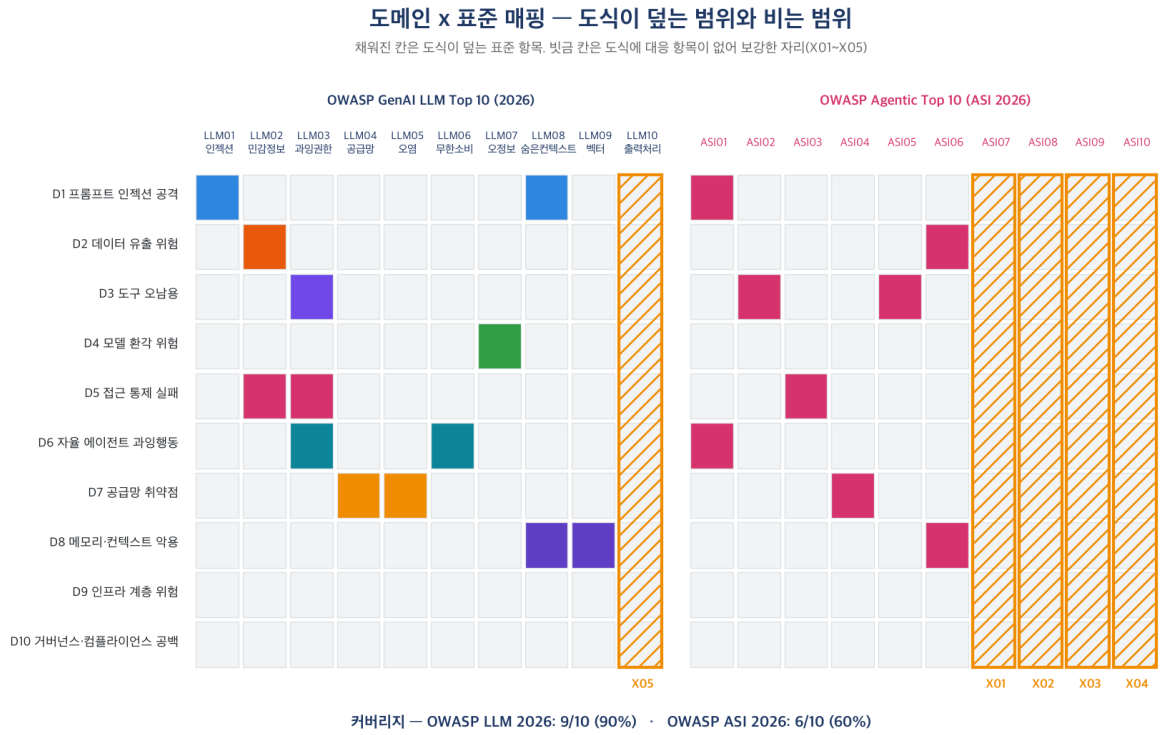


그림 3. 도메인 x 표준 매핑 매트릭스 — 도식 10개 도메인이 OWASP LLM 2026 과 ASI 2026 을 어디까지 덮는지, 어디가 비는지

4.4 규제 매핑

규제·표준	관련 조항	본 문서 대응	증적 산출물

EU AI Act (Regulation (EU) 2024/1689)	제9조 위험관리체계, 제12조 기록보관, 제14조 인적 감독, 제15조 정확성·견고성·사이버보안	D10-03 위험관리, D10-04 감사, D6-01 사람 승인, D4 전체	위험 등록부, 감사 로그, 승인 이력, 평가 보고서
EU AI Act – GPAI	제53조 기술문서·저작권 정책, 제55조 시스템 리스크 모델 평가·적대적 시험	X09 상시 레드팀, D7-06 모델 오염	모델 카드, 레드팀 결과, 사건 보고
ISO/IEC 42001	AI 경영시스템 요구사항(계획·운영·성과평가)	D10 전체	정책 문서, 내부 심사 기록
ISO/IEC 23894	AI 위험관리 지침	D10-03	위험 식별·평가·처리 기록
ISO/IEC 27001 부속서 A	접근통제, 암호화, 공급자 관계, 로깅	D5, D9, D7, D10-04	통제 적용 선언서
NIST SP 800-53 Rev.5	AC, AU, SC, SI, SR 계열	D5, D10-04, D9, D7	통제 매핑표
개인정보보호법(대한민국)	제15조·제17조 처리 근거, 제21조 파기, 제29조 안전성 확보조치	D2-01 민감정보, D2-07 메모리 잔존	처리 근거 기록, 파기 증적, 접근 기록
신용정보법·전자금융거래법	금융 분야 적용 시	D2, D5, D10	업권 통제 매핑(선택 프로파일)

EU AI Act 의 적용 시점은 제113조가 단계별로 정한다. 금지 관행과 AI 리터러시 조항이 2025-02-02, 범용 AI 모델(GPAI) 의무와 거버넌스가 2025-08-02, 부속서 III 고위험 시스템 의무가 2026-08-02 부터 적용된다. 따라서 2026-09 시점에 고위험 분류에 해당하는 조직은 이미 적용 범위 안에 있다. 이 문서는 법률 자문이 아니며, 적용 여부 판단은 법무 검토를 전제로 한다.

4.5 통제 매핑을 코드로 유지하는 이유

표준은 개정된다. 이 장에서 확인한 것처럼 OWASP LLM Top 10 은 2026-08-04 개정으로 열 항목 중 여덟 개의 번호가 흔들렸다. 매핑을 문서 안에만 두면 개정 때마다 문서 전체가 낡는다.

- AegisMesh 는 매핑을 에이전트 매니페스트의 standards 필드와 별도 매핑 파일에 둔다. 문서는 그 파일을 렌더한 결과다.
- 매핑 파일은 프레임워크 판본을 명시한다. 예를 들어 owasp-llm: 2026, owasp-asi: 2026, atlas: 2026.06 처럼 적는다.
- 판본이 바뀌면 매핑 파일만 갱신하고, 검증 스크립트가 매핑 누락을 CI 에서 잡는다. 11.5 절에 그 절차를 둔다.

5. 목표 시스템

5.1 제품 정의

제품명	AegisMesh
한 줄 정의	AI 에이전트의 열 개 위험 영역을 항목 단위 독립 에이전트로 방어하고, 그 판정을 하나의 증적 원장으로 모으는 멀티 에이전트 보안 플랫폼
구성 단위	위험 항목 하나 = 에이전트 하나. 도메인 에이전트 70종, 보강 에이전트 10종, 플랫폼 에이전트 12종 = 92종
핵심 성질	모든 에이전트는 다른 에이전트 없이도 단독 실행된다. 플랫폼은 조립 수단이지 실행 전제가 아니다
대상 사용자	AI 플랫폼 팀, 보안 엔지니어, 규제 대응 담당, 에이전트 애플리케이션 개발자
배포 형태	컨테이너 이미지 + 헬름 차트 + 단일 바이너리 CLI. 폐쇄망 설치 지원
범위 밖	모델 학습·정렬 자체, 일반 애플리케이션 보안(WAF·SAST) 전면 대체, 물리 보안

5.2 운용 3모드

사용자 요구의 핵심은 독립 구동과 연계 구동을 모두 지원하면서, 사용자가 골라 등록하면 바로 쓸 수 있어야 한다는 것이다. 세 모드를 명시적으로 나누고 각 모드의 계약을 다르게 정의한다.

모드	이름	정의	실행 형태	대표 사용 상황
M1	독립(Standalone)	에이전트 하나만 단독 실행한다. 다른 에이전트·플랫폼 구성요소에 대한 의존이 전혀 없다.	CLI 일회 실행 또는 단일 컨테이너 HTTP 서버	CI 에서 프롬프트 인젝션 회귀 시험만 돌린다. 노트북에서 개인정보 탐지만 확인한다.
M2	연계(Composed)	여러 에이전트를 게이트웨이·오케스트레이터 아래 묶어 하나의 판정 흐름으로 만든다.	헬름 릴리스 또는 컴포즈 프로파일. 에이전트 간 통신은 MCP·A2A·REST	운영 중인 에이전트 서비스 앞단에 입력·도구·출력 3관문을 건다.
M3	즉시 사용(Instant)	콘솔에서 항목을 고르고 등록하면 바로 동작한다. 사전 코드 작업이 없다.	프로파일 선택 → 자격증명 입력 → 적용. 내부적으로 M1 또는 M2 로 전개된다	보안 담당자가 규제 요구 항목 12개만 골라 하루 만에 적용한다.

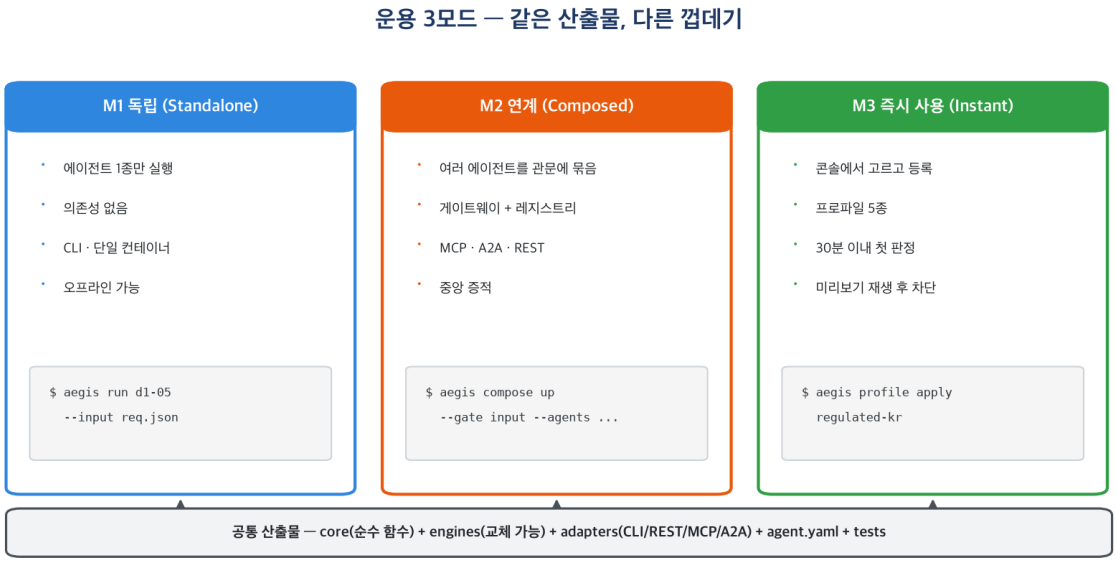


그림 4. 운용 3모드 — 같은 에이전트 산출물이 독립·연계·즉시 사용 세 형태로 전개된다

5.3 세 모드가 같은 산출물을 쓰는 방법

모드마다 다른 코드를 만들면 유지되지 않는다. 에이전트는 하나만 만들고 껍데기만 바꾼다.

1. **코어는 순수 함수다.** 입력 하나를 받아 판정 하나를 낸다. 네트워크·설정·로깅을 코어에 넣지 않는다.
2. **어댑터는 네 개다.** CLI, REST, MCP 서버, A2A 에이전트. 같은 코어를 네 방식으로 노출한다.
3. **매니페스트가 모드를 고른다.** agent.yaml 의 modes 필드가 어떤 어댑터를 켤지 정한다. 코드 변경은 없다.
4. **즉시 사용은 프로파일이다.** M3 는 새 실행 방식이 아니라, 검증된 M1/M2 조합에 이름을 붙인 것이다. 11.4 절에 프로파일 다섯 종을 둔다.

5.4 설계 원칙

번호	원칙	내용	위반 시 증상
DP1	항목이 곧 경계	도식 항목 하나에 에이전트 하나. 하나의 에이전트가 두 항목을 담당하지 않는다.	증적이 항목 단위로 나뉘지 않아 감사 대응이 수작업이 된다
DP2	홀로 서기	모든 에이전트는 플랫폼 없이 단독 실행된다. 플랫폼 호출은 선택 기능이다.	부분 도입이 불가능해져 도입 장벽이 생긴다
DP3	판정은 설명을 동반한다	모든 판정은 근거·신뢰도·규칙 식별자를 함께 낸다. 점수만 내는 판정은 금지한다.	오탐 조정이 불가능하고 규제 설명 책임을 못 채운다
DP4	경로 위와 밖을 나눈다	요청 경로 인라인 에이전트는 지연 예산을 지키고, 상시 에이전트는 정확도를 우선한다.	지연이 튀거나 정확도가 낮은 판정이 인라인에 들어간다
DP5	차단 실패는 안전 쪽으로	C1·C2 계열은 판정 실패 시 차단한다. 단, 모드별로 정책에서 뒤집을 수 있다.	장애 시 방어가 통째로 사라진다
DP6	정책은 코드로	허용·차단·승인요구 규칙은 선언형 정책 파일로 관리하고 버전을 남긴다.	정책이 코드에 흩어져 변경 이력이 사라진다
DP7	표준 식별자를 붙인다	모든 판정에 OWASP·ATLAS·CWE 식별자를 붙인다. 판본을 함께 적는다.	표준 개정 때 전면 재작업이 필요해진다
DP8	탐지기는 교체 가능	각 에이전트의 탐지 엔진은 플러그인이다. 특정 오픈소스에 코드 수준으로 결합하지 않는다.	아카이브·라이선스 변경 한 번에 제품이 멈춘다
DP9	증적은 불변	판정과 행동은 추가 전용 원장에 남긴다. 사후 수정 경로를 만들지 않는다.	감사에서 증적의 신뢰성을 잃는다
DP10	도식 누락은 빌드 실패	도식 80개 항목 중 하나라도 에이전트·요구사항·시험이 비면 CI 가 실패한다.	시간이 지나며 원래 목표에서 조용히 벗어난다

5.5 원칙 DP8 이 필요한 이유

1.3 절의 핵심 발견 3과 5가 그대로 근거다. 도식 항목에 대응하던 대표 도구들이 실제로 죽거나 라이선스가 바뀌었다.

도구	도식 항목 대응	실측 상태(2026-09-17)	대체
protectai/rebuff	D1 프롬프트 인젝션	아카이브, 최신 커밋 2024-01-25	NVIDIA/garak + promptfoo/promptfoo
protectai/llm-guard	D1·D2 입출력 스캔	아카이브, 최신 커밋 2026-07-08	NVIDIA-NeMo/Guardrails + guardrails-ai/guardrails
Azure/PyRIT	D1 레드팀	아카이브(2026-09-16), 스타 4,485	microsoft/PyRIT (4,485★, MIT)
lakeraai/pint-benchmark	D1 벤치마크	아카이브, 최신 커밋 2026-04-02	JailbreakBench/jailbreakbench, centerforaisafety/HarmBench
invariantlabs-ai/mcp-scan	D7 서드파티 도구 심사	snyk/agent-scan 로 이관(상용 업체 흡수)	이관 저장소 유지, 고정 버전 사용 권고
meta-llama/PurpleLlama	D1 분류기 기준선	Llama 3.2 Community License (비OSI)	OSI 라이선스 필요 시 자체 분류기 또는 규칙 기반 병행
Arize-ai/phoenix	관측	Elastic-2.0	comet-ml/opik (Apache-2.0)
hashicorp/vault	D2 자격증명	BUSL-1.1 (Licensor: IBM)	openbao/openbao (MPL-2.0)
minio/minio	증적 객체 저장	아카이브(2026-02-12)	seaweedfs/seaweedfs (Apache-2.0)

탐지 엔진을 플러그인으로 두면 위 표의 왼쪽이 오른쪽으로 바뀔 때 에이전트 인터페이스는 그대로 두고 구현체만 갈아끼운다. 이 문서의 기술 스택(10장)은 기본값을 제시하는 것이지 고정 의존이 아니다.

6. 기능 요구사항

도식 항목 70개는 FR-D 로, 도식 공백 보강 10개는 FR-X 로, 플랫폼 공통 기능 16개는 FR-P 로 전개한다. 합계 96건이다. 서술의 하여야 한다는 필수 요구(SHALL), 하는 것이 좋다는 권고(SHOULD) 를 뜻한다.

6.1 요구사항 표기 규칙

필드	의미	예
ID	FR-(도메인)-(순번). 도식 항목 ID 와 1대1	FR-D1-05
계열	3.14 절의 C1~C4. 배치 관문과 지연 예산을 결정한다	C1
우선순위	P0 1단계 필수, P1 2단계, P2 3단계	P0
판정	에이전트가 내는 결과 유형. allow, block, require_approval, transform, alert 다섯 가지	block 또는 transform
검증	시험 항목 ID. 14장과 11.5 절 검증 스크립트가 참조한다	TC-D1-05

6.2 FR-D1. 프롬프트 인젝션 공격

계열 C1(입력·출력 관문) · 표준 LLM01 / ASI01 · 요구사항 7건

FR ID	대응 항목	요구사항	우선
FR-D1-01	악성 지시 주입	시스템은 웹 페이지·문서·이메일·도구 응답 등 신뢰할 수 없는 콘텐츠에 심어 둔 문장을 모델이 지시로 해석한다(간접 프롬프트 인젝션) 상황을 탐지하여야 한다. 방식은 출처별 신뢰 등급 부여, 데이터/지시 경계 표식(스포트라이팅), 인젝션 분류기 이중 판정 이다.	P0
FR-D1-02	지시 탈취	시스템은 원래 시스템 목표를 덮어써 공격자 목표를 수행하게 만든다 상황을 탐지하여야 한다. 방식은 목표 불변식(goal invariant) 서명·대조, 계획 변경 감지, 단계별 목표 일치도 점수 이다.	P0
FR-D1-03	탈옥 프롬프트	시스템은 안전 정책을 우회하도록 설계된 역할극·인코딩·다단계 템플릿(DAN 계열, GCG 계열 적대 접미사) 상황을 탐지하여야 한다. 방식은 탈옥 코퍼스 유사도 매칭 + 전용 분류기 + 거절 일관성 회귀 시험 이다.	P0
FR-D1-04	컨텍스트 덮어쓰기	시스템은 긴 컨텍스트 후반에 배치한 지시가 앞선 시스템 정책을 무력화한다 상황을 탐지하여야 한다. 방식은 시스템 지시 재삽입(샌드위치), 위치별 순응도 측정, 컨텍스트 세그먼트 권한 표시 이다.	P1
FR-D1-05	은닉 페이로드	시스템은 제로폭 문자·유니코드 태그 블록(ASCII smuggling)·흰 글씨·HTML 주석·이미지 대체텍스트에 지시를 숨긴다 상황을 탐지하여야 한다. 방식은 NFKC 정규화와 비가시 문자 제거, 태그 블록 U+E0000 대역 차단, 렌더 전후 차분 검사 이다.	P0
FR-D1-06	인젝션 경유 유출	시스템은 인젝션으로 마크다운 이미지·링크·도구 호출을 유도해 컨텍스트 내용을 외부로 실어 보낸다 상황을 탐지하여야 한다. 방식은 출력 URL 허용목록, 자동 렌더 차단, 이그레스 프록시에서 파라미터 엔트로피 검사 이다.	P0
FR-D1-07	시스템 프롬프트 유출	시스템은 시스템 지시·도구 스키마·정책 문구가 추출된다 상황을 탐지하여야 한다. 방식은 카나리 토큰 삽입 후 출력 대조, 시스템 지시 유사도 검사, 비밀은 컨텍스트에 두지 않는 설계 원칙 강제 이다.	P0

6.3 FR-D2. 데이터 유출 위험

계열 C3(상시 점검) · 표준 LLM02 / ASI06 · 요구사항 7건

FR ID	대응 항목	요구사항	우선
FR-D2-01	민감정보 노출	시스템은 개인정보·건강정보·영업비밀이 응답에 그대로 실린다 상황을 탐지하여야 한다. 방식은 개체명 인식 기반 탐지 후 마스킹·가명화, 신뢰 구역별 노출 정책, 한국어 전용 사전 병행 이다.	P0
FR-D2-02	세션 간 유출	시스템은 프롬프트 캐시·공유 메모리·임베딩 인덱스를 매개로 다른 사용자·테넌트의 데이터가 섞여 나온다 상황을 탐지하여야 한다. 방식은 캐시 키에 주체·테넌트 식별자 포함, 인덱스 네임스페이스 분리, 교차 조회 회귀 시험 이다.	P0
FR-D2-03	자격증명 유출	시스템은 프롬프트·코드·로그·에러 메시지에 API 키와 토큰이 남는다 상황을 탐지하여야 한다. 방식은 커밋·프롬프트·로그 3중 시크릿 스캔, 동적 시크릿 발급으로 정적 키 제거, 유출 시 자동 폐기 이다.	P0
FR-D2-04	무단 접근	시스템은 권한 없는 문서·테이블·도구 결과가 검색 단계에서 컨텍스트로 들어온다 상황을 탐지하여야 한다. 방식은 검색 이전 권한 프리필터(관계 기반 인가), 결과 후단 재검증, 접근 결정 감사 기록 이다.	P0
FR-D2-05	학습 데이터 재현	시스템은 미세조정·사전학습에 쓰인 원문이 암기되어 추출되거나, 멤버십 추론으로 포함 여부가 드러난다 상황	P1

		을 탐지하여야 한다. 방식은 차등 프라이버시 학습, 중복 제거, 추출·멤버십 공격 자동 시험을 배포 게이트로 편입이다.	
FR-D2-06	로그 취약성	시스템은 관측 도구가 프롬프트·응답 원문을 그대로 적재해 2차 유출 경로가 된다 상황을 탐지하여야 한다. 방식은 수집 파이프라인 단계 마스킹, 페이로드 저장 정책 분리, 보존기한·접근권 분리 이다.	P1
FR-D2-07	메모리 잔존	시스템은 삭제 요청 이후에도 장기 메모리·벡터 인덱스·백업에 사본이 남는다 상황을 탐지하여야 한다. 방식은 메모리 항목 TTL, 삭제 전파(원본·인덱스·캐시·백업), 삭제 증적 발행 이다.	P1

6.4 FR-D3. 도구 오남용

계열 C2(도구 관문) · 표준 LLM03 / ASI02·ASI05 · 요구사항 7건

FR ID	대응 항목	요구사항	우선
FR-D3-01	위험 도구 호출	시스템은 파괴적 인자(전체 삭제, 대량 전송, 결제)로 도구를 호출한다 상황을 탐지하여야 한다. 방식은 인자 스키마 검증 + 사전조건 정책 판정 + 드라이런 후 영향 추정, 임계 초과 시 사람 승인 이다.	P0
FR-D3-02	명령 주입	시스템은 도구 인자에 셸 메타문자를 섞어 임의 명령을 실행한다 상황을 탐지하여야 한다. 방식은 셸 미경유 실행, 인자 허용목록, 위험 패턴 차단, 실행 전 정적 검사 이다.	P0
FR-D3-03	시스템 장악	시스템은 도구 경유 원격 코드 실행으로 호스트를 장악한다(ASI05) 상황을 탐지하여야 한다. 방식은 microVM·사용자 공간 커널 격리, 워크로드별 1회용 샌드박스, 이그레스 기본 차단 이다.	P0
FR-D3-04	파일 조작	시스템은 경로 탈출·심볼릭 링크로 허용 범위 밖 파일을 읽고 쓴다 상황을 탐지하여야 한다. 방식은 경로 정규화·체이닝 검사, 읽기 전용 마운트, seccomp 로 시스템 호출 축소 이다.	P0
FR-D3-05	API 남용	시스템은 정상 권한 안에서 호출 빈도·크기를 남용해 비용과 부하를 유발한다 상황을 탐지하여야 한다. 방식은 주체별 레이트리밋·쿼터·동시성 상한, 비용 단위 과금 관측 이다.	P0
FR-D3-06	권한 상승	시스템은 도구를 연쇄 호출해 원래 부여된 범위를 넘는 권한을 획득한다 상황을 탐지하여야 한다. 방식은 호출마다 토큰 다운스코핑, 위임 체인 기록, 상승 경로 정적 분석 이다.	P0
FR-D3-07	무단 실행	시스템은 등록되지 않았거나 변조된 도구·MCP 서버·스킬이 실행된다 상황을 탐지하여야 한다. 방식은 도구 레지스트리 서명 검증, 설치 전 정적 스캔, 런타임 해시 대조 이다.	P0

6.5 FR-D4. 모델 환각 위험

계열 C1(입력·출력 관문) · 표준 LLM07 / (대응 없음) · 요구사항 7건

FR ID	대응 항목	요구사항	우선
FR-D4-01	허위 출력	시스템은 근거 없는 사실 주장을 자신 있게 생성한다 상황을 탐지하여야 한다. 방식은 근거성 판정기로 문장 단위 검증, 근거 미확보 문장 표시 또는 차단 이다.	P0
FR-D4-02	인용 날조	시스템은 존재하지 않는 논문·조항·URL 을 인용한다 상황을 탐지하여야 한다. 방식은 인용 식별자 실재 확인, 인용문·원문 대조, 미검증 인용 자동 제거 이다.	P1
FR-D4-03	잘못된 결정	시스템은 환각에 근거한 결정이 실제 행동(결제, 배포, 통지)으로 이어진다 상황을 탐지하여야 한다. 방식은 결정 신뢰도 임계값 게이트, 임계 미만 시 사람 승인 경유 이다.	P0
FR-D4-04	논리 오류	시스템은 형식은 맞지만 추론 단계가 어긋난다 상황을 탐지하여야 한다. 방식은 제약 디코딩으로 형식 고정, 검증자 재실행, 자기일관성 표본 비교 이다.	P1
FR-D4-05	규정 위반 출력	시스템은 금지된 조언·표현·미고지 광고 등 규정 위반 문구를 생성한다 상황을 탐지하여야 한다. 방식은 정책 룰 엔진 판정, 도메인 금칙 사전, 위반 시 재작성 또는 차단 이다.	P1
FR-D4-06	오정보 확산	시스템은 잘못된 출력이 다른 에이전트·문서·인덱스로 전파되어 고착된다 상황을 탐지하여야 한다. 방식은 배포 전 게이트, 출처 표기 강제, 전파 경로 추적과 소급 정정 이다.	P1
FR-D4-07	신뢰 침식	시스템은 반복된 오류로 사용자가 시스템 전체를 불신하게 된다 상황을 탐지하여야 한다. 방식은 불확실성 명시, 사용자 피드백 루프, 신뢰 지표 상시 관측과 회귀 경보 이다.	P2

6.6 FR-D5. 접근 통제 실패

계열 C2(도구 관문) · 표준 LLM02·LLM03 / ASI03 · 요구사항 7건

FR ID	대응 항목	요구사항	우선
FR-D5-01	취약 인증	시스템은 정적 API 키·공유 비밀로 에이전트를 인증한다 상황을 탐지하여야 한다. 방식은 OIDC·mTLS 기반 인증,	P0

		워크로드 신원 자동 발급·회전 이다.	
FR-D5-02	인가 파손	시스템은 인가 판단이 애플리케이션 코드에 흩어져 누락과 우회가 생긴다 상황을 탐지하여야 한다. 방식은 정책 결정점 외부화, 관계 기반 인가 모델, 정책 단위 시험 이다.	P0
FR-D5-03	세션 탈취	시스템은 탈취한 베어러 토큰으로 타인 세션을 사용한다 상황을 탐지하여야 한다. 방식은 소유 증명 토큰(DPoP·mTLS 바인딩), 짧은 수명, 이상 위치·기기 감지 이다.	P0
FR-D5-04	신원 위장	시스템은 다른 에이전트를 사칭해 신뢰 관계를 악용한다 상황을 탐지하여야 한다. 방식은 에이전트 카드 서명 검증, 상호 인증, 신원-능력 바인딩 이다.	P0
FR-D5-05	역할 혼동	시스템은 사용자 권한과 에이전트 서비스 권한이 뒤섞여 대리 범위가 흐려진다 상황을 탐지하여야 한다. 방식은 주체·대리자 분리 표기, 위임 체인 명시, 유효 권한은 교집합으로 산정 이다.	P1
FR-D5-06	토큰 오용	시스템은 한 용도로 발급된 토큰이 다른 대상에 재사용된다 상황을 탐지하여야 한다. 방식은 수신자 제한, 1회성·짧은 수명, 사용 이력 감사와 이상 탐지 이다.	P0
FR-D5-07	권한 불일치	시스템은 선언된 권한과 실제 사용 권한이 시간이 지나며 어긋난다(권한 드리프트) 상황을 탐지하여야 한다. 방식은 실사용 권한 수집 후 최소 권한 자동 제안, 미사용 권한 회수 이다.	P1

6.7 FR-D6. 자율 에이전트 과잉행동

계열 C2(도구 관문) · 표준 LLM03·LLM06 / ASI01 · 요구사항 7건

FR ID	대응 항목	요구사항	우선
FR-D6-01	통제 없는 자율성	시스템은 승인 없이 외부에 영향을 주는 행동을 수행한다 상황을 탐지하여야 한다. 방식은 행동 영향 등급별 자율 레벨 정의, 등급 초과 시 사람 승인 경유 이다.	P0
FR-D6-02	재귀 행동	시스템은 에이전트가 자기 자신 또는 하위 에이전트를 반복 생성해 폭증한다 상황을 탐지하여야 한다. 방식은 호출 깊이·팬아웃 상한, 생성 예산, 계보 추적 이다.	P1
FR-D6-03	무한 루프	시스템은 종료 조건을 만족하지 못해 같은 계획을 반복한다 상황을 탐지하여야 한다. 방식은 상태 해시 반복 감지, 진전 없음 판정, 실행 타임아웃과 내구 실행 재개 이다.	P0
FR-D6-04	과업 확대	시스템은 주어진 범위를 넘는 하위 과업을 스스로 추가한다 상황을 탐지하여야 한다. 방식은 과업 범위 계약 명시, 범위 밖 계획 차단, 범위 변경은 승인 사건으로 기록 이다.	P1
FR-D6-05	목표 불일치	시스템은 지표를 만족시키되 의도를 벗어난 방식으로 목표를 달성한다 상황을 탐지하여야 한다. 방식은 목표 불변식 검사, 금지 수단 명시, 정렬 평가 세트 상시 실행 이다.	P1
FR-D6-06	자원 고갈	시스템은 토큰·시간·동시성·저장소를 소진해 서비스와 예산을 무너뜨린다(LLM06) 상황을 탐지하여야 한다. 방식은 주체별 토큰·시간·동시성 쿼터, 백프레셔, 초과 시 강등 실행 이다.	P0
FR-D6-07	금전 피해	시스템은 결제·주문·환불 등 되돌리기 어려운 금전 행동을 잘못 수행한다 상황을 탐지하여야 한다. 방식은 지출 상한과 승인 임계, 되돌릴 수 없는 행동의 2인 승인, 보상 트랜잭션 설계 이다.	P0

6.8 FR-D7. 공급망 취약점

계열 C3(상시 점검) · 표준 LLM04·LLM05 / ASI04 · 요구사항 7건

FR ID	대응 항목	요구사항	우선
FR-D7-01	서드파티 도구	시스템은 심사 없이 외부 MCP 서버·스킬·플러그인을 연결한다 상황을 탐지하여야 한다. 방식은 등록 전 정적·동적 심사, 서명·출처 확인, 레지스트리 승인 워크플로 이다.	P0
FR-D7-02	의존성 취약	시스템은 라이브러리 취약점이 에이전트 런타임으로 그대로 들어온다 상황을 탐지하여야 한다. 방식은 SBOM 생성과 취약점 대조, 빌드 게이트, 취약 버전 자동 차단 이다.	P0
FR-D7-03	라이브러리 백도어	시스템은 설치 스크립트·난독화 코드로 악성 행위를 심은 패키지를 사용한다 상황을 탐지하여야 한다. 방식은 패키지 휴리스틱 탐지, 설치 시 동적 행위 관찰, 신규·저신뢰 패키지 격리 이다.	P1
FR-D7-04	플러그인 취약	시스템은 플러그인이 과도한 권한을 요구하거나 프롬프트 주입 통로가 된다 상황을 탐지하여야 한다. 방식은 권한 선언 강제, 플러그인 샌드박스, 프롬프트 표면 스캔 이다.	P1
FR-D7-05	데이터셋 변조	시스템은 학습·RAG 데이터가 조용히 바뀌어 모델 행동이 오염된다 상황을 탐지하여야 한다. 방식은 데이터 버전 관리와 콘텐츠 해시, 변경 승인, 오염 탐지 통계 이다.	P1
FR-D7-06	모델 오염	시스템은 가중치 파일 자체가 변조되거나 역직렬화 시 코드를 실행한다 상황을 탐지하여야 한다. 방식은 모델 서명·검증, 안전 직렬화 형식 강제, 역직렬화 스캐너 이다.	P0
FR-D7-07	API 침해	시스템은 상위 API 공급자 또는 중간 경로가 침해되어 응답이 조작된다 상황을 탐지하여야 한다. 방식은 이그레스 허용목록과 인증서 고정, 응답 무결성 검증, 공급망 증명 확인 이다.	P0

6.9 FR-D8. 메모리·컨텍스트 악용

계열 C1(입력·출력 관문) · 표준 LLM09·LLM08 / ASI06 · 요구사항 7건

FR ID	대응 항목	요구사항	우선
FR-D8-01	컨텍스트 오염	시스템은 검색된 문서·도구 응답에 실린 조작 내용이 현재 판단을 왜곡한다 상황을 탐지하여야 한다. 방식은 출처 신뢰 등급, 컨텍스트 구획 분리, 삽입 콘텐츠 인젝션 스캔 이다.	P0
FR-D8-02	장기 조작	시스템은 여러 세션에 걸쳐 조금씩 메모리를 바꿔 장기 행동을 유도한다 상황을 탐지하여야 한다. 방식은 메모리 쓰기 승인 정책, 변경 이력·차분 검토, 이상 변동 탐지 이다.	P1
FR-D8-03	지속 익스플로잇	시스템은 한 번 심긴 악성 지시가 메모리에 남아 매 세션 재실행된다 상황을 탐지하여야 한다. 방식은 저장 메모리 정기 재스캔, 만료 정책, 재실행 전 무해화 이다.	P1
FR-D8-04	저장형 프롬프트 공격	시스템은 지시문이 데이터로 저장되었다가 나중에 실행된다(저장형 XSS 의 LLM 판) 상황을 탐지하여야 한다. 방식은 저장 시점 스캔과 무해화, 읽기 시점 재검사, 실행 가능 텍스트 표식 제거 이다.	P0
FR-D8-05	지식 주입	시스템은 인덱싱 파이프라인에 위조 문서를 밀어 넣어 검색 결과를 장악한다 상황을 탐지하여야 한다. 방식은 수집 경로 인증, 문서 서명, 색인 변경 감사와 이상 급증 탐지 이다.	P1
FR-D8-06	메모리 손상	시스템은 메모리 레코드가 부분 손상·중복·충돌해 잘못된 사실이 고착된다 상황을 탐지하여야 한다. 방식은 체크섬과 불변 로그, 충돌 해소 규칙, 복구 지점 유지 이다.	P1
FR-D8-07	검색 편향	시스템은 특정 출처가 과대 대표되어 결론이 한쪽으로 기운다 상황을 탐지하여야 한다. 방식은 검색 품질·다양성 지표 상시 측정, 출처 분포 감사, 리랭커 편향 시험 이다.	P2

6.10 FR-D9. 인프라 계층 위험

계열 C3(상시 점검) · 표준 (LLM 범위 밖) / (ASI 범위 밖) · 요구사항 7건

FR ID	대응 항목	요구사항	우선
FR-D9-01	클라우드 오구성	시스템은 공개 버킷·과대 IAM·미암호화 저장소 등 기본 설정이 위험하게 남는다 상황을 탐지하여야 한다. 방식은 클라우드 상태 점검 정기 실행, IaC 정적 검사, 위반 자동 차단 이다.	P0
FR-D9-02	서버 침해	시스템은 런타임 침해로 에이전트 호스트가 장악된다 상황을 탐지하여야 한다. 방식은 커널 이벤트 기반 런타임 탐지, 무결성 감시, 침해 시 자동 격리 이다.	P0
FR-D9-03	암호화 공백	시스템은 내부 구간 평문 통신, 저장 데이터 미암호화, 인증서 만료가 남는다 상황을 탐지하여야 한다. 방식은 상호 TLS 기본화, 인증서 자동 발급·회전, 저장 암호화 강제 이다.	P0
FR-D9-04	데이터베이스 노출	시스템은 에이전트가 직접 접속하는 DB 계정이 과대 권한을 갖는다 상황을 탐지하여야 한다. 방식은 DB 접근 게이트웨이 경유, 변경 승인 워크플로, 쿼리 감사 이다.	P1
FR-D9-05	엔드포인트 침해	시스템은 개발자 워크스테이션·러너가 침해되어 에이전트 자격증명이 유출된다 상황을 탐지하여야 한다. 방식은 호스트 관측·무결성 점검, 자격증명 하드웨어 보관, 단기 세션 이다.	P2
FR-D9-06	네트워크 가로채기	시스템은 중간자 공격이나 잘못된 라우팅으로 트래픽이 가로채진다 상황을 탐지하여야 한다. 방식은 이그레스 정책 기본 차단, 상호 인증, 네트워크 흐름 관측 이다.	P1
FR-D9-07	서비스 거부	시스템은 대량 요청으로 추론 백엔드와 도구를 마비시킨다 상황을 탐지하여야 한다. 방식은 엣지 레이트리밋과 평판 기반 차단, 대기열·우선순위, 자동 확장 한계 설정 이다.	P1

6.11 FR-D10. 거버넌스·컴플라이언스 공백

계열 C4(증적 관문) · 표준 (횡단) / (횡단) · 요구사항 7건

FR ID	대응 항목	요구사항	우선
FR-D10-01	정책 부재	시스템은 무엇을 허용하고 무엇을 막는지 문서와 코드 어디에도 없다 상황을 탐지하여야 한다. 방식은 정책을 코드로 선언하고 버전 관리, 기본 거부 베이스라인 배포 이다.	P0
FR-D10-02	규제 위반	시스템은 EU AI Act·개인정보보호법·업권 규제 요구를 충족하지 못한다 상황을 탐지하여야 한다. 방식은 규제 통제 항목을 시스템 통제에 매핑하고 증적 자동 수집 이다.	P1
FR-D10-03	위험관리 부실	시스템은 위험 식별·평가·수용 결정이 기록되지 않아 재현되지 않는다 상황을 탐지하여야 한다. 방식은 위험 등록부 운영, 점수 체계 적용, 수용 결정에 책임자와 기한 기록 이다.	P1
FR-D10-04	감사 실패	시스템은 사후에 누가 무엇을 왜 했는지 재구성할 수 없다 상황을 탐지하여야 한다. 방식은 행동 단위 불변 감사	P0

		로그, 결정 근거 보관, 재현 가능한 추적 식별자 이다.	
FR-D10-05	윤리 맹점	시스템은 특정 집단에 불리한 결과를 지표로 잡아내지 못한다 상황을 탐지하여야 한다. 방식은 공정성 지표 정례 측정, 집단별 성능 분해, 영향 평가 문서화 이다.	P2
FR-D10-06	투명성 결여	시스템은 모델·데이터·제약이 문서화되지 않아 설명할 수 없다 상황을 탐지하여야 한다. 방식은 시스템·모델 카드 자동 생성, 변경 시 갱신 강제, 이해관계자 공개 이다.	P2
FR-D10-07	모니터링 부재	시스템은 운영 중 품질·안전 저하를 감지할 상시 관측이 없다 상황을 탐지하여야 한다. 방식은 안전·품질 지표 상시 수집, 임계 경보, 회귀 시 자동 롤백 이다.	P1

6.12 FR-X. 도식 공백 보강 요구사항

FR ID	항목	요구사항	우선
FR-X01	에이전트 간 통신 보안	시스템은 에이전트 간 호출을 상호 인증하고 메시지 무결성을 검증하여야 한다. A2A 에이전트 카드 서명과 MCP 서버 신원 검증을 포함한다.	P0
FR-X02	연쇄 실패	시스템은 한 에이전트의 오류 출력이 다른 에이전트 입력으로 전파되는 경로를 추적하고, 임계 초과 시 전파를 차단하여야 한다.	P1
FR-X03	사람-에이전트 신뢰 악용	시스템은 에이전트가 사람에게 승인·자격증명·예외 처리를 요구하는 상호작용을 기록하고, 반복·유도 패턴을 탐지하여야 한다.	P1
FR-X04	이탈 에이전트	시스템은 등록되지 않은 에이전트와 종료되지 않은 에이전트를 탐지하고 강제 종료 수단을 제공하여야 한다.	P0
FR-X05	출력 처리 부실	시스템은 모델 출력이 하위 시스템에서 코드·질의·명령·마크업으로 해석될 위험을 검사하고 무해화하여야 한다(LLM10).	P0
FR-X06	멀티모달 공격면	시스템은 이미지·오디오·PDF·오피스 문서 내부에 포함된 지시문과 메타데이터를 추출해 인젝션 검사 대상에 포함하여야 한다.	P1
FR-X07	모델·추론 계층 위험	시스템은 모델 추출 시도, 추론 서버 자체 취약점, 양자화·병합 산출물의 무결성을 점검하여야 한다.	P1
FR-X08	사고 대응·포렌식	시스템은 탐지 이후의 봉쇄·근절·복구 절차를 실행 가능한 런북으로 제공하고, 사건 재현에 필요한 입력·컨텍스트·판정을 보존하여야 한다.	P0
FR-X09	상시 레드팀	시스템은 공격 시나리오 묶음을 주기·배포 시점에 자동 실행하고, 방어 회귀를 배포 게이트로 차단하여야 한다.	P1
FR-X10	비용·서비스 수준 관측	시스템은 방어 자체가 유발하는 지연·비용·오탐률을 측정하고 예산 대비 초과 시 경보하여야 한다.	P1

6.13 FR-P. 플랫폼 요구사항

FR ID	구분	요구사항	우선
FR-P01	게이트웨이	시스템은 요청·도구 호출·응답이 지나는 인라인 관문을 제공하고, 각 관문에서 등록된 에이전트를 호출하여야 한다.	P0
FR-P02	정책 결정	시스템은 정책을 선언형 파일로 평가하는 결정점을 제공하고, allow·block·require_approval·transform 판정을 반환하여야 한다.	P0
FR-P03	레지스트리	시스템은 에이전트·도구·모델·정책을 등록하고 서명·버전·가용성을 관리하여야 한다.	P0
FR-P04	오케스트레이션	시스템은 하나의 판정 요청을 여러 에이전트에 병렬 분배하고 타임아웃·강등 규칙에 따라 결과를 합성하여야 한다.	P0
FR-P05	증적 원장	시스템은 모든 판정·행동·승인을 추가 전용 원장에 적재하고 변조 탐지를 제공하여야 한다.	P0
FR-P06	상관 분석	시스템은 개별 발견을 사건 단위로 묶고 동일 원인·연쇄 관계를 식별하여야 한다.	P1
FR-P07	신원·비밀	시스템은 에이전트 워크로드 신원을 자동 발급·회전하고 동적 시크릿을 제공하여야 한다.	P0
FR-P08	샌드박스	시스템은 격리 등급별 실행 환경을 요청 단위로 발급·회수하여야 한다.	P0
FR-P09	관측	시스템은 지표·추적·로그를 OpenTelemetry 규약으로 내보내고, 수집 단계에서 민감정보를 마스킹하여야 한다.	P0
FR-P10	레드팀 스케줄러	시스템은 공격 시나리오를 주기 실행하고 결과를 회귀 기준선과 비교하여야 한다.	P1
FR-P11	컴플라이언스 보고	시스템은 통제·규제 매핑을 유지하고 증적에서 보고서를 자동 생성하여야 한다.	P1
FR-P12	콘솔·장터	시스템은 항목을 골라 등록하면 즉시 적용되는 화면을 제공하여야 한다.	P0
FR-P13	다중 테넌시	시스템은 테넌트별 정책·증적·인덱스를 분리하고 교차 접근을 차단하여야 한다.	P1
FR-P14	폐쇄망 운영	시스템은 외부 네트워크 없이 설치·갱신·서명 검증이 가능하여야 한다.	P1

FR-P15	강등 운영	시스템은 일부 에이전트 장애 시 정책에 따라 차단 또는 통과로 강등 동작하고 그 사실을 증적에 남겨야 한다.	P0
FR-P16	누락 검증	시스템은 도식 80개 항목 대비 에이전트·요구사항·시험의 누락을 CI 에서 검사하고 누락 시 빌드를 실패시켜야 한다.	P0

6.14 우선순위 집계

우선순위	의미	FR-D	FR-X	FR-P	합계
P0	1단계 필수. 이것 없이는 배포하지 않는다	39	4	11	54
P1	2단계. 운영 안정화 단계에서 채운다	26	6	5	37
P2	3단계. 성숙 단계에서 채운다	5	0	0	5
합계		**70**	**10**	**16**	**96**

7. 비기능 요구사항

보안 판정 시스템에서 가장 먼저 무너지는 것은 성능이 아니라 신뢰다. 오탐이 잦으면 사용자는 방어를 끈다. 미탐이 있으면 방어가 있는 줄 알면서 뚫린다. 따라서 이 문서는 판정 품질(NFR-Q)을 최상위 비기능 요구로 두고, 지연·가용성은 그 아래에 배치한다.

7.1 NFR-Q 판정 품질 (최상위)

ID	요구	목표값	측정 방법	미달 시 조치
NFR-Q1	인라인 차단 에이전트의 오탐률	정상 트래픽 표본 대비 0.5% 이하	주간 골든셋 1만 건 재생 후 차단 건 수동 표본 검수	임계 상향 또는 해당 에이전트를 경보 전용으로 강등
NFR-Q2	공개 공격 코퍼스 미탐률	프롬프트 인젝션·탈옥 코퍼스 대비 10% 이하	JailbreakBench, HarmBench, garak 프로브 정기 실행	탐지 엔진 교체 또는 다중 판정기 합의 방식으로 전환
NFR-Q3	판정 설명 제공률	100%	판정 레코드에 rule_id, evidence, confidence 필드 존재 여부 검사	필드 누락 판정은 무효 처리하고 기본 정책 적용
NFR-Q4	판정 재현성	동일 입력·동일 버전에서 100% 동일 판정	동일 입력 3회 재생 비교	비결정 요소(모델 온도, 시간 의존 규칙) 제거
NFR-Q5	회귀 방지	직전 기준선 대비 탐지율 하락 0건	배포 전 회귀 시험 게이트	배포 차단
NFR-Q6	오탐 예산 소진 경보	일 단위 오탐 예산의 80% 도달 시 경보	오탐 카운터 상시 집계	운영자 통지 및 자동 임계 조정 제안

7.2 NFR-L 지연

ID	대상	예산(p95)	초과 시 동작
NFR-L1	입력 관문 전체(C1 에이전트 합산)	80ms	정책에 따라 차단 또는 통과. 어느 쪽이든 증적 기록
NFR-L2	도구 관문 전체(C2 에이전트 합산)	20ms	차단(기본값). 도구 호출은 되돌리기 어렵다
NFR-L3	출력 관문 전체	150ms	스트리밍 응답은 청크 단위 판정으로 분할
NFR-L4	단일 에이전트 판정	인라인 30ms, 상시 무제한	인라인 초과 에이전트는 상시 계열로 재배치
NFR-L5	증적 적재	비동기, 요청 경로 차단 금지	버퍼 포화 시 표본 적재로 강등하고 강등 사실을 기록

지연 예산은 관문 단위 합산이다. 한 관문에 에이전트를 열 개 붙이면 각각 8ms 안에 끝나야 한다는 뜻이다. 따라서 인라인 에이전트는 모델 호출을 기본으로 삼지 않는다. 규칙·분류기·임베딩 유사도처럼 결정적이고 빠른 방식을 우선하고, 모델 기반 판정은 상시 계열이나 2차 판정에만 쓴다.

7.3 NFR-A 가용성과 강등

ID	요구	목표
NFR-A1	플랫폼 가용성	월 99.9%. 게이트웨이는 무상태로 수평 확장
NFR-A2	에이전트 장애 격리	에이전트 한 종의 장애가 다른 에이전트 판정에 영향을 주지 않는다
NFR-A3	강등 정책	에이전트별로 fail_open 또는 fail_closed 를 매니페스트에 명시. 기본값은 계열 C1·C2 는 closed, C3·C4 는 open
NFR-A4	부분 가동	플랫폼 구성요소(레지스트리·콘솔) 장애 시에도 이미 배포된 에이전트는 계속 판정한다
NFR-A5	복구 목표	RTO 30분, RPO 5분. 증적 원장은 RPO 0 을 목표로 동기 복제

7.4 NFR-I 격리

도구 실행과 레드팀 실행은 실제 악성 입력을 다룬다. 격리 수준을 등급으로 정의하고 에이전트마다 최소 등급을 강제한다.

등급	격리 수단	네트워크	적용 대상
L0	동일 프로세스	전체 허용	순수 계산 판정(정규화, 패턴 매칭). 외부 입력을 실행하지 않는 경우에 한한다
L1	별도 컨테이너, 읽기 전용 루트, seccomp 프로파일	허용목록	대부분의 탐지 에이전트
L2	사용자 공간 커널 또는 microVM	기본 차단, 명시 허용만	도구 실행 대리, 코드 실행 판정
L3	1회용 microVM, 스냅샷 후 폐기, 물리 분리 노드	완전 차단	레드팀 실행, 악성 페이로드 재현, 미지 플러그인 최초 실행

7.5 NFR-S 자체 보안

- **보안 시스템이 공격 표면이 된다.** 모든 판정 요청은 원문 프롬프트를 담는다. 판정 경로 자체가 최고 등급 데이터 취급 대상이다.
- **증적 원장은 추가 전용이다.** 삭제·수정 API 를 제공하지 않는다. 보존기한 만료는 별도 승인 절차를 거친 배치로만 수행한다.
- **에이전트 간 호출은 상호 인증한다.** 내부망이라는 이유로 인증을 생략하지 않는다(FR-X01).
- **공급망은 스스로에게도 적용한다.** 자체 릴리스는 SBOM 을 첨부하고 서명한다. 서명 검증 실패 시 기동하지 않는다.
- **레드팀 자산은 분리 보관한다.** 공격 코퍼스와 익스플로잇은 별도 저장소와 권한으로 관리하고 운영 클러스터에 상주시키지 않는다.

7.6 NFR-P 확장성 · NFR-O 운영성 · NFR-C 이식성

ID	요구	목표
NFR-P1	처리량	게이트웨이 노드당 초당 2,000 판정 요청. 수평 확장으로 선형 증가
NFR-P2	에이전트 수	단일 설치에서 동시 등록 200종, 활성 100종
NFR-P3	증적 적재량	일 10억 건 판정 레코드를 30일 온라인 보존
NFR-O1	설치 시간	M3 프로파일 기준 30분 이내 첫 판정
NFR-O2	무중단 갱신	에이전트 개별 롤링 교체. 게이트웨이 재기동 없이 반영
NFR-O3	관측 표준	OpenTelemetry 규약 준수. 벤더 고유 형식 강제 금지
NFR-O4	정책 변경 반영	정책 배포 후 10초 이내 전 노드 반영
NFR-C1	런타임 이식성	쿠버네티스, 도커 컴포즈, 단일 호스트 세 형태 모두 지원
NFR-C2	모델 독립성	특정 모델 공급자에 고정되지 않는다. 자체 호스팅 모델만으로 전 기능 동작
NFR-C3	폐쇄망	외부 인터넷 없이 설치·갱신 가능. 서명 검증은 내부 신뢰 저장소 사용
NFR-C4	언어	콘솔·보고서 한국어·영어 동시 지원

7.7 NFR-D 데이터 보호

ID	요구	목표
NFR-D1	판정 페이로드 보존	기본 미보존. 보존은 명시적 설정으로만 켜지며 보존 시 자동 마스킹
NFR-D2	저장 암호화	증적·설정·시크릿 전 구간 암호화. 키는 외부 관리 시스템 위임
NFR-D3	전송 암호화	모든 내부 구간 상호 TLS
NFR-D4	데이터 잔존	삭제 요청 시 원본·인덱스·캐시·백업까지 전파(D2-07 과 동일 규격)
NFR-D5	국외 이전	기본값은 국내 처리. 외부 모델 호출은 정책에서 명시 허용한 경우로 한정

8. 아키텍처

8.1 7계층 구조

계층	이름	책임	대표 구성요소
L7	표현·장터	항목 선택, 등록, 프로파일 배포, 보고서 열람	콘솔, 카탈로그 UI, 보고서 생성기
L6	거버넌스·증적	통제-규제 매핑, 불변 원장, 감사 질의	증적 원장, 컴플라이언스 보고, 위험 등록부
L5	판정 에이전트	위험 항목별 탐지·차단 판정	도메인 에이전트 70종 + 보강 10종
L4	오케스트레이션	판정 분배, 합성, 타임아웃·강등, 상관 분석	오케스트레이터, 상관 분석기, 발견 버스
L3	데이터 평면	요청·도구 호출·응답을 가로채는 인라인 관문	게이트웨이, 관문 4종, 정책 결정점
L2	실행 기반	격리 실행, 신원·비밀, 레지스트리	샌드박스 브로커, 신원 발급, 에이전트·도구 레지스트리
L1	인프라	컴퓨트, 저장, 네트워크, 관측 수집	쿠버네티스, 객체 저장, 메시지 버스, 관측 수집기

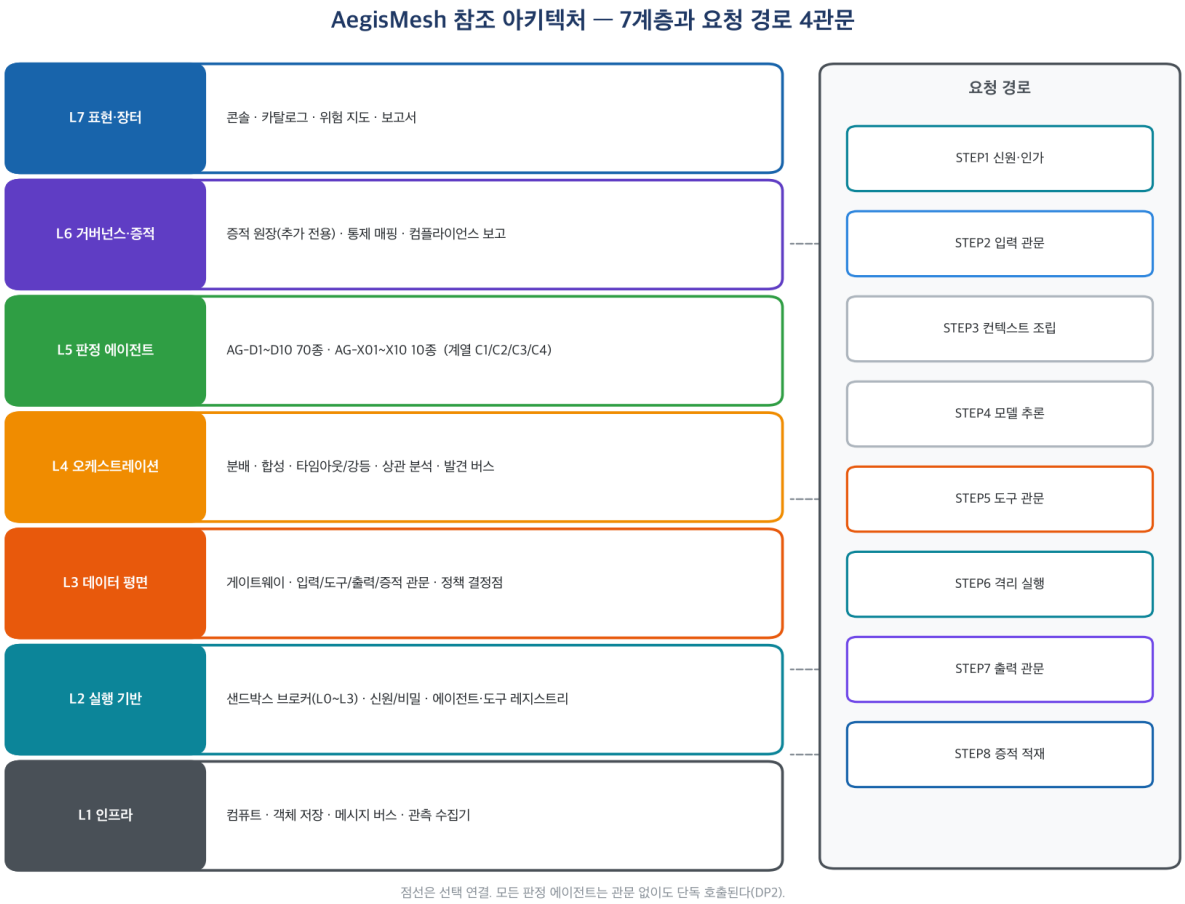


그림 5. 참조 아키텍처 — 7계층과 요청 경로 4관문. 점선은 선택 연결이며, 모든 판정 에이전트는 관문 없이도 단독 호출된다.

8.2 요청 경로와 4관문

에이전트 애플리케이션의 한 번의 요청은 아래 순서를 지난다. 각 관문은 등록된 에이전트를 병렬 호출하고 판정을 합성한다.

단계	이름	지나는 관문	호출되는 계열	차단 시 결과
STEP0	요청 수신	-	-	-

STEP1	신원·인가 확인	입력 관문 전단	D5	401 또는 403
STEP2	입력 검사	입력 관문	D1 7종, D8 7종, X06	요청 거부 또는 입력 무해화
STEP3	컨텍스트 조립	-	D8-01·D8-05 재호출(검색 결과 검사)	오염 문서 제외
STEP4	모델 추론	-	-	-
STEP5	도구 호출 판정	도구 관문	D3, D5, D6, X01	호출 거부 또는 사람 승인 대기
STEP6	도구 실행	격리 실행	D3(샌드박스 등급 강제)	실행 실패로 반환
STEP7	출력 검사	출력 관문	D4 7종, X05, D2-01(인라인 겸용)	응답 차단 또는 마스킹·재작성
STEP8	증적 적재	증적 관문	D10, 전 계열 판정 기록	적재 실패는 경보(요청은 차단하지 않는다)

상시 계열(C3)의 D2·D7·D9 는 이 경로 밖에서 주기·이벤트로 돈다. 다만 발견은 같은 발견 버스로 들어와 같은 증적 원장에 쌓이고, 필요 시 인라인 정책을 동적으로 바꾼다. 예를 들어 D7 이 특정 MCP 서버의 서명 위반을 발견하면 도구 관문의 허용목록에서 즉시 제외된다.

8.3 에이전트 공통 골격

92종의 에이전트는 모두 같은 다섯 부분으로 이루어진다. 새 에이전트를 추가할 때 작성하는 것은 core 와 manifest 둘뿐이다.

부분	역할	구현 형태	작성 주체
core	판정 로직. 입력 하나를 받아 Finding 하나를 낸다	순수 함수. 네트워크·전역 상태 금지	에이전트 작성자
engines	실제 탐지 엔진 어댑터. 교체 가능(DP8)	플러그인 인터페이스 구현	에이전트 작성자 또는 커뮤니티
adapters	CLI, REST, MCP 서버, A2A 에이전트 네 종	공통 라이브러리가 제공. 코드 작성 없음	플랫폼
manifest	agent.yaml. 신원·능력·정책 기본값·표준 매핑·격리 등급	선언형 파일	에이전트 작성자
harness	시험 골격. 골든셋·공격 코퍼스·회귀 기준선	공통 라이브러리 + 항목별 데이터	에이전트 작성자

```
agents/d1-05-hidden-payloads/
├── agent.yaml              # 매니페스트 (11.2 절 규격)
├── core.py                 # detect(ctx: Input) -> Finding   ← 유일한 필수 구현
├── engines/
│   ├── unicode_rules.py    # 기본 엔진: NFKC 정규화 + 태그 블록 탐지
│   └── garak_probe.py      # 선택 엔진: 외부 도구 위임
├── policy/default.rego     # 기본 정책 (조직이 덮어쓴다)
├── tests/
│   ├── golden/             # 정상 입력 (오탐 측정용)
│   ├── attacks/            # 공격 입력 (미탐 측정용)
│   └── baseline.json       # 회귀 기준선
└── Dockerfile              # 공통 베이스 이미지 상속
```

8.4 에이전트 실행 형태

```
# M1 독립 — 설치 없이 한 번 실행
$ aegis run d1-05 --input request.json
{"verdict":"block","rule_id":"D1-05.unicode-tag","confidence":0.97,
 "evidence":[{"offset":142,"len":18,"kind":"unicode-tag-block"}],
 "standards":{"owasp-llm-2026":"LLM01","owasp-asi-2026":"ASI01"}}

# M1 독립 — 상주 서버로
$ docker run -p 8080:8080 ghcr.io/aegismesh/d1-05-hidden-payloads:1.0.0
$ curl -s localhost:8080/v1/judge -d @request.json

# M1 독립 — MCP 서버로 (코딩 에이전트에 직접 물린다)
$ aegis serve d1-05 --protocol mcp --stdio
```

```
# M2 연계 — 관문에 여러 에이전트를 묶는다
$ aegis compose up --gate input --agents d1-01,d1-02,d1-03,d1-05,d1-07,x06

# M3 즉시 사용 — 검증된 프로파일을 적용
$ aegis profile apply regulated-kr --target prod
```

8.5 배포 토폴로지

토폴로지	구성	적용 상황	장단점
T1 사이드카	에이전트를 애플리케이션 파드의 사이드카로 배치	단일 서비스 보호, 낮은 지연이 최우선	지연 최소. 에이전트 수만큼 자원 증가
T2 중앙 게이트웨이	게이트웨이 클러스터가 판정을 대행	여러 서비스 공통 적용, 정책 일원화	운영 단순. 게이트웨이가 단일 실패 지점이 되지 않도록 다중화 필요
T3 혼합	C2 도구 관문은 사이드카, C1 입출력 관문은 중앙	권장 기본값	지연 민감 구간만 사이드카로 당긴다
T4 오프라인	상시 계열만 배치하고 인라인 관문 없음	도입 초기, 관측 우선	차단 없이 가시성만 확보. 1단계 도입에 적합

8.6 실패 모드와 강등

실패	기본 동작	근거
인라인 에이전트 타임아웃	계열 C1·C2 는 차단, C3·C4 는 통과	되돌리기 어려운 행동은 막는 쪽이 안전하다
정책 결정점 장애	마지막으로 배포된 정책 스냅샷으로 로컬 판정	정책 서버 장애가 전면 차단으로 번지지 않게 한다
증적 원장 장애	요청은 계속 처리하고 로컬 버퍼에 적재 후 재전송	증적 때문에 서비스가 멈추면 증적을 끄게 된다
레지스트리 장애	기존 배포 상태 유지. 신규 등록만 중단	L2 장애가 L5 판정을 막지 않는다
에이전트 대량 오탐	오탐 예산 초과 시 자동으로 경보 전용으로 강등	사용자가 방어를 통째로 끄는 것보다 낫다
샌드박스 고갈	도구 실행 대기열 적용. 임계 초과 시 도구 호출 거부	격리 없는 실행으로 강등하지 않는다

마지막 줄이 중요하다. 자원이 부족하다는 이유로 격리 등급을 낮추는 강등은 허용하지 않는다. 격리는 성능과 맞바꿀 수 있는 항목이 아니다.

9. 에이전트 카탈로그

도식 항목 하나에 에이전트 하나라는 원칙(DP1)에 따라 92종을 정의한다. 모든 에이전트는 동일한 다섯 부분 골격(8.3 절)을 가지며, 아래 표의 기본 엔진은 교체 가능한 기본값이다(DP8). 저장소 표기는 2026-09-17 실측 기준 현행 경로이고, 별표는 사용자 즐겨찾기 교차 항목이다.

9.1 카탈로그 읽는 법

열	의미
에이전트 ID	AG-(항목 ID). 컨테이너 이미지 태그와 동일하다
계열	C1 입출력 인라인 / C2 도구 인라인 / C3 상시 / C4 증적
격리	7.4 절의 최소 격리 등급. 이보다 낮은 등급으로 실행하면 기동을 거부한다
판정	이 에이전트가 낼 수 있는 판정 유형
기본 탐지 엔진	초기 설치 시 활성화되는 오픈소스. 첫 번째가 기본값이고 나머지는 선택

9.2 AG-D1 스쿼드 — 프롬프트 인젝션 공격

에이전트 ID	담당 항목	계열	격리	판정	기본 탐지 엔진(교체 가능)
AG-D1-01	악성 지시 주입	C1	L1	block / transform	NVIDIA/garak NVIDIA-NeMo/Guardrails * meta-llama/PurpleLlama
AG-D1-02	지시 탈취	C1	L1	block / transform	invariantlabs-ai/invariant snyk/agent-scan
AG-D1-03	탈옥 프롬프트	C1	L1	block / transform	verazuo/jailbreak_llms * EasyJailbreak/EasyJailbreak * JailbreakBench/jailbreakbench
AG-D1-04	컨텍스트 덮어쓰기	C1	L1	block / transform	NVIDIA/garak promptfoo/promptfoo
AG-D1-05	은닉 페이로드	C1	L1	block / transform	NVIDIA/garak guardrails-ai/guardrails
AG-D1-06	인젝션 경유 유출	C1	L1	block / transform	luckyPipewrench/pipelock * agentgateway/agentgateway
AG-D1-07	시스템 프롬프트 유출	C1	L1	block / transform	NVIDIA/garak promptfoo/promptfoo praetorian-inc/augustus *

9.3 AG-D2 스쿼드 — 데이터 유출 위험

에이전트 ID	담당 항목	계열	격리	판정	기본 탐지 엔진(교체 가능)
AG-D2-01	민감정보 노출	C3	L1	alert / block	data-privacy-stack/presidio Marker-Inc-Korea/ko-pii *
AG-D2-02	세션 간 유출	C3	L1	alert / block	openfga/openfga caura-ai/caura *
AG-D2-03	자격증명 유출	C3	L1	alert / block	gitleaks/gitleaks trufflesecurity/trufflehog * Yelp/detect-secrets
AG-D2-04	무단 접근	C3	L1	alert / block	openfga/openfga authzed/spicedb
AG-D2-05	학습 데이터 재현	C3	L1	alert / block	meta-pytorch/opacus privacytrustlab/ml_privacy_meter google/differential-privacy *
AG-D2-06	로그 취약성	C3	L1	alert / block	fluent/fluent-bit * data-privacy-stack/presidio
AG-D2-07	메모리 잔존	C3	L1	alert / block	letta-ai/letta * mem0ai/mem0 * MemTensor/MemOS *

9.4 AG-D3 스쿼드 — 도구 오남용

에이전트 ID	담당 항목	계열	격리	판정	기본 탐지 엔진(교체 가능)
AG-D3-01	위험 도구 호출	C2	L2	block / require_approval	open-policy-agent/opa cerbos/cerbos
AG-D3-02	명령 주입	C2	L2	block / require_approval	anthropics/sandbox-runtime * containers/bubblewrap
AG-D3-03	시스템 장악	C2	L2	block / require_approval	google/gvisor firecracker-microvm/firecracker superradcompany/microsandbox *
AG-D3-04	파일 조작	C2	L2	block / require_approval	containers/bubblewrap seccomp/libseccomp
AG-D3-05	API 남용	C2	L2	block / require_approval	Kong/kong envoyproxy/envoy apache/apisix
AG-D3-06	권한 상승	C2	L2	block / require_approval	keycloak/keycloak * spiffe/spire

AG-D3-07	무단 실행	C2	L2	block / require_approval	snyk/agent-scan NVIDIA/SkillSpector * MCP-Defender/MCP-Defender *

9.5 AG-D4 스쿼드 — 모델 환각 위험

에이전트 ID	담당 항목	계열	격리	판정	기본 탐지 엔진(교체 가능)
AG-D4-01	허위 출력	C1	L1	block / transform	vibrantlabsai/ragas confident-ai/deepeval * KRLabsOrg/LettuceDetect
AG-D4-02	인용 날조	C1	L1	block / transform	vibrantlabsai/ragas truera/trulens
AG-D4-03	잘못된 결정	C1	L1	block / transform	humanlayer/humanlayer * langchain-ai/langgraph *
AG-D4-04	논리 오류	C1	L1	block / transform	dottxt-ai/outlines * 567-labs/instructor
AG-D4-05	규정 위반 출력	C1	L1	block / transform	NVIDIA-NeMo/Guardrails * guardrails-ai/guardrails
AG-D4-06	오정보 확산	C1	L1	block / transform	evidentlyai/evidently * Giskard-AI/giskard-oss *
AG-D4-07	신뢰 침식	C1	L1	block / transform	comet-ml/opik * langfuse/langfuse

9.6 AG-D5 스쿼드 — 접근 통제 실패

에이전트 ID	담당 항목	계열	격리	판정	기본 탐지 엔진(교체 가능)
AG-D5-01	취약 인증	C2	L1	block / require_approval	keycloak/keycloak * spiffe/spire zitadel/zitadel
AG-D5-02	인가 파손	C2	L1	block / require_approval	open-policy-agent/opa cerbos/cerbos openfga/openfga
AG-D5-03	세션 탈취	C2	L1	block / require_approval	ory/hydra oauth2-proxy/oauth2-proxy
AG-D5-04	신원 위장	C2	L1	block / require_approval	spiffe/spire a2aproject/A2A *
AG-D5-05	역할 혼동	C2	L1	block / require_approval	keycloak/keycloak * apache/casbin
AG-D5-06	토큰 오용	C2	L1	block / require_approval	openbao/openbao ory/oathkeeper
AG-D5-07	권한 불일치	C2	L1	block / require_approval	getagentidentity/llm-authz-audit * permitio/opal

9.7 AG-D6 스쿼드 — 자율 에이전트 과잉행동

에이전트 ID	담당 항목	계열	격리	판정	기본 탐지 엔진(교체 가능)
AG-D6-01	통제 없는 자율성	C2	L1	block / require_approval	humanlayer/humanlayer * microsoft/agent-governance-toolkit *
AG-D6-02	재귀 행동	C2	L1	block / require_approval	temporalio/temporal restatedev/restate
AG-D6-03	무한 루프	C2	L1	block / require_approval	temporalio/temporal dbos-inc/dbos-transact-py
AG-D6-04	과업 확대	C2	L1	block / require_approval	sipyourdrink-ltd/bernstein * microsoft/agent-governance-toolkit *
AG-D6-05	목표 불일치	C2	L1	block / require_approval	invariantlabs-ai/invariant UKGovernmentBEIS/inspect_ai
AG-D6-06	자원 고갈	C2	L1	block / require_approval	BerriAI/litellm * maximhq/bifrost * Kong/kong
AG-D6-07	금전 피해	C2	L1	block / require_approval	BerriAI/litellm * Portkey-AI/gateway *

9.8 AG-D7 스쿼드 — 공급망 취약점

에이전트 ID	담당 항목	계열	격리	판정	기본 탐지 엔진(교체 가능)
AG-D7-01	서드파티 도구	C3	L2	alert / block	snyk/agent-scan modelcontextprotocol/registry NVIDIA/SkillSpector *
AG-D7-02	의존성 취약	C3	L2	alert / block	aquasecurity/trivy anchore/grype google/osv-scanner
AG-D7-03	라이브러리 백도어	C3	L2	alert / block	DataDog/guarddog ossf/package-analysis
AG-D7-04	플러그인 취약	C3	L2	alert / block	affaan-m/agentshield * getagentseal/agentseal *
AG-D7-05	데이터셋 변조	C3	L2	alert / block	treeverse/dvc treeverse/lakeFS
AG-D7-06	모델 오염	C3	L2	alert / block	sigstore/model-transparency protectai/modelscan safetensors/safetensors
AG-D7-07	API 침해	C3	L2	alert / block	sigstore/cosign in-toto/in-toto luckyPipewrench/pipelock *

9.9 AG-D8 스쿼드 — 메모리·컨텍스트 악용

에이전트 ID	담당 항목	계열	격리	판정	기본 탐지 엔진(교체 가능)
AG-D8-01	컨텍스트 오염	C1	L1	block / transform	NVIDIA-NeMo/Guardrails * invariantlabs-ai/invariant
AG-D8-02	장기 조작	C1	L1	block / transform	letta-ai/letta * caura-ai/caura * matrixorigin/memoria *
AG-D8-03	지속 익스플로잇	C1	L1	block / transform	langchain-ai/langmem getzep/zep
AG-D8-04	저장형 프롬프트 공격	C1	L1	block / transform	NVIDIA/garak data-privacy-stack/presidio
AG-D8-05	지식 주입	C1	L1	block / transform	qdrant/qdrant * weaviate/weaviate treeverse/lakeFS
AG-D8-06	메모리 손상	C1	L1	block / transform	matrixorigin/memoria * MemTensor/MemOS *
AG-D8-07	검색 편향	C1	L1	block / transform	vibrantlabsai/ragas evidentlyai/evidently *

9.10 AG-D9 스쿼드 — 인프라 계층 위험

에이전트 ID	담당 항목	계열	격리	판정	기본 탐지 엔진(교체 가능)
AG-D9-01	클라우드 오구성	C3	L1	alert / block	prowler-cloud/prowler bridgecrewio/checkov turbot/steampipe
AG-D9-02	서버 침해	C3	L1	alert / block	falcosecurity/falco * cilium/tetragon wazuh/wazuh
AG-D9-03	암호화 공백	C3	L1	alert / block	cert-manager/cert-manager istio/istio * linkerd/linkerd2
AG-D9-04	데이터베이스 노출	C3	L1	alert / block	bytebase/bytebase * opensearch-project/security
AG-D9-05	엔드포인트 침해	C3	L1	alert / block	wazuh/wazuh rabbitstack/fibratus *
AG-D9-06	네트워크 가로채기	C3	L1	alert / block	cilium/cilium * istio/istio *
AG-D9-07	서비스 거부	C3	L1	alert / block	crowdsecurity/crowdsec * envoyproxy/envoy traefik/traefik

9.11 AG-D10 스쿼드 — 거버넌스·컴플라이언스 공백

에이전트 ID	담당 항목	계열	격리	판정	기본 탐지 엔진(교체 가능)
AG-D10-01	정책 부재	C4	L0	alert	open-policy-agent/opa kyverno/kyverno open-policy-agent/conftest
AG-D10-02	규제 위반	C4	L0	alert	oscal-compass/compliance-trestle usnistgov/OSCAL ComplianceAsCode/content
AG-D10-03	위험관리 부실	C4	L0	alert	DependencyTrack/dependency-track opencve/opencve
AG-D10-04	감사 실패	C4	L0	alert	open-telemetry/opentelemetry-collector * grafana/loki * openobserve/openobserve
AG-D10-05	윤리 맹점	C4	L0	alert	fairlearn/fairlearn Trusted-AI/AIF360
AG-D10-06	투명성 결여	C4	L0	alert	mlflow/mlflow Giskard-AI/giskard-oss *
AG-D10-07	모니터링 부재	C4	L0	alert	prometheus/prometheus * grafana/grafana * comet-ml/opik *

9.12 AG-X 보강 에이전트

에이전트 ID	담당 항목	계열	격리	기본 탐지 엔진
AG-X01	에이전트 간 통신 보안	C2	L1	a2aproject/A2A * spiffe/spire agentgateway/agentgateway
AG-X02	연쇄 실패	C3	L1	comet-ml/opik * temporalio/temporal
AG-X03	사람-에이전트 신뢰 악용	C3	L1	humanlayer/humanlayer * microsoft/agent-governance-toolkit *
AG-X04	이탈 에이전트	C2	L1	modelcontextprotocol/registry secureagentics/Adrian *
AG-X05	출력 처리 부실	C2	L1	guardrails-ai/guardrails dottxt-ai/outlines *
AG-X06	멀티모달 공격면	C3	L1	NVIDIA/garak data-privacy-stack/presidio
AG-X07	모델·추론 계층 위험	C3	L3	Trusted-AI/adversarial-robustness-toolbox microsoft/PyRIT *
AG-X08	사고 대응·포렌식	C3	L1	wazuh/wazuh MISP/MISP TheHive-Project/TheHive
AG-X09	상시 레드팀	C3	L3	promptfoo/promptfoo NVIDIA/garak microsoft/PyRIT *

AG-X10	비용·서비스 수준 관측	C3	L1	prometheus/prometheus * comet-ml/opik *

9.13 AG-P 플랫폼 에이전트

에이전트 ID	이름	책임	기본 구현 후보
AG-P01	Gateway Agent (게이트웨이)	모든 요청·도구 호출·응답이 지나는 데이터 평면. 4개 관문에서 도메인 에이전트를 호출한다.	agentgateway/agentgateway envoyproxy/envoy katanemo/plano *
AG-P02	Policy Agent (정책 결정)	정책을 코드로 평가하는 결정점. 허용·차단·승인요구·변조 4가지 판정을 낸다.	open-policy-agent/opa cerbos/cerbos
AG-P03	Registry Agent (레지스트리)	에이전트·도구·모델·정책의 등록·서명·버전·가용성을 관리한다.	modelcontextprotocol/registry goharbor/harbor *
AG-P04	Orchestrator Agent (오케스트레이터)	판정 요청을 도메인 에이전트에 분배하고 결과를 합성한다. 병렬·타임아웃·강등을 관리한다.	temporalio/temporal ray-project/ray
AG-P05	Evidence Agent (증적 원장)	모든 판정과 행동을 불변 로그로 적재하고 감사 질의에 답한다.	ClickHouse/ClickHouse * seaweedfs/seaweedfs
AG-P06	Correlator Agent (상관 분석)	도메인 에이전트의 개별 발견을 사건으로 묶고 연쇄 실패를 탐지한다.	nats-io/nats-server redpanda-data/redpanda
AG-P07	Identity Agent (신원·비밀)	에이전트 워크로드 신원 발급, 토큰 다운스코핑, 동적 시크릿을 담당한다.	spiffe/spire openbao/openbao external-secrets/external-secrets
AG-P08	Sandbox Agent (샌드박스 중개)	격리 실행 환경을 요청 단위로 발급·회수하고 격리 등급을 강제한다.	firecracker-microvm/firecracker google/gvisor e2b-dev/E2B *
AG-P09	Telemetry Agent (관측)	지표·추적·로그를 표준 규약으로 수집하고 마스킹한다.	open-telemetry/opentelemetry-collector * prometheus/prometheus * grafana/tempo *
AG-P10	RedTeam Agent (레드팀)	공격 시나리오를 정기·배포 시점에 실행해 방어 회귀를 잡는다.	promptfoo/promptfoo NVIDIA/garak
AG-P11	Compliance Agent (컴플라이언스)	통제·규제 매핑을 유지하고 증적에서 보고서를 생성한다.	oscal-compass/compliance-trestle DependencyTrack/dependency-track
AG-P12	Console Agent (콘솔·장터)	등록·선택·즉시 사용 화면과 프로파일 배포를 제공한다.	langflow-ai/langflow * grafana/grafana *

9.14 에이전트 수량 집계

구분	종수	계열 분포	비고
도메인 에이전트	70	C1 21종, C2 21종, C3 21종, C4 7종	도식 70개 세부 항목과 1대1
보강 에이전트	10	C2 3종, C3 7종	도식 공백. ASI07~ASI10 및 LLM10 대응
플랫폼 에이전트	12	해당 없음	판정이 아니라 기반 기능 제공
합계	**92**		이미지 92개, 매니페스트 92개



그림 6. 에이전트 배치도 — 92종이 7계층과 4관문 위에 어떻게 놓이는가

10. 기술 스택

2026-09-17 에 GitHub REST API 로 245개 저장소를 직접 조회했다. 스타 수·라이선스·기본 브랜치 최신 커밋은 그날의 실측값이며, 라이선스가 NOASSERTION 으로 반환된 저장소는 LICENSE 파일 본문을 읽어 판정했다. 별표는 사용자 즐겨찾기 목록과 교차한 저장소다.

10.1 선정 기준

기준	내용	탈락 사례
활성	기본 브랜치 최신 커밋이 180일 이내	protectai/rebuff(2024-01-25), agencyenterprise/PromptInject(2022-11-18)
비아카이브	GitHub 아카이브 표시가 없을 것	protectai/llm-guard, Azure/PyRIT, lakeraai/pint-benchmark, minio/minio, TheHive-Project/TheHive
라이선스	상용 배포 가능. 비OSI 라이선스는 대안을 함께 제시	hashicorp/vault(BUSL, Licensor IBM), Arize-ai/phoenix(ELv2), getagentseal/agentseal(FSL)
교체 가능성	표준 인터페이스 또는 CLI·HTTP 로 감쌀 수 있을 것	코드 수준 결합만 지원하는 라이브러리
운영 실적	릴리스가 정기적이고 컨테이너 이미지가 제공될 것	연구 코드 단발 공개

10.2 D1 프롬프트 인젝션 공격 스택

저장소	스타	라이선스	최신 커밋	설명(원문 요약)
NVIDIA/garak	9,276	Apache-2.0	2026-09-16	the LLM vulnerability scanner
NVIDIA-NeMo/Guardrails *	7,150	Apache-2.0	2026-09-16	NeMo Guardrails is an open-source toolkit for easily adding programmable guardrails to …
meta-llama/PurpleLlama	4,398	Llama 3.2 Community License (비OSI)	2026-08-18	Set of tools to assess and improve LLM security.
invariantlabs-ai/invariant	457	Apache-2.0	2026-01-12	Guardrails for secure and robust agent development
snyk/agent-scan	3,058	Apache-2.0	2026-09-16	Security scanner for AI agents, MCP servers and agent skills.
verazuo/jailbreak_llms *	3,816	MIT	2024-12-24	[CCS'24] A dataset consists of 15,140 ChatGPT prompts from Reddit, Discord, websites, and …
EasyJailbreak/EasyJailbreak *	909	GPL-3.0	2026-09-01	An easy-to-use Python framework to generate adversarial jailbreak prompts.
JailbreakBench/jailbreakbench	672	MIT	2025-03-31	JailbreakBench: An Open Robustness Benchmark for Jailbreaking Language Models [NeurIPS 2024 …
promptfoo/promptfoo	25,197	MIT	2026-09-17	Test your prompts, agents, and RAGs. Red teaming/pentesting/vulnerability scanning for AI …
guardrails-ai/guardrails	7,423	Apache-2.0	2026-08-26	Adding guardrails to large language models.
luckyPipewrench/pipelock *	876	Apache-2.0	2026-09-17	Open-source AI agent firewall for MCP security and agent egress. Scans mediated HTTP, MCP …
agentgateway/agentgateway	4,887	Apache-2.0	2026-09-16	Next Generation Agentic Proxy for AI Agents and MCP servers
praetorian-inc/augustus *	289	Apache-2.0	2026-09-15	LLM security testing framework for detecting prompt injection, jailbreaks, and adversarial …
microsoft/PyRIT *	4,485	MIT	2026-09-16	The Python Risk Identification Tool for generative AI (PyRIT) is an open source framework …
AISecurityLab/hackagent *	515	Apache-2.0	2026-09-16	HackAgent is an open-source security toolkit to detect vulnerabilities of your AI Agents
centerforaisafety/HarmBench	1,047	MIT	2024-08-05	HarmBench: A Standardized Evaluation Framework for Automated Red Teaming and Robust Refusal
llm-attacks/llm-attacks	4,795	MIT	2024-08-02	Universal and Transferable Attacks on Aligned Language Models
utkusen/promptmap	1,269	GPL-3.0	2025-12-01	a security scanner for custom LLM applications
agencyenterprise/PromptInject	524	MIT	2022-11-18	PromptInject is a framework that assembles prompts in a modular fashion to provide a …
Repello-AI/Agent-Wiz *	397	Apache-2.0	2025-10-30	A CLI tool for threat modeling and visualizing AI agents built using popular frameworks …

10.3 D2 데이터 유출 위험 스택

저장소	스타	라이선스	최신 커밋	설명(원문 요약)
data-privacy-stack/presidio	10,903	MIT	2026-09-16	An open-source framework for detecting, redacting, masking, and anonymizing sensitive data …
Marker-Inc-Korea/ko-pii *	90	MIT	2026-09-09	한국어 PII 검출 + 가명화 Python 라이브러리
openfga/openfga	5,782	Apache-2.0	2026-09-08	A high performance and flexible authorization/permission engine built for developers and …
caura-ai/caura *	518	Apache-2.0	2026-09-17	Caura (formerly MemClaw) governed shared memory for AI agent fleets. Multi-agent …
gitleaks/gitleaks	29,348	MIT	2026-07-22	Find secrets with Gitleaks
trufflesecurity/trufflehog *	27,963	AGPL-3.0	2026-09-16	Find, verify, and analyze leaked credentials
Yelp/detect-secrets	4,635	Apache-2.0	2026-04-02	An enterprise friendly way of detecting and preventing secrets in code.
authzed/spicedb	7,057	Apache-2.0	2026-09-16	Open Source, Google Zanzibar-inspired database for scalably storing and querying …
meta-pytorch/opacus	1,959	Apache-2.0	2026-07-13	Training PyTorch models with differential privacy
privacytrustlab/ml_privacy_meter	726	MIT	2025-04-26	Privacy Meter: An open-source library to audit data privacy in statistical and machine …
google/differential-privacy *	3,360	Apache-2.0	2026-09-11	Google's differential privacy libraries.
fluent/fluent-bit *	8,111	Apache-2.0	2026-09-16	Fast and Lightweight Logs, Metrics and Traces processor for Linux, BSD, OSX and Windows
letta-ai/letta *	24,770	Apache-2.0	2026-09-10	Platform for stateful agents: AI with advanced memory that can learn and self-improve over …
mem0ai/mem0 *	65,460	Apache-2.0	2026-09-16	The Memory Layer for AI Agents - Drop-in memory infrastructure for AI agents and apps …
MemTensor/MemOS *	11,478	Apache-2.0	2026-09-16	Self-evolving memory OS for LLM & AI Agents: ultra-persistent memory, hybrid-retrieval, and …
awslabs/git-secrets	13,395	Apache-2.0	2025-09-17	Prevents you from committing secrets and credentials into git repositories
tensorflow/privacy	2,034	Apache-2.0	2026-08-26	Library for training machine learning models with privacy for training data
open-telemetry/opentelemetry-collector *	7,559	Apache-2.0	2026-09-17	OpenTelemetry Collector

10.4 D3 도구 오남용 스택

저장소	스타	라이선스	최신 커밋	설명(원문 요약)
open-policy-agent/opa	12,241	Apache-2.0	2026-09-16	Open Policy Agent (OPA) is an open source, general-purpose policy engine.
cerbos/cerbos	4,588	Apache-2.0	2026-09-16	Cerbos is an open-core authorization management platform for authorizing every identity and …
anthropics/sandbox-runtime *	5,256	Apache-2.0	2026-09-16	A lightweight sandboxing tool for enforcing filesystem and network restrictions on …
containers/bubblewrap	8,745	LGPL-2.1	2026-09-16	Low-level unprivileged sandboxing tool used by Flatpak and similar projects
google/gvisor	19,336	Apache-2.0	2026-09-17	Application Kernel for Containers
firecracker-microvm/firecracker	36,827	Apache-2.0	2026-09-16	Secure and fast microVMs for serverless computing.
superradcompany/microsandbox *	8,277	Apache-2.0	2026-09-17	Easy fast local-first microVM runtime and library
seccomp/libseccomp	934	LGPL-2.1	2026-07-01	The main libseccomp repository
Kong/kong	44,143	Apache-2.0	2026-09-03	The API and AI Gateway
envoyproxy/envoy	28,946	Apache-2.0	2026-09-17	Cloud-native high-performance edge/middle/service proxy
apache/apisix	17,129	Apache-2.0	2026-09-17	The Cloud-Native API Gateway and AI Gateway
keycloak/keycloak *	36,813	Apache-2.0	2026-09-16	Open Source Identity and Access Management For Modern Applications and Services
spiffe/spire	2,539	Apache-2.0	2026-09-15	The SPIFFE Runtime Environment

snyk/agent-scan	3,058	Apache-2.0	2026-09-16	Security scanner for AI agents, MCP servers and agent skills.
NVIDIA/SkillSpector *	17,502	Apache-2.0	2026-09-16	Security scanner for AI agent skills. Detect vulnerabilities, malicious patterns, security …
MCP-Defender/MCP-Defender *	257	AGPL-3.0	2026-06-05	Desktop app that automatically scans and blocks malicious MCP traffic in AI apps like …
e2b-dev/E2B *	13,850	Apache-2.0	2026-09-16	Open-source, secure environment with real-world tools for enterprise-grade agents.
opensandbox-group/OpenSandbox *	15,358	Apache-2.0	2026-09-17	Secure, Fast, and Extensible Sandbox runtime for AI agents.
TencentCloud/CubeSandbox *	12,624	Tencent 자체 라이선스	2026-09-17	Instant, Concurrent, Secure & Lightweight Sandbox for AI Agents.
falcosecurity/falco *	9,384	Apache-2.0	2026-09-16	Cloud Native Runtime Security
affaan-m/agentshield *	1,191	MIT	2026-09-10	AI agent security scanner. Detect vulnerabilities in agent configurations, MCP servers, and …
secureagentics/Adrian *	564	Apache-2.0	2026-09-15	Open-source runtime AI agent security tool - monitors and controls AI agents, catching …
BakeLens/crust *	439	Elastic-2.0	2026-03-30	Open Source AI Agent Security Infrastructure intercepts and blocks dangerous agent …
archestra-ai/archestra *	4,282	이중 라이선스 라우터	2026-09-17	Enterprise AI Platform with guardrails, MCP registry, gateway & orchestrator

10.5 D4 모델 환각 위험 스택

저장소	스타	라이선스	최신 커밋	설명(원문 요약)
vibrantlabsai/ragas	15,758	Apache-2.0	2026-02-24	Supercharge Your LLM Application Evaluations
confident-ai/deepeval *	18,301	Apache-2.0	2026-09-16	The LLM Evaluation Framework
KRLabsOrg/LettuceDetect	607	MIT	2026-09-07	Span-level grounding verification for RAG, code, and tool-grounded AI outputs.
truera/trulens	3,562	MIT	2026-09-16	Evaluation and Tracking for LLM Experiments and AI Agents
humanlayer/humanlayer *	11,554	Apache-2.0	2026-06-19	The best way to get AI coding agents to solve hard problems in complex codebases.
langchain-ai/langgraph *	41,791	MIT	2026-09-14	Build resilient agents.
dottxt-ai/outlines *	15,819	Apache-2.0	2026-08-24	Structured Outputs
567-labs/instructor	13,910	MIT	2026-09-11	structured outputs for llms
NVIDIA-NeMo/Guardrails *	7,150	Apache-2.0	2026-09-16	NeMo Guardrails is an open-source toolkit for easily adding programmable guardrails to …
guardrails-ai/guardrails	7,423	Apache-2.0	2026-08-26	Adding guardrails to large language models.
evidentlyai/evidently *	7,922	Apache-2.0	2026-09-10	Evidently is an open-source ML and LLM observability framework. Evaluate, test, and monitor …
Giskard-AI/giskard-oss *	5,821	Apache-2.0	2026-09-14	Open-Source Evaluation & Testing library for LLM Agents
comet-ml/opik *	22,078	Apache-2.0	2026-09-16	Debug, evaluate, and monitor your LLM applications, RAG systems, and agentic workflows with …
langfuse/langfuse	34,703	MIT + ee/ 상용 (저작권자 ClickHouse, Inc.)	2026-09-16	Open source agent evals & observability: Trace, evaluate, and improve LLM applications with …
EleutherAI/lm-evaluation-harness *	14,005	MIT	2026-09-14	A framework for few-shot evaluation of language models.
UKGovernmentBEIS/inspect_ai	2,787	MIT	2026-09-17	Inspect: A framework for large language model evaluations
huggingface/lighteval	2,543	MIT	2026-09-09	Lighteval is your all-in-one toolkit for evaluating LLMs across multiple backends
stanford-crfm/helm	2,910	Apache-2.0	2026-06-05	Holistic Evaluation of Language Models (HELM) is an open source Python framework created by …
openai/evals	19,468	MIT	2026-04-14	Evals is a framework for evaluating LLMs and LLM systems, and an open-source registry of …
cleanlab/cleanlab *	11,654	Apache-2.0	2026-01-13	Cleanlab's open-source library is the standard data-centric AI package for data quality and …
vectara/hallucination-leaderboard	3,313	Apache-2.0	2026-05-11	Leaderboard Comparing LLM Performance at Producing Hallucinations when Summarizing Short …

10.6 D5 접근 통제 실패 스택

저장소	스타	라이선스	최신 커밋	설명(원문 요약)
keycloak/keycloak *	36,813	Apache-2.0	2026-09-16	Open Source Identity and Access Management For Modern Applications and Services
spiffe/spire	2,539	Apache-2.0	2026-09-15	The SPIFFE Runtime Environment
zitadel/zitadel	15,038	AGPL-3.0	2026-09-15	ZITADEL - Identity infrastructure, simplified foryou.
open-policy-agent/opa	12,241	Apache-2.0	2026-09-16	Open Policy Agent (OPA) is an open source, general-purpose policy engine.
cerbos/cerbos	4,588	Apache-2.0	2026-09-16	Cerbos is an open-core authorization management platform for authorizing every identity and …
openfga/openfga	5,782	Apache-2.0	2026-09-08	A high performance and flexible authorization/permission engine built for developers and …
ory/hydra	17,546	Apache-2.0	2026-07-29	Internet-scale OpenID Certified OpenID Connect and OAuth2.1 provider that integrates with …
oauth2-proxy/oauth2-proxy	14,964	MIT	2026-09-13	A reverse proxy that provides authentication with Google, Azure, OpenID Connect and many …
a2aproject/A2A *	25,804	Apache-2.0	2026-09-16	Agent2Agent (A2A) is an open protocol enabling communication and interoperability between …
apache/casbin	20,393	Apache-2.0	2026-09-11	Apache Casbin: an authorization library that supports access control models like ACL, RBAC …
openbao/openbao	7,386	MPL-2.0	2026-09-17	OpenBao is a software solution to manage, store, and distribute sensitive data including …
ory/oathkeeper	3,601	Apache-2.0	2026-07-27	A cloud native Identity & Access Proxy / API (IAP) and Access Control Decision API that …
getagentidentity/llm-authz-audit *	6	MIT	2026-02-16	Scan your LLM-powered applications for authorization gaps, leaked credentials, missing rate …
permitio/opal	5,509	Apache-2.0	2026-08-24	Policy and data administration, distribution, and real-time updates on top of Policy Agents …
ory/kratos	13,879	Apache-2.0	2026-07-29	Headless cloud-native authentication and identity management written in Go. Scales to a …
ory/keto	5,397	Apache-2.0	2026-07-29	The most scalable and customizable permission server on the market. Fix your slow or broken …
authelia/authelia	28,996	Apache-2.0	2026-09-16	The Single Sign-On Multi-Factor portal for web apps. OpenID Certified and Post-Quantum …
logto-io/logto *	14,578	MPL-2.0	2026-09-17	Authentication and authorization infrastructure for SaaS and AI apps, built on OIDC and …
casdoor/casdoor	14,414	Apache-2.0	2026-09-16	An open-source Agent-first Identity and Access Management (IAM) /LLM MCP & agent gateway …
supertokens/supertokens-core	15,307	Apache-2.0 + ee/ 상용	2026-09-04	Open source alternative to Auth0 / Firebase Auth / AWS Cognito
gravitational/teleport *	20,924	AGPL-3.0	2026-08-25	The easiest, and most secure way to access and protect all of your infrastructure.
hashicorp/boundary	4,060	BUSL-1.1 (Licensor: IBM)	2026-08-06	Boundary enables identity-based access management for dynamic infrastructure.

10.7 D6 자율 에이전트 과잉행동 스택

저장소	스타	라이선스	최신 커밋	설명(원문 요약)
humanlayer/humanlayer *	11,554	Apache-2.0	2026-06-19	The best way to get AI coding agents to solve hard problems in complex codebases.
microsoft/agent-governance-toolkit *	6,274	MIT	2026-09-15	AI Agent Governance Toolkit Policy enforcement, zero-trust identity, execution sandboxing …
temporalio/temporal	23,169	MIT	2026-09-16	Temporal service
restatedev/restate	4,428	BUSL-1.1	2026-09-16	Restate is the platform for building resilient applications that tolerate all …
dbos-inc/dbos-transact-py	1,578	MIT	2026-09-15	Database-Backed Durable Python Workflows
sipyourdrink-ltd/bernstein *	1,185	Apache-2.0	2026-09-16	The opensource AI Agents Governance & Orchestration framework: write the

				rules …
invariantlabs-ai/invariant	457	Apache-2.0	2026-01-12	Guardrails for secure and robust agent development
UKGovernmentBEIS/inspect_ai	2,787	MIT	2026-09-17	Inspect: A framework for large language model evaluations
BerriAI/litellm *	58,937	MIT + enterprise/ 상용	2026-09-17	The fastest, litest AI Gateway. Rust core with Python SDK. Call 100+ LLM APIs in OpenAI (or …
maximhq/bifrost *	8,125	Apache-2.0	2026-09-16	Fastest enterprise AI gateway (50x faster than LiteLLM) with adaptive load balancer …
Kong/kong	44,143	Apache-2.0	2026-09-03	The API and AI Gateway
Portkey-AI/gateway *	13,018	MIT	2026-05-25	A blazing fast AI Gateway with integrated guardrails. Route to 1,600+ LLMs, 50+ AI …
inngest/inngest	5,837	SSPL-1.0	2026-09-16	The leading workflow orchestration platform. Run stateful step functions and AI workflows …
AgentOps-AI/agentops *	5,822	MIT	2026-06-25	Python SDK for AI agent monitoring, LLM cost tracking, benchmarking, and more. Integrates …
AgentOps-AI/tokencost	2,008	MIT	2025-09-05	Easy token price estimates for 400+ LLMs. TokenOps.
katanemo/plano *	7,055	Apache-2.0	2026-08-19	Plano is an AI-native proxy server and data plane for agentic apps. Smart LLM routing …

10.8 D7 공급망 취약점 스택

저장소	스타	라이선스	최신 커밋	설명(원문 요약)
snyk/agent-scan	3,058	Apache-2.0	2026-09-16	Security scanner for AI agents, MCP servers and agent skills.
modelcontextprotocol/registry	7,257	MIT -> Apache-2.0 전환 중	2026-09-16	A community driven registry service for Model Context Protocol (MCP) servers.
NVIDIA/SkillSpector *	17,502	Apache-2.0	2026-09-16	Security scanner for AI agent skills. Detect vulnerabilities, malicious patterns, security …
aquasecurity/trivy	37,953	Apache-2.0	2026-09-16	Find vulnerabilities, misconfigurations, secrets, SBOM in containers, Kubernetes, code …
anchore/grype	12,894	Apache-2.0	2026-09-16	A vulnerability scanner for container images and filesystems
google/osv-scanner	11,042	Apache-2.0	2026-09-17	Vulnerability scanner written in Go which uses the data provided by https://osv.dev
DataDog/guarddog	1,207	Apache-2.0	2026-09-02	:snake: :mag: GuardDog is a CLI tool to Identify malicious PyPI and npm packages
ossf/package-analysis	912	Apache-2.0	2026-07-21	Open Source Package Analysis
affaan-m/agentshield *	1,191	MIT	2026-09-10	AI agent security scanner. Detect vulnerabilities in agent configurations, MCP servers, and …
getagentseal/agentseal *	374	FSL-1.1-Apache-2.0 (비 OSI)	2026-06-11	Security toolkit for AI agents. Scan your machine for dangerous skills and MCP configs …
treeverse/dvc	15,875	Apache-2.0	2026-08-06	Data Versioning and ML Experiments
treeverse/lakeFS	5,529	Apache-2.0	2026-08-16	lakeFS - Data version control for your data lake | Git for data
sigstore/model-transparency	244	Apache-2.0	2026-09-14	Supply chain security for ML
protectai/modelscan	774	Apache-2.0	2026-02-18	Protection against Model Serialization Attacks
safetensors/safetensors	3,897	Apache-2.0	2026-09-16	Simple, safe way to store and distribute tensors
sigstore/cosign	6,307	Apache-2.0	2026-09-15	Code signing and transparency for containers and binaries
in-toto/in-toto	1,039	Apache-2.0	2026-08-27	in-toto is a framework to protect supply chain integrity.
luckyPipewrench/pipelock *	876	Apache-2.0	2026-09-17	Open-source AI agent firewall for MCP security and agent egress. Scans mediated HTTP, MCP …
ossf/scorecard	5,692	Apache-2.0	2026-09-08	OpenSSF Scorecard - Security health metrics for Open Source
ossf/allstar	1,453	Apache-2.0	2026-09-08	GitHub App to set and enforce security policies
pypa/pip-audit	1,363	Apache-2.0	2026-09-09	Audits Python environments, requirements files and dependency trees for known security …
anchore/syft	9,568	Apache-2.0	2026-09-16	CLI tool and library for generating a Software Bill of Materials from container images and …

anchore/grant	183	Apache-2.0	2026-09-11	A license scanner for container images and filesystems.
CycloneDX/cyclonedx-cli	542	Apache-2.0	2026-07-23	CycloneDX CLI tool for SBOM analysis, merging, diffs and format conversions.
slsa-framework/slsa	1,928	Community Specification License 1.0	2026-09-16	Supply-chain Levels for Software Artifacts
goharbor/harbor *	29,396	Apache-2.0	2026-09-16	An open source trusted cloud native registry project that stores, signs, and scans content.
quay/clair	11,056	Apache-2.0	2026-09-16	Vulnerability Static Analysis for Containers
tektoncd/chains	276	Apache-2.0	2026-09-17	Supply Chain Security in Tekton Pipelines

10.9 D8 메모리·컨텍스트 악용 스택

저장소	스타	라이선스	최신 커밋	설명(원문 요약)
NVIDIA-NeMo/Guardrails *	7,150	Apache-2.0	2026-09-16	NeMo Guardrails is an open-source toolkit for easily adding programmable guardrails to …
invariantlabs-ai/invariant	457	Apache-2.0	2026-01-12	Guardrails for secure and robust agent development
letta-ai/letta *	24,770	Apache-2.0	2026-09-10	Platform for stateful agents: AI with advanced memory that can learn and self-improve over …
caura-ai/caura *	518	Apache-2.0	2026-09-17	Caura (formerly MemClaw) governed shared memory for AI agent fleets. Multi-agent …
matrixorigin/memoria *	600	Apache-2.0	2026-09-11	Secure memory management for AI Agents Ensures data integrity Reduces hallucinations …
langchain-ai/langmem	1,669	MIT	2026-09-09	
getzep/zep	4,919	Apache-2.0	2026-09-11	Zep | Examples, Integrations, & More
NVIDIA/garak	9,276	Apache-2.0	2026-09-16	the LLM vulnerability scanner
data-privacy-stack/presidio	10,903	MIT	2026-09-16	An open-source framework for detecting, redacting, masking, and anonymizing sensitive data …
qdrant/qdrant *	34,609	Apache-2.0	2026-09-03	Qdrant - High-performance, massive-scale Vector Database and Vector Search Engine for the …
weaviate/weaviate	16,815	BSD-3-Clause + Weaviate License	2026-09-16	Weaviate is an open-source vector database that stores both objects and vectors, allowing …
treeverse/lakeFS	5,529	Apache-2.0	2026-08-16	lakeFS - Data version control for your data lake | Git for data
MemTensor/MemOS *	11,478	Apache-2.0	2026-09-16	Self-evolving memory OS for LLM & AI Agents: ultra-persistent memory, hybrid-retrieval, and …
vibrantlabsai/ragas	15,758	Apache-2.0	2026-02-24	Supercharge Your LLM Application Evaluations
evidentlyai/evidently *	7,922	Apache-2.0	2026-09-10	Evidently is an open-source ML and LLM observability framework. Evaluate, test, and monitor …
Papr-ai/memory-opensource *	74	AGPL-3.0	2026-02-10	Predictive memory layer for AI agents. MongoDB + Qdrant + Neo4j with multi-tier caching …
milvus-io/milvus *	46,132	Apache-2.0	2026-09-17	Milvus is a high-performance, cloud-native vector database built for scalable vector ANN …

10.10 D9 인프라 계층 위험 스택

저장소	스타	라이선스	최신 커밋	설명(원문 요약)
prowler-cloud/prowler	14,823	Apache-2.0	2026-09-16	Prowler is the worlds most widely used open-source cloud security platform that automates …
bridgecrewio/checkov	9,007	Apache-2.0	2026-09-17	Prevent cloud misconfigurations and find vulnerabilities during build-time in …
turbot/steampipe	7,955	AGPL-3.0	2026-09-16	Zero-ETL, infinite possibilities. Live query APIs, code & more with SQL. No DB required.
falcosecurity/falco *	9,384	Apache-2.0	2026-09-16	Cloud Native Runtime Security
cilium/tetragon	5,009	Apache-2.0	2026-09-17	eBPF-based Security Observability and Runtime Enforcement
wazuh/wazuh	16,903	GPL-2.0	2026-09-15	Wazuh - The Open Source Security Platform. Unified XDR and SIEM protection

				for endpoints …
cert-manager/cert-manager	14,083	Apache-2.0	2026-09-17	Automatically provision and manage TLS certificates in Kubernetes
istio/istio *	38,391	Apache-2.0	2026-09-17	Connect, secure, control, and observe services.
linkerd/linkerd2	11,496	Apache-2.0	2026-09-16	Ultralight, security-first service mesh for Kubernetes. Main repo for Linkerd 2.x.
bytebase/bytebase *	14,489	MIT + enterprise 상용	2026-09-17	Database governance built for humans and agents controlling changes and access across every …
opensearch-project/security	252	Apache-2.0	2026-09-17	Secure your cluster with TLS, numerous authentication backends, data masking, audit logging …
rabbitstack/fibratus *	2,544	Apache-2.0	2026-09-12	Security sensor for realtime threat detection and protection
cilium/cilium *	25,230	Apache-2.0	2026-09-16	eBPF-based Networking, Security, and Observability
crowdsecurity/crowdsec *	14,874	MIT	2026-09-16	CrowdSec - the open-source and participative security solution offering crowdsourced …
envoyproxy/envoy	28,946	Apache-2.0	2026-09-17	Cloud-native high-performance edge/middle/service proxy
traefik/traefik	64,870	MIT	2026-09-14	The Cloud Native Application Proxy
aquasecurity/kube-bench	8,187	Apache-2.0	2026-08-18	Checks whether Kubernetes is deployed according to security best practices as defined in …
open-policy-agent/gatekeeper	4,276	Apache-2.0	2026-09-17	Policy Controller for Kubernetes
stackrox/stackrox	1,312	Apache-2.0	2026-09-16	The StackRox Kubernetes Security Platform performs a risk analysis of the container …
jertel/elastalert2	1,132	Apache-2.0	2026-09-03	ElastAlert 2 is a continuation of the original yelp/elastalert project. Pull requests are …
projectdiscovery/nuclei *	31,312	MIT	2026-09-14	Nuclei is a fast, customizable vulnerability scanner powered by the global security …
OWASP/Nettacker *	5,572	Apache-2.0	2026-09-13	Automated Penetration Testing Framework - Open-Source Vulnerability Scanner - Vulnerability …
external-secrets/external-secrets	6,863	Apache-2.0	2026-09-16	External Secrets Operator reads information from a third-party service like AWS Secrets …
seaweedfs/seaweedfs	34,776	Apache-2.0	2026-09-17	SeaweedFS is a distributed storage system for object storage (S3), file systems, and …

10.11 D10 거버넌스·컴플라이언스 공백 스택

저장소	스타	라이선스	최신 커밋	설명(원문 요약)
open-policy-agent/opa	12,241	Apache-2.0	2026-09-16	Open Policy Agent (OPA) is an open source, general-purpose policy engine.
kyverno/kyverno	8,156	Apache-2.0	2026-09-17	Unified Policy as Code
open-policy-agent/conftest	3,262	Apache-2.0	2026-09-13	Write tests against structured configuration data using the Open Policy Agent Rego query …
oscal-compass/compliance-trestle	276	Apache-2.0	2026-09-11	An opinionated tooling platform for managing compliance as code, using continuous …
usnistgov/OSCAL	951	미국 연방 퍼블릭 도메인	2026-08-07	Open Security Controls Assessment Language (OSCAL)
ComplianceAsCode/content	2,804	BSD-3-Clause	2026-09-16	Security automation content in SCAP, Bash, Ansible, and other formats
DependencyTrack/dependency-track	4,210	Apache-2.0	2026-09-15	Dependency-Track is an intelligent Component Analysis platform that allows organizations to …
opencve/opencve	2,834	BUSL-1.1	2026-09-10	Vulnerability Intelligence Platform
open-telemetry/opentelemetry-collector *	7,559	Apache-2.0	2026-09-17	OpenTelemetry Collector
grafana/loki *	28,903	AGPL-3.0	2026-09-17	Like Prometheus, but for logs.
openobserve/openobserve	22,050	AGPL-3.0	2026-09-17	Open source observability platform for logs, metrics, traces, RUM, Session replay …
fairlearn/fairlearn	2,285	MIT	2026-09-15	A Python package to assess and improve fairness of machine learning models.
Trusted-AI/AIF360	2,866	Apache-2.0	2026-06-12	A comprehensive set of fairness metrics for datasets and machine learning models …
mlflow/mlflow	27,991	Apache-2.0	2026-09-17	The open source AI engineering platform for agents, LLMs, and ML models. MLflow enables …

Giskard-AI/giskard-oss *	5,821	Apache-2.0	2026-09-14	Open-Source Evaluation & Testing library for LLM Agents
prometheus/prometheus *	66,101	Apache-2.0	2026-09-16	The Prometheus monitoring system and time series database.
grafana/grafana *	76,779	AGPL-3.0	2026-09-17	The open and composable observability and data visualization platform. Visualize metrics …
comet-ml/opik *	22,078	Apache-2.0	2026-09-16	Debug, evaluate, and monitor your LLM applications, RAG systems, and agentic workflows with …
MISP/MISP	6,541	AGPL-3.0	2026-09-15	MISP (core software) - Open Source Threat Intelligence and Sharing Platform
microsoft/agent-governance-toolkit *	6,274	MIT	2026-09-15	AI Agent Governance Toolkit Policy enforcement, zero-trust identity, execution sandboxing …
mitre-atlas/atlas-navigator-data	34	Apache-2.0	2026-06-24	Scripts and outputs for ATLAS data in STIX JSON and ATT&CK Navigator layer formats
Arize-ai/phoenix *	11,505	Elastic-2.0	2026-09-17	AI Observability & Evaluation
langfuse/langfuse	34,703	MIT + ee/ 상용 (저작권자 ClickHouse, Inc.)	2026-09-16	Open source agent evals & observability: Trace, evaluate, and improve LLM applications with …
evidentlyai/evidently *	7,922	Apache-2.0	2026-09-10	Evidently is an open-source ML and LLM observability framework. Evaluate, test, and monitor …
VictoriaMetrics/VictoriaMetrics	17,728	Apache-2.0	2026-09-16	VictoriaMetrics: fast, cost-effective monitoring solution and time series database

10.12 플랫폼·공통 스택

저장소	스타	라이선스	최신 커밋	설명(원문 요약)
agentgateway/agentgateway	4,887	Apache-2.0	2026-09-16	Next Generation Agentic Proxy for AI Agents and MCP servers
envoyproxy/envoy	28,946	Apache-2.0	2026-09-17	Cloud-native high-performance edge/middle/service proxy
katanemo/plano *	7,055	Apache-2.0	2026-08-19	Plano is an AI-native proxy server and data plane for agentic apps. Smart LLM routing …
open-policy-agent/opa	12,241	Apache-2.0	2026-09-16	Open Policy Agent (OPA) is an open source, general-purpose policy engine.
cerbos/cerbos	4,588	Apache-2.0	2026-09-16	Cerbos is an open-core authorization management platform for authorizing every identity and …
modelcontextprotocol/registry	7,257	MIT -> Apache-2.0 전환 중	2026-09-16	A community driven registry service for Model Context Protocol (MCP) servers.
goharbor/harbor *	29,396	Apache-2.0	2026-09-16	An open source trusted cloud native registry project that stores, signs, and scans content.
temporalio/temporal	23,169	MIT	2026-09-16	Temporal service
ray-project/ray	43,838	Apache-2.0	2026-09-17	Ray is an AI compute engine. Ray consists of a core distributed runtime and a set of AI …
ClickHouse/ClickHouse *	49,934	Apache-2.0	2026-09-17	ClickHouse is a real-time analytics database management system
seaweedfs/seaweedfs	34,776	Apache-2.0	2026-09-17	SeaweedFS is a distributed storage system for object storage (S3), file systems, and …
nats-io/nats-server	20,790	Apache-2.0	2026-09-16	High-Performance server for NATS.io, the cloud and edge native messaging system.
redpanda-data/redpanda	12,548	BSL + RCL	2026-08-20	Redpanda is a streaming data platform for developers. Kafka API compatible. 10x faster. No …
spiffe/spire	2,539	Apache-2.0	2026-09-15	The SPIFFE Runtime Environment
openbao/openbao	7,386	MPL-2.0	2026-09-17	OpenBao is a software solution to manage, store, and distribute sensitive data including …
external-secrets/external-secrets	6,863	Apache-2.0	2026-09-16	External Secrets Operator reads information from a third-party service like AWS Secrets …
firecracker-microvm/firecracker	36,827	Apache-2.0	2026-09-16	Secure and fast microVMs for serverless computing.
google/gvisor	19,336	Apache-2.0	2026-09-17	Application Kernel for Containers
e2b-dev/E2B *	13,850	Apache-2.0	2026-09-16	Open-source, secure environment with real-world tools for enterprise-grade agents.
open-telemetry/opentelemetry-collector *	7,559	Apache-2.0	2026-09-17	OpenTelemetry Collector
prometheus/prometheus *	66,101	Apache-2.0	2026-09-16	The Prometheus monitoring system and time series database.

grafana/tempo *	5,476	AGPL-3.0	2026-09-16	Grafana Tempo is a high volume, minimal dependency distributed tracing backend.
promptfoo/promptfoo	25,197	MIT	2026-09-17	Test your prompts, agents, and RAGs. Red teaming/pentesting/vulnerability scanning for AI …
NVIDIA/garak	9,276	Apache-2.0	2026-09-16	the LLM vulnerability scanner
oscal-compass/compliance-trestle	276	Apache-2.0	2026-09-11	An opinionated tooling platform for managing compliance as code, using continuous …
DependencyTrack/dependency-track	4,210	Apache-2.0	2026-09-15	Dependency-Track is an intelligent Component Analysis platform that allows organizations to …
langflow-ai/langflow *	154,904	MIT	2026-09-16	Langflow is a powerful tool for building and deploying AI-powered agents and workflows.
grafana/grafana *	76,779	AGPL-3.0	2026-09-17	The open and composable observability and data visualization platform. Visualize metrics …
modelcontextprotocol/modelcontextprotocol	9,234	MIT -> Apache-2.0 전환 중	2026-09-16	Specification anddocumentation for the Model Context Protocol
modelcontextprotocol/python-sdk *	24,315	MIT	2026-09-16	The official Python SDK for Model Context Protocol servers and clients
a2aproject/A2A *	25,804	Apache-2.0	2026-09-16	Agent2Agent (A2A) is an open protocol enabling communication and interoperability between …
a2aproject/a2a-python	2,142	Apache-2.0	2026-09-15	Official Python SDK for the Agent2Agent (A2A) Protocol
google/adk-python	21,557	Apache-2.0	2026-09-17	An open-source, code-first Python toolkit for building, evaluating, and deploying …
openai/openai-agents-python *	29,505	MIT	2026-09-16	A lightweight, powerful framework for multi-agent workflows
langchain-ai/langgraph *	41,791	MIT	2026-09-14	Build resilient agents.
pydantic/pydantic-ai *	19,993	MIT	2026-09-17	How Python does AI. Agents, realtime voice, image generation, embeddings. Every model …
crewAIInc/crewAI *	58,671	MIT	2026-09-16	Framework for orchestrating role-playing, autonomous AI agents. By fostering collaborative …
microsoft/autogen *	61,008	CC-BY-4.0	2026-04-06	A programming framework for agentic AI
kagent-dev/kagent *	3,745	Apache-2.0	2026-09-16	Cloud Native Agentic AI | Discord: https://bit.ly/kagentdiscord
open-telemetry/semantic-conventions	651	Apache-2.0	2026-09-16	Defines standards for generating consistent, accessible telemetry across a variety of …
open-telemetry/opentelemetry-python	2,636	Apache-2.0	2026-09-16	OpenTelemetry Python API and SDK
kyverno/kyverno	8,156	Apache-2.0	2026-09-17	Unified Policy as Code
cilium/cilium *	25,230	Apache-2.0	2026-09-16	eBPF-based Networking, Security, and Observability
istio/istio *	38,391	Apache-2.0	2026-09-17	Connect, secure, control, and observe services.
qdrant/qdrant *	34,609	Apache-2.0	2026-09-03	Qdrant - High-performance, massive-scale Vector Database and Vector Search Engine for the …
valkey-io/valkey	27,219	BSD-3-Clause	2026-09-16	A flexible distributed key-value database that is optimized for caching and other realtime …

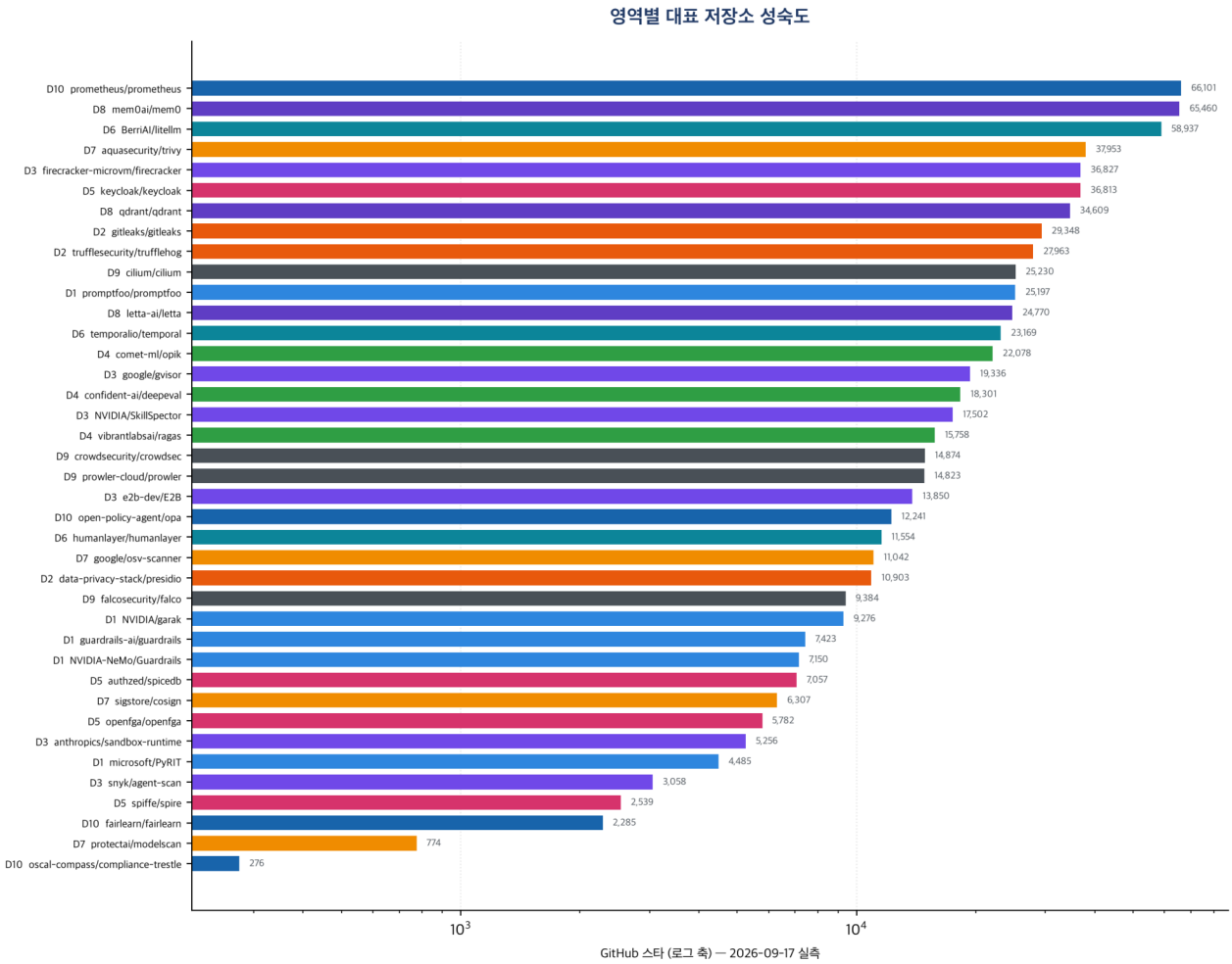


그림 7. 영역별 대표 저장소 스타 수(로그 축) – 2026-09-17 실측. 방어 계층별 성숙도 격차를 보여 준다

10.13 라이선스 5등급

상용 제품에 담을 수 있는지를 기준으로 다섯 등급으로 나눈다. 등급 4 이상은 제품 기본값에서 제외하고 선택 연동으로만 둔다.

등급	성격	대표 라이선스	해당 저장소(발췌)	취급
1	제약 없음	MIT, Apache-2.0, BSD-3-Clause	NVIDIA/garak, promptfoo, open-policy-agent/opa, openfga, spiffe/spire, sigstore/cosign, aquasecurity/trivy	기본값으로 사용
2	약한 카피레프트	MPL-2.0, LGPL-2.1	openbao/openbao(MPL-2.0), logto-io/logto, containers/bubblewrap, seccomp/libseccomp	동적 링크·별도 프로세스 사용 시 안전
3	강한 카피레프트	GPL-3.0, AGPL-3.0	trufflesecurity/trufflehog(AGPL), grafana/grafana(AGPL), grafana/loki(AGPL), zitadel(AGPL), turbot/steampipe(AGPL), gravitational/teleport(AGPL)	별도 프로세스로 격리 호출. 소스 결합 금지
4	소스 공개형 비OSI	BUSL-1.1, SSPL, ELv2, FSL	hashicorp/vault(BUSL-1.1 (Licensor: IBM)), hashicorp/boundary, restatedev/restate, opencve/opencve, inngest/inngest(SSPL), Arize-ai/phoenix(ELv2), BakeLens/crust(ELv2), getagentseal/agentseal(FSL)	기본값 금지. 대안 명시 후 선택 연동
5	모델·데이터 전용 라이선스	Llama Community License, CC-BY-SA, 기업 자체 약관	meta-llama/PurpleLlama(Llama 3.2 Community), TencentCloud/CubeSandbox(Tencent 자체), OWASP 문서(CC-BY-SA-4.0)	가중치·문서 사용 조건을 별도 검토. 코드와 분리 관리

등급 4 의 대체 기본값은 다음과 같다. 시크릿은 openbao/openbao, 관측은 comet-ml/opik, 내구 실행은 temporalio/temporal, 객체 저장은 seaweedfs/seaweedfs 를 쓴다. 모두 Apache-2.0 또는 MIT 이며 실측에서 활성 상태를 확인했다.

10.14 이전·개명·인수 목록

도식 항목에 대응하는 도구를 옛 경로로 적어 두면 문서가 곧 낡는다. 실측에서 확인한 경로 변경은 아래와 같다.

옛 경로	현행 경로	성격	확인 방법
invariantlabs-ai/mcp-scan	snyk/agent-scan	상용 보안 업체로 이관	GitHub API 리다이렉트
microsoft/presidio	data-privacy-stack/presidio	조직 이관	GitHub API 리다이렉트
NVIDIA/NeMo-Guardrails	NVIDIA-NeMo/Guardrails	조직 분리	GitHub API 리다이렉트
pytorch/opacus	meta-pytorch/opacus	조직 이관	GitHub API 리다이렉트
huggingface/safetensors	safetensors/safetensors	조직 분리	GitHub API 리다이렉트
meta-llama/llama-stack	ogx-ai/ogx	개명·이관	GitHub API 리다이렉트
googleapis/genai-toolbox	googleapis/mcp-toolbox	개명	GitHub API 리다이렉트
strands-agents/sdk-python	strands-agents/harness-sdk	개명	GitHub API 리다이렉트
openai/preparedness	openai/frontier-evals	개명	GitHub API 리다이렉트
iterative/dvc	treeverse/dvc	조직 이관	GitHub API 리다이렉트
explodinggradients/ragas	vibrantlabsai/ragas	조직 이관	GitHub API 리다이렉트
Azure/PyRIT	microsoft/PyRIT	아카이브 후 신규 저장소로 이동(리다이렉트 아님)	양쪽 저장소 개별 조회
OWASP/www-project-top-10-…	GenAI-Security-Project/GenAI-LLM-Top10	표준 문서 저장소 이관	README 의 레거시 표시(2026-08-05 커밋)

10.15 아카이브·정체 저장소

저장소	상태	최신 커밋	이 문서에서의 취급
protectai/rebuff	아카이브	2024-01-25	인용만. 스택에서 제외
protectai/llm-guard	아카이브	2026-07-08	인용만. 스택에서 제외
Azure/PyRIT	아카이브	2026-09-16	microsoft/PyRIT 로 대체
lakeraai/pint-benchmark	아카이브	2026-04-02	벤치마크는 JailbreakBench·HarmBench 로 대체
credo-ai/credoai_lens	아카이브	2024-06-13	거버넌스 평가는 OSCAL 계열로 대체
minio/minio	아카이브	2026-02-12	seaweedfs/seaweedfs 로 대체
TheHive-Project/TheHive	아카이브	2025-07-25	사고 대응은 MISP + 자체 원장 조합 권고
tensorflow/model-card-toolkit	아카이브	2023-07-26	모델 카드는 mlflow 메타데이터로 생성
whylabs/langkit	정체	2024-11-22	참고만
aquasecurity/tfsec	정체(trivy 로 통합)	2025-05-02	aquasecurity/trivy 사용
AgentOps-AI/tokencost	정체	2025-09-05	비용 산정은 게이트웨이 계측으로 대체
Yelp/detect-secrets	완만	2026-04-02	gitleaks·trufflehog 보조로만 사용
deepchecks/deepchecks	정체 + AGPL	2025-11-24	평가는 evidently·giskard 로 대체
Trusted-AI/AIF360	완만	2026-06-12	fairlearn 우선, AIF360 보조

11. 독립 구동, 연계, 즉시 사용

이 장은 사용자가 항목을 골라 등록하면 바로 쓸 수 있어야 한다는 요구를 실행 가능한 규격으로 옮긴다. 핵심은 하나다. 모든 에이전트가 같은 매니페스트 규격을 따르면, 독립 실행과 연계 조립과 즉시 사용이 같은 산출물에서 나온다.

11.1 세 모드의 계약

항목	M1 독립	M2 연계	M3 즉시 사용
실행 전제	없음. 바이너리 또는 이미지 하나	게이트웨이 + 레지스트리	콘솔 계정과 대상 등록
설정 원천	명령행 인자 또는 로컬 파일	레지스트리에 배포된 정책	프로파일(검증된 조합)
입출력	표준 입출력 또는 HTTP	관문이 호출. 발견은 버스로	동일. 사용자에게는 숨겨진다
증적	로컬 파일(선택)	중앙 원장	중앙 원장
네트워크	완전 오프라인 가능	내부망	내부망
도입 소요	분 단위	일 단위	30분 이내(NFR-01)
되돌리기	프로세스 종료	관문에서 에이전트 해제	프로파일 해제 버튼

11.2 agent.yaml 규격

에이전트 하나를 정의하는 단일 파일이다. 이 파일만 있으면 세 모드 모두에서 동작한다. 레지스트리 등록, 콘솔 카탈로그 표시, 정책 기본값, 표준 매핑, 누락 검증이 모두 이 파일을 근거로 한다.

```yaml
apiVersion: aegismesh/v1
kind: Agent
metadata:
  id: d1-05                           # 도식 항목 ID 와 동일 (변경 금지)
  name: Hidden Payload Detector
  nameKo: 은닉 페이로드 탐지기
  version: 1.0.0
  source:                             # 도식 추적 (11.5 절 검증 스크립트가 참조)
    diagram: "Security Risks in AI Agents"
    domain: D1
    item: "Hidden payloads"
spec:
  series: C1                          # C1/C2/C3/C4 — 배치 관문을 결정
  gate: input                         # input | tool | output | evidence | offline
  isolation: L1                       # 최소 격리 등급. 미달 시 기동 거부
  verdicts: [block, transform, allow]
  latencyBudgetMs: 30                 # 초과 시 강등 정책 적용
  failMode: closed                    # closed | open
  standards:                          # 판본을 반드시 함께 적는다 (DP7)
    owasp-llm: { version: "2026", ids: [LLM01] }
    owasp-asi: { version: "2026", ids: [ASI01] }
    mitre-atlas: { version: "2026.06", ids: [AML.TA0011] }
    cwe: { version: "4.20", ids: [CWE-94] }
  modes: [cli, rest, mcp, a2a]        # 켤 어댑터
  engines:
    default: unicode_rules
    available:
      - id: unicode_rules
        kind: builtin
      - id: garak
        kind: external
        repo: NVIDIA/garak
        license: Apache-2.0
        invoke: { type: cli, image: "ghcr.io/aegismesh/engine-garak:0.17.0" }
  io:
    input:  { schema: aegismesh.io/JudgeRequest/v1 }
    output: { schema: aegismesh.io/Finding/v1 }
  resources: { cpu: "200m", memory: "256Mi" }
  dependencies: []                    # 비어 있어야 M1 독립 실행이 성립한다
```

```
  tests:
    golden: tests/golden
    attacks: tests/attacks
    baseline: tests/baseline.json
    thresholds: { falsePositiveRate: 0.005, falseNegativeRate: 0.10 }
policy:
  default: policy/default.rego
  overridable: true
```

dependencies 가 비어 있어야 한다는 제약이 DP2(홀로 서기)를 강제한다. 다른 에이전트를 필요로 하는 판정은 오케스트레이터가 조합으로 만들고, 에이전트 자신은 그 사실을 모른다.

11.3 등록 7단계

단계	이름	수행 주체	산출물	실패 시
R1	매니페스트 검증	레지스트리	스키마 검증 결과	등록 거부
R2	서명·출처 확인	레지스트리	서명 검증 기록, SBOM 확인	등록 거부
R3	정적 심사	심사 파이프라인	취약점·라이선스·비밀 스캔 보고서	등록 보류(사람 검토)
R4	격리 시험 실행	샌드박스(L3)	골든셋·공격셋 실행 결과	등록 거부
R5	품질 기준 판정	레지스트리	오탐률·미탐률 대 임계값 비교	경보 전용으로만 등록 허용
R6	카탈로그 공개	콘솔	카탈로그 항목, 한국어·영어 설명	-
R7	적용	사용자	관문 바인딩 또는 단독 실행	롤백

R4 를 최고 격리 등급에서 돌리는 이유는 공격 코퍼스를 실제로 실행하기 때문이다. 미지 플러그인의 첫 실행은 언제나 1회용 microVM 에서 이루어지고, 실행 후 스냅샷은 폐기한다(7.4 절 L3).

11.4 프로파일 다섯 종

M3 즉시 사용은 프로파일이다. 검증된 에이전트 조합과 정책 기본값에 이름을 붙인 것이다. 사용자는 프로파일을 고르고 대상만 지정하면 된다.

프로파일	포함 에이전트	대상	차단 정책	예상 지연
minimal-visibility	C3·C4 계열 28종(관측만)	도입 첫 주. 차단 없이 현황 파악	전부 alert	요청 경로 영향 없음
chatbot-baseline	D1 7종 + D2 3종 + D4 3종 + X05	사용자 대면 챗봇	인젝션·민감정보 차단, 환각은 표시	입력 40ms, 출력 90ms
tool-agent	chatbot-baseline + D3 7종 + D5 5종 + D6 4종 + X01·X04	도구를 호출하는 에이전트	도구 관문 차단, 고위험은 승인	도구 관문 15ms 추가
regulated-kr	tool-agent + D2 전체 + D10 전체 + X08	국내 규제 산업	민감정보 무관용, 증적 전량 보존	출력 140ms
full-mesh	92종 전체	성숙 단계	정책 파일로 세부 제어	NFR-L 예산 전체 사용

```
# 프로파일은 선언형 파일이다. 사용자가 콘솔에서 고르는 것과 동일하다.
apiVersion: aegismesh/v1
kind: Profile
metadata: { id: regulated-kr, nameKo: 국내 규제 산업 기본 }
spec:
  extends: tool-agent
  add:
    - selector: { domain: [D2, D10] }        # 도메인 단위 선택
    - selector: { id: [x08] }
  policyOverrides:
    D2-01: { verdict: block, threshold: 0.60 }   # 민감정보는 임계 낮춤
    D4-01: { verdict: transform }                # 환각은 표시 후 통과
  evidence: { retentionDays: 1825, payload: masked }
  region: { modelEgress: deny }                  # 외부 모델 호출 금지
```

11.5 누락 검증을 빌드 게이트로

DP10 을 강제하는 장치다. 도식 80개 항목 각각에 대해 매니페스트·요구사항·시험·표준 매핑이 존재하는지 검사하고, 하나라도 없으면 빌드를 실패시킨다. 이것이 없으면 시간이 지나며 원래 도식에서 조용히 벗어난다.

```
#!/usr/bin/env python3
"""verify_coverage.py — 도식 항목 대비 산출물 누락 검사 (CI 필수 단계)"""
import sys, glob, yaml, json

DIAGRAM = json.load(open("diagram_items.json"))      # 도식 전사 원본 (3장에서 생성)
EXPECTED = {i["id"] for i in DIAGRAM["items"]}       # D1-01 ... D10-07 (70개)
EXPECTED |= {g["id"] for g in DIAGRAM["gaps"]}       # X01 ... X10  (10개)

manifests = {}
for path in glob.glob("agents/*/agent.yaml"):
    m = yaml.safe_load(open(path))
    manifests[m["metadata"]["id"].upper()] = (path, m)

errors = []
for item in sorted(EXPECTED):
    key = item.replace("-", "-").upper()
    if key not in manifests:
        errors.append(f"[누락] 에이전트 매니페스트 없음: {item}")
        continue
    path, m = manifests[key]
    spec = m.get("spec", {})
    if not spec.get("standards"):
        errors.append(f"[누락] 표준 매핑 없음: {item} ({path})")
    for f in ("golden", "attacks", "baseline"):
        if not spec.get("tests", {}).get(f):
            errors.append(f"[누락] 시험 자산 없음: {item}.{f}")
    if spec.get("dependencies"):
        errors.append(f"[위반] DP2 독립 실행 — dependencies 가 비어 있지 않음: {item}")
    if spec.get("series") in ("C1", "C2") and spec.get("failMode") != "closed":
        errors.append(f"[위반] DP5 — 인라인 계열인데 failMode 가 closed 가 아님: {item}")

extra = set(manifests) - EXPECTED - {f"P{n:02d}" for n in range(1, 13)}
for e in sorted(extra):
    errors.append(f"[경고] 도식에 근거가 없는 에이전트: {e}")

print(f"검사 대상 {len(EXPECTED)}개, 매니페스트 {len(manifests)}개, 문제 {len(errors)}건")
for e in errors:
    print(" ", e)
sys.exit(1 if any(not x.startswith("[경고]") for x in errors) else 0)
```

검사	실패 조건	결과
에이전트 존재	도식 항목에 대응하는 agent.yaml 이 없다	빌드 실패
표준 매핑	standards 필드가 비었다	빌드 실패
시험 자산	골든셋·공격셋·기준선 중 하나라도 없다	빌드 실패
독립성	dependencies 가 비어 있지 않다	빌드 실패(DP2 위반)
강등 기본값	인라인 계열인데 failMode 가 open	빌드 실패(DP5 위반)
근거 없는 추가	도식·보강·플랫폼 어디에도 없는 에이전트	경고(차단하지 않음)

11.6 즉시 사용 화면의 정보 구조

영역	내용	사용자 행동
1. 위험 지도	도식과 같은 10분류 70항목 격자. 적용 여부를 색으로 표시	빈 칸을 눌러 해당 에이전트 상세로 이동

2. 프로파일	다섯 종 카드. 포함 항목 수·예상 지연·차단 정책 요약	하나 선택
3. 대상	보호할 서비스·엔드포인트·모델 공급자	대상 등록
4. 미리보기	최근 트래픽 표본에 대해 차단 없이 판정만 재생	예상 차단 건수·오탐 추정 확인
5. 적용	차단 없이 관측만 / 부분 차단 / 전체 차단 3단계	단계 선택 후 적용

4번 미리보기 영역이 도입 성공률을 좌우한다. 차단을 켜기 전에 과거 트래픽으로 판정을 재생해 예상 차단 건수를 보여 주지 않으면, 운영 팀은 차단을 켜지 않는다. 이 재생 기능은 NFR-Q1 오탐 측정과 같은 파이프라인을 쓴다.

12. 데이터 모델, API, 프로토콜

12.1 Finding – 판정 단일 표현

92종 에이전트가 무엇을 하든 결과는 하나의 형식으로 나온다. 증적 원장·상관 분석·보고서·콘솔이 모두 이 형식만 안다.

```
{
  "schema": "aegismesh.io/Finding/v1",
  "id": "fnd_01JB9X2K7Q",
  "traceId": "4bf92f3577b34da6a3ce929d0e0e4736",   // W3C Trace Context
  "spanId": "00f067aa0ba902b7",
  "agent": { "id": "d1-05", "version": "1.0.0", "engine": "unicode_rules" },
  "subject": {                                      // 누가, 무엇에 대해
    "tenant": "acme",
    "principal": { "type": "user", "id": "u_1029" },
    "onBehalfOf": { "type": "agent", "id": "支援-bot", "spiffeId": "spiffe://acme/agent/support" },
    "resource": { "type": "chat.request", "id": "req_88121" }
  },
  "gate": "input",
  "verdict": "block",                               // allow|block|require_approval|transform|alert
  "confidence": 0.97,
  "severity": "high",                               // info|low|medium|high|critical
  "ruleId": "D1-05.unicode-tag",
  "evidence": [                                     // DP3 — 근거 없는 판정 금지
    { "kind": "span", "offset": 142, "length": 18, "note": "U+E0041 태그 블록 18자" }
  ],
  "standards": {
    "owasp-llm": { "version": "2026", "ids": ["LLM01"] },
    "owasp-asi": { "version": "2026", "ids": ["ASI01"] },
    "mitre-atlas": { "version": "2026.06", "ids": ["AML.TA0011"] },
    "cwe": { "version": "4.20", "ids": ["CWE-94"] }
  },
  "action": { "taken": "blocked", "transform": null, "approvalRef": null },
  "latencyMs": 11,
  "payloadRef": null,                               // 기본 미보존 (NFR-D1)
  "occurredAt": "2026-09-17T04:12:33.912Z"
}
```

필드	필수	설명
agent	필수	판정 주체. 버전과 사용 엔진을 함께 남겨야 회귀 추적이 된다
subject.onBehalfOf	조건부	에이전트가 사람을 대리할 때 필수. D5-05 역할 혼동 판정의 근거가 된다
verdict	필수	다섯 값만 허용. 새 값을 추가하려면 스키마 판올림이 필요하다
evidence	필수	비어 있으면 판정은 무효다(DP3, NFR-Q3)
standards	필수	판본 문자열을 반드시 포함한다(DP7)
payloadRef	선택	원문 보존을 켠 경우에만 참조 키가 들어간다. 원문 자체는 절대 담지 않는다

12.2 핵심 엔티티

엔티티	설명	주요 관계
Agent	에이전트 정의(agent.yaml 의 런타임 표현)	Agent 1:N Finding, Agent N:M Gate
Gate	관문. input/tool/output/evidence	Gate N:M Agent, Gate 1:N Policy
Policy	선언형 정책과 임계값	Policy 1:N Decision
Finding	단일 판정	Finding N:1 Agent, Finding N:1 Incident
Incident	상관 분석으로 묶인 사건	Incident 1:N Finding, Incident 1:N Action
Approval	사람 승인 요청과 결과	Approval 1:1 Finding, Approval N:1 Principal

Evidence	불변 원장 레코드	Evidence 1:1 Finding 또는 Action
Control	규제·표준 통제 항목	Control N:M Agent(매핑), Control 1:N Report
Profile	즉시 사용 조합	Profile N:M Agent
RiskItem	도식 원본 항목(D1-01 등)	RiskItem 1:1 Agent – 누락 검증의 기준

마지막 줄의 RiskItem 이 이 시스템의 기준점이다. 도식에서 전사한 80개 항목이 데이터베이스에 들어 있고, 그것과 Agent 의 1대1 관계가 깨지면 11.5 절 검사에서 빌드가 실패한다.

12.3 REST API

```
POST   /v1/judge                        # 단일 판정. 에이전트 독립 실행(M1)과 동일 경로
POST   /v1/judge:batch                  # 관문이 여러 에이전트를 병렬 호출할 때
GET    /v1/agents                       # 카탈로그
GET    /v1/agents/{id}                  # 매니페스트 + 실측 품질 지표
POST   /v1/agents                       # 등록 (11.3 절 R1~R5 파이프라인 기동)
GET    /v1/risk-items                   # 도식 80개 항목과 적용 현황 (콘솔 1번 영역)
POST   /v1/profiles/{id}:apply          # 즉시 사용 적용
GET    /v1/findings?incident=&from=     # 조회
GET    /v1/incidents/{id}               # 상관 분석 결과
POST   /v1/approvals/{id}:decide        # 사람 승인
GET    /v1/evidence:export              # 감사 증적 내보내기 (서명 포함)
GET    /v1/reports/{control-framework} # 컴플라이언스 보고서
GET    /v1/coverage                     # 도식 대비 커버리지 (누락 검증 결과)
GET    /healthz  /readyz  /metrics      # 운영
```

12.4 MCP 와 A2A

에이전트를 다른 시스템에 물리는 방법은 두 가지다. 도구로 노출할 때는 MCP, 에이전트로 협력할 때는 A2A 를 쓴다.

구분	MCP	A2A
판본	2026-07-28 (2026-07-28) 개정	v1.0.1 (2026-05-28)
쓰임	코딩 에이전트·챗봇이 판정 기능을 도구로 호출	판정 에이전트끼리, 또는 외부 에이전트와 협력
노출 형태	judge, explain, list_rules 세 도구	AgentCard 공개 + 태스크 기반 협력
신원	서버 신원 검증 + 도구 허용목록	AgentCard 서명 검증(X01 요구사항)
장시간 작업	core 에 태스크 개념이 없어 확장에 의존	Task 수명주기로 직접 표현. 레드팀 실행 등 장시간 작업은 A2A 사용
주의	개정이 잦다. 서버·클라이언트 판본 혼재를 전제로 협상 로직을 둔다	레지스트리 표준이 아직 정착 중

```
# MCP 서버로 노출 (독립 실행 M1 과 동일 산출물)
$ aegis serve d1-05 --protocol mcp --stdio

# 코딩 에이전트 설정 예
{
  "mcpServers": {
    "aegis-d1-05": {
      "command": "aegis",
      "args": ["serve", "d1-05", "--protocol", "mcp", "--stdio"]
    }
  }
}
```

12.5 관측 규약

- 지표·추적·로그는 OpenTelemetry 규약을 따른다. 시맨틱 컨벤션은 v1.44.0 (2026-08-04) 를 기준으로 하되, GenAI 영역은 아직 개발 단계 상태이므로 판본을 고정하고 변경을 추적한다.

- 추적 컨텍스트는 W3C Trace Context 를 쓴다. 관문·에이전트·도구 실행이 같은 traceId 를 공유해야 사건 재구성이 가능하다.
- 에이전트 고유 지표는 aegismesh 접두사를 쓴다. 예: aegismesh.judge.duration, aegismesh.verdict.count, aegismesh.false_positive.budget.
- 로그 수집 단계에서 마스킹한다. 수집기 파이프라인에 개인정보 탐지 프로세서를 넣어 원문이 저장소에 닿지 않게 한다(NFR-D1).

```
# OpenTelemetry Collector 파이프라인 — 마스킹을 수집 단계에 둔다
processors:
  transform/mask:
    log_statements:
      - context: log
        statements:
          - replace_pattern(body, "(sk-[A-Za-z0-9]{20,})", "[REDACTED_API_KEY]")
  attributes/drop_payload:
    actions:
      - key: gen_ai.prompt
        action: delete
      - key: gen_ai.completion
        action: delete
service:
  pipelines:
    logs:
      receivers: [otlp]
      processors: [transform/mask, attributes/drop_payload, batch]
      exporters: [otlphttp/evidence]
```

12.6 증적 원장

요구	구현
추가 전용	삭제·수정 API 미제공. 보존기한 만료 처리는 승인된 배치 작업으로만
변조 탐지	레코드 해시 체인 + 주기적 체크포인트 서명
조회 성능	열 지향 저장으로 기간·테넌트·에이전트·심각도 축 질의
내보내기	서명된 묶음으로 내보낸다. 감사자가 독립 검증할 수 있어야 한다
보존	기본 90일 온라인, 규제 프로파일은 5년(11.4 절 regulated-kr)
분리	테넌트별 논리 분리. 규제 요구 시 물리 분리 옵션

13. 보안, 법적, 윤리 고려사항

13.1 이중 용도 통제

이 시스템은 방어를 위해 공격 기법을 실행한다. 레드팀 에이전트(AG-X09)와 D1 계열의 공격 코퍼스가 그렇다. 같은 자산이 공격 도구가 될 수 있으므로 별도 통제를 둔다.

통제	내용	근거
대상 범위 강제	레드팀 실행 대상은 사전 등록된 자산으로 제한한다. 미등록 대상 지정 시 실행을 거부한다	권한 없는 시험은 법적 문제가 된다
실행 승인	공격 코퍼스 실행은 조직 단위 승인 후에만 가능하다. 승인 기록은 증적 원장에 남는다	책임 소재 확보
자산 분리	공격 코퍼스·페이로드는 별도 저장소와 권한으로 관리하고 운영 클러스터에 상주시키지 않는다	NFR-S
결과 취급	레드팀 결과는 취약점 정보다. 일반 증적과 분리해 접근 권한을 좁힌다	정보 확산 통제
격리 등급	레드팀 실행은 예외 없이 L3(1회용 microVM, 네트워크 완전 차단)	7.4 절
공개 정책	자체 발견 취약점은 책임 있는 공개 절차를 따른다	커뮤니티 규범

13.2 오픈소스 라이선스 리스크

리스크	내용	대응
카피레프트 전파	AGPL 도구를 프로세스 내 결합하면 제품 전체에 공개 의무가 번질 수 있다	AGPL 도구는 예외 없이 별도 프로세스·컨테이너로 격리하고 네트워크 호출로만 연동한다
비OSI 라이선스	BUSL·SSPL·ELv2·FSL 은 호스팅·재판매를 제한한다	10.13 절 등급 4 는 기본값에서 제외. 대안을 명시하고 선택 연동으로만 둔다
라이선스 변경	상용 업체 인수 후 라이선스가 바뀐 전례가 반복된다	고정 버전 사용, 포크 가능성 사전 검토, 교체 가능 엔진 구조(DP8)
모델 가중치	코드와 가중치의 라이선스가 다르다. Llama 계열은 사용자 수 조건과 파생 명명 조건이 붙는다	가중치는 코드와 분리해 관리하고, 배포 대상에 포함하기 전 개별 검토
데이터셋	공격 코퍼스·평가셋에 CC-BY-SA 등 공유 조건이 붙는다	데이터셋별 라이선스를 매니페스트에 기록하고 재배포 시 조건 준수
표준 문서	OWASP 문서는 CC-BY-SA-4.0 이다	인용 시 출처와 라이선스를 밝히고, 문서 자체를 재배포하지 않는다

13.3 개인정보와 데이터 보호

- **판정 경로는 최고 등급 데이터를 지난다.** 프롬프트에는 개인정보가 섞인다. 판정 요청을 로그로 남기는 것만으로 유출 경로가 생긴다. 기본값은 원문 미보존이다(NFR-D1).
- **마스킹은 수집 단계에서 한다.** 저장 후 마스킹은 이미 늦다. 수집기 파이프라인에 프로세서를 넣는다(12.5 절).
- **삭제는 전파되어야 한다.** 삭제 요청은 원본·인덱스·캐시·백업까지 닿아야 한다. D2-07 요구사항이 곧 법적 의무다.
- **국외 이전은 명시 허용만.** 외부 모델 공급자 호출은 정책에서 켠 경우로 한정하고, 켠 사실을 증적에 남긴다.
- **한국어 개인정보 처리.** 영문 중심 탐지기만으로는 주민등록번호·계좌·한국식 주소 표기를 놓친다. Marker-Inc-Korea/ko-pii 같은 한국어 전용 사전을 병행한다.

13.4 판정의 공정성과 설명 책임

쟁점	내용	요구사항 대응
차단의 편향	특정 언어·집단·표현 방식에 대해 차단율이 높게 나올 수 있다	D10-05. 집단별 차단율을 정례 측정하고 격차를 공개 지표로 관리
설명 요구	차단된 사용자는 이유를 알 권리가 있다	DP3·NFR-Q3. 모든 판정은 규칙 식별자와 근거를 동반한다. 사용자 노출 문구는 별도 정의
이의 제기	오탐에 대한 정정 경로가 없으면 신뢰를 잃는다	판정 이의 신청과 재판정 절차를 콘솔에 둔다. 결과는 골든셋에 편입

감시 전용화	판정 로그가 직원 감시 수단으로 전용될 수 있다	목적 제한을 정책으로 선언하고, 원문 보존 설정 변경은 2인 승인 대상
자동 차단의 한계	되돌리기 어려운 차단은 사람 검토를 거쳐야 한다	D6-01·D6-07. 금전·계약·통지 행동은 승인 경유

13.5 알려진 오탐·미탐 특성

방어 도구는 특성이 다르다. 어느 쪽 오류를 감수할지 미리 정해 두지 않으면 운영에서 임의로 꺼진다.

에이전트 계열	잦은 오탐 유형	잦은 미탐 유형	권장 기본 임계
D1 인젝션	보안 문서·코드 예제·프롬프트 공학 논의를 공격으로 오인	새 인코딩, 다국어 우회, 다단계 누적 유도	차단 0.85, 경보 0.60
D2 민감정보	식별자 형식과 유사한 일반 숫자열	문맥으로만 식별되는 준식별자 조합	차단 0.70(규제 프로파일 0.60)
D3 도구 오남용	정당한 대량 작업	정상 인자로 위장한 누적 파괴	정책 기반 판정 우선, 점수는 보조
D4 환각	요약·의역을 근거 없음으로 판정	그럴듯한 부분 오류	차단하지 않고 표시 우선
D8 메모리	정당한 장기 선호 저장	느린 누적 조작	쓰기 승인 정책으로 대체

14. 도식 검증

도식에 실제로 적힌 표기만 판정 대상으로 삼는다. 도식이 말하지 않은 것을 추정해 오류로 몰지 않는다. 판정 구분은 여덟 가지다. 일치, 부분일치, 낡음, 중복, 범주 혼재, 공백, 표기 오류, 해석 주의.

14.1 판정표

번호	도식 표기·구성	실측 대조	판정
V01	분류 10개, 분류마다 세부 항목 7개	전사 결과 정확히 10 x 7 = 70. 구조가 일관된다	일치
V02	Prompt Injection Attacks 를 첫 갈래로 배치	OWASP 2025·2026 모두 LLM01 이 Prompt Injection. 순위 인식이 표준과 같다	일치
V03	D1-07 System prompt leakage	2025판 LLM07 이었으나 2026판에서 LLM08 Hidden Context Exposure 로 재정의·확장. 도식 표기는 2025판 기준	**낡음**
V04	Data Leakage Risks 에 Training data recall 포함	학습 단계에서 결정되는 성질이라 런타임 게이트웨이로는 막을 수 없다. 방어는 학습 통제·추출 시험으로만 가능	부분일치
V05	Tool Misuse & Abuse 의 System compromise	ASI05 Unexpected Code Execution (RCE) 와 정확히 대응	일치
V06	Model Hallucination Risks 를 보안 위험으로 분류	OWASP 2026 은 LLM07 Misinformation 으로 보안 항목에 포함한다. 분류 자체는 표준과 일치하나, 환각은 기밀성·무결성·가용성 어디에도 정확히 들어맞지 않는다	해석 주의
V07	D4-05 Compliance violations 와 D10 Governance 의 관계	출력 수준 규정 위반과 조직 수준 거버넌스 공백이 같은 단어로 표현된다. 실제로는 다른 관문에서 다루어야 한다	**중복**
V08	Access Control Failures 7항목	ASI03 Identity & Privilege Abuse 의 하위 구성과 대응한다. 누락 없음	일치
V09	D2-04 Unauthorized access 와 D5-02 Broken authorization	같은 인가 실패를 데이터 관점과 통제 관점으로 나눠 적었다. 에이전트 분리는 가능하나 정책은 공유해야 한다	**중복**
V10	D2-03 API key leaks 와 D5-06 Token misuse	자격증명이 새는 것과 오용되는 것을 분리했다. 분리 자체는 타당하나 대응 도구가 같다	부분일치
V11	Autonomous Agent Overreach 의 Financial damage	위험 원인이 아니라 결과(영향)다. 같은 층위에 원인과 결과가 섞여 있다	**범주 혼재**
V12	D6-02 Recursive actions 와 D6-03 Infinite loops	재귀 생성과 무한 반복은 원인이 다르지만 도식에서는 병렬 항목이다. 대응 수단은 공유된다	부분일치
V13	Supply Chain Vulnerabilities 의 Model poisoning	2026판 LLM05 Data and Model Poisoning 과 대응. 2025판에서는 LLM04 였다	일치(번호만 변동)
V14	Memory & Context Exploits 구성	ASI06 Memory & Context Poisoning 과 대응. 다만 벡터·임베딩 고유 취약(LLM09)은 D8-05 한 줄로만 다룬다	부분일치
V15	Infrastructure-Level Risks 를 동급 분류로 배치	OWASP LLM·ASI 범위 밖이지만 실제 사고에서는 결정적이다. 일반 보안 표준으로 다루어야 할 영역을 같은 층에 둔 것은 실무적으로 타당하다	해석 주의
V16	D9-07 DDoS attacks	2026판 LLM06 Unbounded Consumption 과 상당 부분 겹친다. 인프라 계층에만 둔 것은 좁은 해석이다	**중복**
V17	D10-07 Lack monitoring	영문 표기가 Lack of monitoring 이어야 자연스럽다. 의미 전달에는 지장 없음	**표기 오류(경미)**
V18	ASI07 Insecure Inter-Agent Communication	도식에 대응 항목이 없다. 멀티 에이전트 전제에서는 필수 항목	**공백**
V19	ASI08 Cascading Failures	도식에 대응 항목이 없다	**공백**
V20	ASI09 Human-Agent Trust Exploitation	도식에 대응 항목이 없다	**공백**
V21	ASI10 Rogue Agents	도식에 대응 항목이 없다	**공백**
V22	LLM10 Improper Output Handling	출력의 하위 시스템 해석 위험(XSS·SQL 주입·SSRF)이 도식에 없다. 환각과는 다른 문제다	**공백**
V23	멀티모달 공격면	이미지·오디오·문서 내부 지시가 도식에 없다. 2026년 사고의 상당수가 여기서 나온다	**공백**
V24	심각도·우선순위 표기	70개 항목이 모두 같은 무게로 그려졌다. 실제로는 발생 빈도와 영향이 크게 다르다. OWASP AIVSS 같은 점수 체계가 필요하다	**공백**
V25	발생 빈도·근거 데이터	도식에 수치·출처가 없다. 위험 목록으로는 유용하나 우선순위 결정 근거로는 부족하다	**공백**
V26	원 출처 URL·게시 일자	이미지 내부에 URL·일자 표기가 없어 원본 판본을 확인할 수 없다	**검증 불가**
V27	중앙 아이콘(방패·자물쇠·체크)	방어 주체를 뜻하는 은유로 읽었다. 도식에 설명 문구가 없어 다른 해석도 가능하다	해석 주의
V28	화살표 방향(중심에서 바깥으로)	에이전트가 열 방향의 위험에 노출된다는 뜻으로 읽었다	해석 주의
V29	D8-01 Context poisoning 과 D1-01 Malicious instructions	간접 프롬프트 인젝션은 둘 다에 걸친다. 경계가 시점(즉시 대 지속)으로만 갈린다	부분일치
V30	방어 수단·도구 언급 없음	도식은 위험 목록 전용이다. 결함이 아니라 범위의 문제	해석 주의

V31	OWASP LLM Top 10 2026 커버리지	도식 70항목이 LLM01~LLM09 를 덮고 LLM10 만 비어 있다. 10개 중 9개 = 90%	정량 확인
V32	OWASP ASI 2026 커버리지	ASI01~ASI06 을 덮고 ASI07~ASI10 이 비어 있다. 10개 중 6개 = 60%	정량 확인

14.2 판정 집계

판정	건수	의미	문서에서의 처리
일치	5	도식 표기가 현행 표준과 어긋나지 않는다	그대로 요구사항으로 전개
부분일치	6	방향은 맞으나 범위나 경계가 다르다	요구사항에서 경계를 명시
낡음	1	2025 판 기준 표기	4.1 절 대조표로 보정
중복	3	다른 분류에 같은 개념이 다시 나온다	에이전트는 분리하되 정책을 공유
범주 혼재	1	원인과 결과가 같은 층위에 있다	영향 지표로 재분류
표기 오류	1	영문 표기의 경미한 문법 문제	원문 유지, 각주 처리
공백	7	도식에 없는 필수 항목	X01~X10 보강 항목으로 추가
해석 주의	5	도식에 설명이 없어 해석이 갈린다	해석 근거를 본문에 명시
검증 불가	1	확인 수단이 없다	미확인으로 표기
정량 확인	2	커버리지 측정 결과	5장 범위 정의에 반영
합계	**32**		

14.3 도식에 대한 종합 평가

도식은 2026년 중반까지의 AI 에이전트 위험 지형을 충실히 담고 있다. 열 개 분류 구성은 OWASP 2026 판과 90% 겹치고, 인프라와 거버넌스를 같은 층에 둔 것은 표준보다 오히려 실무에 가깝다. 가장 큰 한계는 두 가지다.

1. **단일 에이전트 전제.** 에이전트가 여럿일 때 생기는 통신·연쇄·이탈 위험이 통째로 빠져 있다. 멀티 에이전트를 지향하는 이 문서에서는 그대로 쓸 수 없어 X01~X04 를 추가했다.
2. **무게가 없다.** 70개 항목이 모두 같은 크기로 그려져 있어 무엇부터 해야 할지 알 수 없다. 이 문서는 6.14 절의 우선순위와 11.4 절의 프로파일로 그 무게를 부여했다.

반대로 도식이 잘한 점도 분명하다. 대부분의 유사 도식이 프롬프트 인젝션과 데이터 유출에서 멈추는 데 비해, 이 도식은 공급망·메모리·거버넌스까지 열 개 축을 균형 있게 펼쳤다. 이 문서가 92종 에이전트로 전개할 수 있었던 것은 도식의 세부 항목이 충분히 구체적이었기 때문이다.

15. 지표, 로드맵, 리스크

15.1 성공 지표

구분	지표	1단계 목표	정상 운영 목표	측정 방법
커버리지	도식 80개 항목 중 에이전트가 구현된 비율	P0 39건 100%	80건 100%	verify_coverage.py CI 출력
커버리지	OWASP LLM 2026 10개 항목 대응률	9/10	10/10(LLM10 은 X05 로)	매니페스트 standards 집계
커버리지	OWASP ASI 2026 10개 항목 대응률	6/10	10/10(X01~X04 포함)	매니페스트 standards 집계
품질	인라인 오탐률	1.0% 이하	0.5% 이하	주간 골든셋 재생
품질	공개 공격 코퍼스 미탐률	20% 이하	10% 이하	garak·JailbreakBench·HarmBench 정기 실행
성능	입력 관문 p95 지연	150ms	80ms	관문 계측
성능	도구 관문 p95 지연	40ms	20ms	관문 계측
도입	첫 판정까지 걸린 시간	2시간	30분	설치 실측
도입	차단 모드로 전환한 고객 비율	30%	70%	적용 단계 집계
운영	판정 설명 제공률	100%	100%	Finding 스키마 검사
운영	증적 무결성 검증 성공률	100%	100%	해시 체인 정기 검증
운영	사건 평균 재구성 시간	1시간	10분	사고 훈련 측정

도입 지표 중 차단 모드 전환율이 가장 중요하다. 관측만 하고 차단을 켜지 않는 설치는 실질적으로 방어가 아니다. 이 수치가 낮으면 원인은 거의 항상 오탐이다.

15.2 단계별 로드맵

단계	기간	범위	산출물	완료 기준
0. 기반	0~2개월	에이전트 공통 골격, 매니페스트 규격, Finding 스키마, 누락 검증 CI	공통 라이브러리, agent.yaml 스키마, verify_coverage.py	표본 에이전트 3종이 M1 으로 단독 실행된다
1. 요청 경로	2~5개월	D1 7종, D3 7종, D5 5종, X05 + 게이트웨이·정책 결정점	입력·도구 관문, chatbot-baseline 프로파일	차단 모드로 실서비스 1건 적용. 오탐률 1% 이하
2. 데이터·자율성	5~8개월	D2 7종, D4 7종, D6 7종, X01·X04 + 증적 원장, 승인 흐름	출력 관문, tool-agent 프로파일, 증적 내보내기	감사 증적으로 사건 재구성 훈련 통과
3. 공급망·인프라	8~12개월	D7 7종, D8 7종, D9 7종, X02·X06·X07	상시 점검 파이프라인, 레지스트리 심사 R1~R5	미검증 MCP 서버 등록 차단이 동작
4. 거버넌스	12~15개월	D10 7종, X03·X08·X09·X10 + 컴플라이언스 보고	regulated-kr 프로파일, 통제 매핑 자동 보고서	외부 감사 대응 시연 통과
5. 성숙	15~18개월	full-mesh, 다중 테넌시, 폐쇄망, 장터	콘솔 장터, 서드파티 에이전트 등록	외부 조직이 만든 에이전트가 등록·실행된다

15.3 성숙도 단계

수준	이름	상태	특징	다음 단계 조건
L1	가시성	상시 계열만 배치. 차단 없음	무엇이 일어나는지 안다. 요청 경로에 영향이 없다	오탐 추정치가 예산 안에 들어온다
L2	선택 차단	고신뢰 규칙만 차단, 나머지는 경보	명백한 공격은 막는다. 운영 부담이 낮다	차단 건 검토 대기열이 하루 안에 비워진다
L3	관문 차단	입력·도구·출력 3관문 모두 차단 활성	심층 방어가 성립한다	사건 재구성 훈련을 통과한다
L4	자율 대응	발견이 정책을 자동 변경. 격리·회수까지 자동	탐지에서 대응까지 사람 개입 없이 닫힌다	-

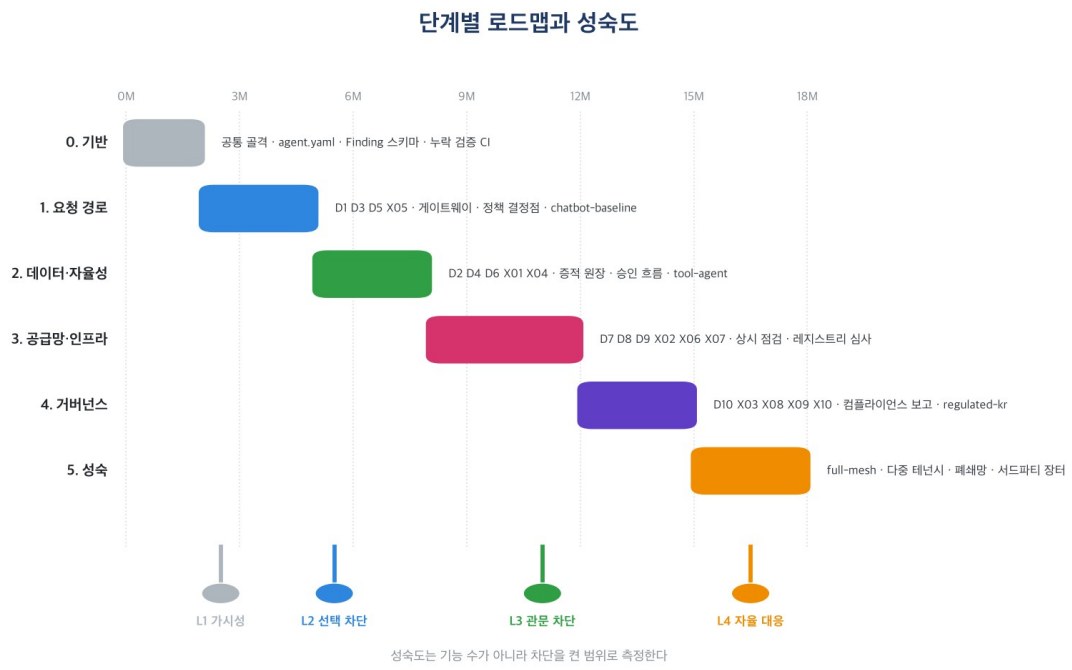


그림 8. 단계별 로드맵과 성숙도 — 어느 단계에서 어떤 도메인이 켜지는가

15.4 리스크 등록부

ID	리스크	영향	가능성	대응
R01	오탐으로 운영 팀이 차단을 끈다	높음	높음	미리보기 재생 기능 필수 제공(11.6 절), 오탐 예산과 자동 강등(NFR-Q6)
R02	인라인 지연이 서비스 지연 예산을 잡아먹는다	높음	중간	관문 단위 예산 강제, 모델 기반 판정은 인라인 금지, 사이드카 토폴로지
R03	의존 오픈소스가 아카이브되거나 라이선스가 바뀐다	중간	높음	교체 가능 엔진 구조(DP8), 실측 기반 분기 점검, 등급 4 기본값 배제
R04	표준이 개정되어 매핑이 낡는다	중간	높음	매핑을 코드로 유지(4.5 절), 판본 명시, CI 검사
R05	92종 에이전트의 운영 부담이 과도하다	높음	중간	프로파일 중심 도입, 공통 골격으로 운영 표면 축소, 기본값은 minimal-visibility
R06	판정 경로가 새 공격 표면이 된다	치명	낮음	NFR-S 전 항목, 자체 SBOM·서명, 레드팀 자산 분리
R07	증적 보존이 개인정보 위험을 키운다	높음	중간	원문 미보존 기본값, 수집 단계 마스킹, 보존 설정 변경은 2인 승인
R08	멀티 에이전트 프로토콜이 아직 흔들린다	중간	높음	MCP·A2A 판본 고정과 협상 로직, 프로토콜 계층을 어댑터로 격리
R09	도식 항목 일부는 런타임 방어로 막을 수 없다	중간	확정	D2-05 학습 데이터 재현 등은 시험·통제로만 대응함을 명시(V04 판정)
R10	경쟁 제품이 같은 도식을 더 빨리 구현한다	낮음	중간	차별점은 항목 단위 독립성과 증적 품질. 기능 수 경쟁을 하지 않는다

15.5 다음 결정이 필요한 사항

번호	결정 사항	선택지	권고
Q1	기본 인라인 판정 방식	규칙 기반 / 소형 분류기 / 모델 호출	규칙 + 소형 분류기. 지연 예산(NFR-L)이 모델 호출을 허용하지 않는다
Q2	증적 저장소	열 지향 DB / 로그 시스템 / 객체 저장 + 색인	열 지향 DB 기본, 장기 보존은 객체 저장으로 계층화
Q3	정책 언어	선언형 정책 언어 / 자체 DSL / 설정 파일	기존 정책 엔진 채택. 자체 DSL 은 학습 비용과 검증 도구 부재로 불리
Q4	에이전트 배포 단위	컨테이너 / 프로세스 내 플러그인 / 서버리스	컨테이너. 의존성 충돌과 격리 요구가 다른 선택지를 배제한다
Q5	장터 개방 시점	1단계 / 5단계 / 개방하지 않음	5단계. 서드파티 에이전트는 심사 파이프라인(R1~R5)이 성숙한 뒤
Q6	한국어 판정 자원	외부 상용 / 오픈소스 조합 / 자체 구축	오픈소스 조합으로 시작하고 골든셋을 자체 축적

부록 A. 용어

용어	설명
간접 프롬프트 인젝션	사용자가 아니라 모델이 읽는 외부 콘텐츠(웹·문서·도구 응답)에 지시를 심는 공격
관문(Gate)	요청 경로 위에서 판정이 일어나는 지점. 입력·도구·출력·증적 네 개
계열(Series)	에이전트의 실행 시점 분류. C1 입출력 인라인, C2 도구 인라인, C3 상시, C4 증적
격리 등급	L0 동일 프로세스부터 L3 1회용 microVM 까지 네 단계
강등(Degradation)	장애·과부하 시 차단 또는 통과로 동작을 낮추는 것. 반드시 증적에 남긴다
골든셋	정상 트래픽 표본. 오탐률 측정 기준
근거성(Groundedness)	출력의 각 주장이 제공된 근거 문서로 뒷받침되는 정도
매니페스트	agent.yaml. 에이전트의 신원·능력·정책 기본값·표준 매핑을 담는 단일 파일
멤버십 추론	특정 데이터가 학습에 쓰였는지를 모델 응답으로 추정하는 공격
발견(Finding)	에이전트가 내는 단일 판정 레코드
숨은 컨텍스트	시스템 지시·도구 스키마·정책문 등 사용자에게 보이지 않는 컨텍스트. OWASP 2026 LLM08 의 대상
스포트라이팅	데이터와 지시를 구분자·표식으로 분리해 모델이 데이터를 지시로 읽지 않게 하는 기법
오케스트레이터	판정 요청을 여러 에이전트에 분배하고 결과를 합성하는 플랫폼 구성요소
원장(Ledger)	추가 전용 증적 저장소. 삭제·수정 API 를 제공하지 않는다
프로파일	검증된 에이전트 조합과 정책 기본값에 이름을 붙인 것. 즉시 사용의 단위
AIVSS	OWASP 가 제안한 AI 시스템 취약점 점수 체계
A2A	Agent2Agent. 에이전트 간 협력 프로토콜
ASI	OWASP Agentic Security Initiative. Agentic Applications Top 10 의 식별자 접두사
ASCII smuggling	유니코드 태그 블록 등 비가시 문자로 지시를 숨기는 기법
MCP	Model Context Protocol. 모델·에이전트가 도구와 자원에 접근하는 프로토콜
OSCAL	NIST 의 통제·평가 정보를 기계 판독 형식으로 표현하는 표준
SBOM	소프트웨어 구성 명세. 공급망 취약점 대조의 기준
SVID	SPIFFE 워크로드 신원 문서(X.509 또는 JWT)
ReBAC	관계 기반 접근 제어. 객체 간 관계로 권한을 판정한다

부록 B. 출처 총람

B.1 원본 도식

구분	내용
제목	Security Risks in AI Agents
표기된 작성자	Rushika Rai
입수	사용자 첨부 이미지
원 게시 URL	[미확인] – 이미지 내부에 URL·게시 일자 표기 없음
저작권	표기된 작성자에게 있음. 본 문서는 텍스트 항목을 인용해 분석하며 이미지를 재배포하지 않음
본 문서의 그림	그림 1~8 은 모두 자체 제작. 원본 도식을 복제하지 않음

B.2 표준·규제 문서

문서	발행처	판본·일자	접근 경로
OWASP GenAI LLM Top 10 2026	OWASP GenAI Security Project	2026-08-04	github.com/GenAI-Security-Project/GenAI-LLM-Top10 (2026/final)
OWASP Top 10 for LLM Applications 2025	OWASP	2.0.0 (2025-01-27)	github.com/OWASP/www-project-top-10-for-large-language-model-applications (2_0_vulns)
OWASP Top 10 for Agentic Applications (ASI) 2026	OWASP GenAI Security Project	2025-12-09 공개	위 2026 저장소 mappings/asi-2026.json
MITRE ATLAS	MITRE	2026.06 매핑본	atlas.mitre.org, mitre-atlas/atlas-navigator-data
MITRE ATT&CK	MITRE	v19.1 매핑본	attack.mitre.org
CWE	MITRE	4.20	cwe.mitre.org
NIST AI RMF 1.0	NIST	2023-01	nist.gov
NIST AI 600-1 (생성형 AI 프로파일)	NIST	2024-07	nist.gov
NIST SP 800-53 Rev.5	NIST	현행	csrc.nist.gov
CSA AI Controls Matrix	Cloud Security Alliance	v1.1	cloudsecurityalliance.org
EU AI Act	EU	Regulation (EU) 2024/1689, 2024-08-01 발효	eur-lex.europa.eu
ISO/IEC 42001 / 23894 / 27001	ISO/IEC	현행	iso.org (유료)
개인정보보호법	대한민국	현행	law.go.kr
Model Context Protocol	Anthropic → Agentic AI Foundation	2026-07-28 개정	github.com/modelcontextprotocol/modelcontextprotocol
Agent2Agent (A2A)	A2A Project	v1.0.1 (2026-05-28)	github.com/a2aproject/A2A
OpenTelemetry Semantic Conventions	CNCF	v1.44.0 (2026-08-04)	github.com/open-telemetry/semantic-conventions
W3C Trace Context	W3C	Recommendation	w3.org

B.3 실측 방법

```
# 저장소 실측 (2026-09-17). 스타·라이선스·아카이브 여부·기본 브랜치 최신 커밋·최신 릴리스
gh api "repos/{owner}/{repo}"                          # full_name 이 다르면 이전된 저장소
gh api "repos/{owner}/{repo}/commits/{default_branch}" --jq '.commit.committer.date'
gh api "repos/{owner}/{repo}/releases/latest"          --jq '.tag_name'
gh api "repos/{owner}/{repo}/license"                  --jq '.content' | base64 -d | head

# 표준 문서 확인 — PDF 요약이 아니라 저장소 원문을 직접 읽었다
gh api "repos/GenAI-Security-Project/GenAI-LLM-Top10/contents/2026/final" --jq '.[].name'
```

```
gh api "repos/GenAI-Security-Project/GenAI-LLM-Top10/contents/2026/final/mappings" --jq '.[].name'

# 즐겨찾기 교차
# github.com/WisemanLim?tab=stars 수집 목록과 저장소 경로를 대조
```

조회 대상 245개 저장소의 결과는 assets 디렉터리의 repos.tsv 에 원본 그대로 보관한다. 본문의 모든 스타 수·라이선스·커밋 일자는 이 파일에서 생성했으며, 문서 빌드 시점에 다시 읽는다. 따라서 수치를 사람이 옮겨 적으며 생기는 오류가 없다.

부록 C. 사용자 즐겨찾기 교차

github.com/WisemanLim?tab=stars 목록 5,832건과 본 문서에서 다룬 저장소를 대조했다. 아래는 교차한 저장소이며, 본문 표에서는 이름 뒤 별표로 표시했다.

저장소	스타	라이선스	최신 커밋	설명
AISecurityLab/hackagent	515	Apache-2.0	2026-09-16	HackAgent is an open-source security toolkit to detect vulnerabilities
AgentOps-AI/agentops	5,822	MIT	2026-06-25	Python SDK for AI agent monitoring, LLM cost tracking, benchmarking, a
Arize-ai/phoenix	11,505	Elastic-2.0	2026-09-17	AI Observability & Evaluation
BakeLens/crust	439	Elastic-2.0	2026-03-30	🦀 Open Source AI Agent Security Infrastructure – intercepts and blocks
BerriAI/litellm	58,937	MIT + enterprise/ 상용	2026-09-17	The fastest, litest AI Gateway. Rust core with Python SDK. Call 100+ L
ClickHouse/ClickHouse	49,934	Apache-2.0	2026-09-17	ClickHouse® is a real-time analytics database management system
EasyJailbreak/EasyJailbreak	909	GPL-3.0	2026-09-01	An easy-to-use Python framework to generate adversarial jailbreak prom
EleutherAI/lm-evaluation-harness	14,005	MIT	2026-09-14	A framework for few-shot evaluation of language models.
Giskard-AI/giskard-oss	5,821	Apache-2.0	2026-09-14	🐢 Open-Source Evaluation & Testing library for LLM Agents
MCP-Defender/MCP-Defender	257	AGPL-3.0	2026-06-05	Desktop app that automatically scans and blocks malicious MCP traffic
Marker-Inc-Korea/ko-pii	90	MIT	2026-09-09	한국어 PII 검출 + 가명화 Python 라이브러리
MemTensor/MemOS	11,478	Apache-2.0	2026-09-16	Self-evolving memory OS for LLM & AI Agents: ultra-persistent memory,
NVIDIA-NeMo/Guardrails	7,150	Apache-2.0	2026-09-16	NeMo Guardrails is an open-source toolkit for easily adding programmab
NVIDIA/SkillSpector	17,502	Apache-2.0	2026-09-16	Security scanner for AI agent skills. Detect vulnerabilities, maliciou
OWASP/Nettacker	5,572	Apache-2.0	2026-09-13	Automated Penetration Testing Framework - Open-Source Vulnerability Sc
Papr-ai/memory-opensource	74	AGPL-3.0	2026-02-10	Predictive memory layer for AI agents. MongoDB + Qdrant + Neo4j with m
Portkey-AI/gateway	13,018	MIT	2026-05-25	A blazing fast AI Gateway with integrated guardrails. Route to 1,600+
Repello-AI/Agent-Wiz	397	Apache-2.0	2025-10-30	A CLI tool for threat modeling and visualizing AI agents built using p
TencentCloud/CubeSandbox	12,624	Tencent 자체 라이선스	2026-09-17	Instant, Concurrent, Secure & Lightweight Sandbox for AI Agents.
a2aproject/A2A	25,804	Apache-2.0	2026-09-16	Agent2Agent (A2A) is an open protocol enabling communication and inter
affaan-m/agentshield	1,191	MIT	2026-09-10	AI agent security scanner. Detect vulnerabilities in agent configurati
anthropics/claude-code-security-review	6,231	MIT	2026-02-11	An AI-powered security review GitHub Action using Claude to analyze co
anthropics/sandbox-runtime	5,256	Apache-2.0	2026-09-16	A lightweight sandboxing tool for enforcing filesystem and network res
archestra-ai/archestra	4,282	이중 라이선스 라우터	2026-09-17	Enterprise AI Platform with guardrails, MCP registry, gateway & orches
bytebase/bytebase	14,489	MIT + enterprise 상용	2026-09-17	Database governance built for humans and agents – controlling changes
caura-ai/caura	518	Apache-2.0	2026-09-17	Caura (formerly MemClaw) – governed shared memory for AI agent fleets.
cilium/cilium	25,230	Apache-2.0	2026-09-16	eBPF-based Networking, Security, and Observability
cleanlab/cleanlab	11,654	Apache-2.0	2026-01-13	Cleanlab's open-source library is the standard data-centric AI package
cloudflare/security-audit-skill	7,807	MIT	2026-09-14	A coding-agent skill for multi-phase security audits with independentl
comet-ml/opik	22,078	Apache-2.0	2026-09-16	Debug, evaluate, and monitor your LLM applications, RAG systems, and a
confident-ai/deepeval	18,301	Apache-2.0	2026-09-16	The LLM Evaluation Framework
crewAIInc/crewAI	58,671	MIT	2026-09-16	Framework for orchestrating role-playing, autonomous AI agents. By fos
crowdsecurity/crowdsec	14,874	MIT	2026-09-16	CrowdSec - the open-source and participative security solution offerin
dottxt-ai/outlines	15,819	Apache-2.0	2026-08-24	Structured Outputs
e2b-dev/E2B	13,850	Apache-2.0	2026-09-16	Open-source, secure environment with real-world tools for enterprise-g
elastic/elasticsearch	77,920	AGPL-3.0 / SSPL-1.0 / Elastic-2.0 3중	2026-09-17	Free and Open Source, Distributed, RESTful Search Engine
evidentlyai/evidently	7,922	Apache-2.0	2026-09-10	Evidently is an open-source ML and LLM observability framework. Eval
falcosecurity/falco	9,384	Apache-2.0	2026-09-16	Cloud Native Runtime Security
fluent/fluent-bit	8,111	Apache-2.0	2026-09-16	Fast and Lightweight Logs, Metrics and Traces processor for Linux, BSD
getagentidentity/llm-authz-audit	6	MIT	2026-02-16	Scan your LLM-powered applications for authorization gaps, leaked cred
getagentseal/agentseal	374	FSL-1.1-Apache-2.0 (비OSI)	2026-06-11	Security toolkit for AI agents. Scan your machine for dangerous skills
goharbor/harbor	29,396	Apache-2.0	2026-09-16	An open source trusted cloud native registry project that stores, sign
google/differential-privacy	3,360	Apache-2.0	2026-09-11	Google's differential privacy libraries.

google/mantis	1,569	Apache-2.0	2026-09-13	A modular, stack-agnostic toolkit of security review skills for AI cod
googleapis/mcp-toolbox	16,512	Apache-2.0	2026-09-17	MCP Toolbox for Databases is an open source MCP server for databases.
grafana/grafana	76,779	AGPL-3.0	2026-09-17	The open and composable observability and data visualization platform.
grafana/loki	28,903	AGPL-3.0	2026-09-17	Like Prometheus, but for logs.
grafana/tempo	5,476	AGPL-3.0	2026-09-16	Grafana Tempo is a high volume, minimal dependency distributed tracing
gravitational/teleport	20,924	AGPL-3.0	2026-08-25	The easiest, and most secure way to access and protect all of your inf
hashicorp/vault	36,325	BUSL-1.1 (Licensor: IBM)	2026-09-17	A tool for secrets management, encryption as a service, and privileged
humanlayer/humanlayer	11,554	Apache-2.0	2026-06-19	The best way to get AI coding agents to solve hard problems in complex
istio/istio	38,391	Apache-2.0	2026-09-17	Connect, secure, control, and observe services.
jaegertracing/jaeger	23,217	Apache-2.0	2026-09-16	CNCF Jaeger, a Distributed Tracing Platform
kagent-dev/kagent	3,745	Apache-2.0	2026-09-16	Cloud Native Agentic AI | Discord: https://bit.ly/kagentdiscord
katanemo/plano	7,055	Apache-2.0	2026-08-19	Plano is an AI-native proxy server and data plane for agentic apps. Sm
keycloak/keycloak	36,813	Apache-2.0	2026-09-16	Open Source Identity and Access Management For Modern Applications and
langchain-ai/langchain	146,481	MIT	2026-09-16	The agent engineering platform.
langchain-ai/langgraph	41,791	MIT	2026-09-14	Build resilient agents.
langflow-ai/langflow	154,904	MIT	2026-09-16	Langflow is a powerful tool for building and deploying AI-powered agen
letta-ai/letta	24,770	Apache-2.0	2026-09-10	Platform for stateful agents: AI with advanced memory that can learn a
lm-sys/FastChat	39,535	Apache-2.0	2025-06-02	An open platform for training, serving, and evaluating large language
logto-io/logto	14,578	MPL-2.0	2026-09-17	👮 Authentication and authorization infrastructure for SaaS and AI ap
luckyPipewrench/pipelock	876	Apache-2.0	2026-09-17	Open-source AI agent firewall for MCP security and agent egress. Scans
matrixorigin/memoria	600	Apache-2.0	2026-09-11	Secure memory management for AI Agents • Ensures data integrity • Redu
maximhq/bifrost	8,125	Apache-2.0	2026-09-16	Fastest enterprise AI gateway (50x faster than LiteLLM) with adaptive
mem0ai/mem0	65,460	Apache-2.0	2026-09-16	The Memory Layer for AI Agents - Drop-in memory infrastructure for AI
microsoft/PyRIT	4,485	MIT	2026-09-16	The Python Risk Identification Tool for generative AI (PyRIT) is an op
microsoft/agent-governance-toolkit	6,274	MIT	2026-09-15	AI Agent Governance Toolkit — Policy enforcement, zero-trust identity,
microsoft/autogen	61,008	CC-BY-4.0	2026-04-06	A programming framework for agentic AI
milvus-io/milvus	46,132	Apache-2.0	2026-09-17	Milvus is a high-performance, cloud-native vector database built for s
modelcontextprotocol/python-sdk	24,315	MIT	2026-09-16	The official Python SDK for Model Context Protocol servers and clients
open-telemetry/opentelemetry-collector	7,559	Apache-2.0	2026-09-17	OpenTelemetry Collector
openai/codex-security	10,744	Apache-2.0	2026-09-17	OpenAI's Codex Security CLI and TypeScript SDK for finding, validating
openai/frontier-evals	1,300	MIT	2026-04-21	OpenAI Frontier Evals
openai/openai-agents-python	29,505	MIT	2026-09-16	A lightweight, powerful framework for multi-agent workflows
opensandbox-group/OpenSandbox	15,358	Apache-2.0	2026-09-17	Secure, Fast, and Extensible Sandbox runtime for AI agents.
opensearch-project/OpenSearch	13,721	Apache-2.0	2026-09-17	🔎 Open source distributed and RESTful search engine.
ottosulin/awesome-ai-security	1,480	MIT	2026-09-13	A collection of awesome resources related AI security
praetorian-inc/augustus	289	Apache-2.0	2026-09-15	LLM security testing framework for detecting prompt injection, jailbre
projectdiscovery/nuclei	31,312	MIT	2026-09-14	Nuclei is a fast, customizable vulnerability scanner powered by the gl
prometheus/prometheus	66,101	Apache-2.0	2026-09-16	The Prometheus monitoring system and time series database.
pydantic/pydantic-ai	19,993	MIT	2026-09-17	How Python does AI. Agents, realtime voice, image generation, embeddin
qdrant/qdrant	34,609	Apache-2.0	2026-09-03	Qdrant - High-performance, massive-scale Vector Database and Vector Se
rabbitstack/fibratus	2,544	Apache-2.0	2026-09-12	Security sensor for realtime threat detection and protection
secureagentics/Adrian	564	Apache-2.0	2026-09-15	Open-source runtime AI agent security tool - monitors and controls AI
sgl-project/sglang	36,078	Apache-2.0	2026-09-17	SGLang is a high-performance serving framework for large language mode
sipyourdrink-ltd/bernstein	1,185	Apache-2.0	2026-09-16	The open‑source AI Agents Governance & Orchestration framework: write
strands-agents/harness-sdk	7,301	Apache-2.0	2026-09-16	Build an agent harness and control it end-to-end. Open-source SDK for
supabase/supabase	109,853	Apache-2.0	2026-09-17	The Postgres development platform. Supabase gives you a dedicated Post
superradcompany/microsandbox	8,277	Apache-2.0	2026-09-17	🥾 Easy fast local-first microVM runtime and library
trufflesecurity/trufflehog	27,963	AGPL-3.0	2026-09-16	Find, verify, and analyze leaked credentials
verazuo/jailbreak_llms	3,816	MIT	2024-12-24	[CCS'24] A dataset consists of 15,140 ChatGPT prompts from Reddit, Dis
vllm-project/vllm	91,966	Apache-2.0	2026-09-17	A high-throughput and memory-efficient inference and serving engine fo

교차 93건 / 문서 수록 저장소 245건. 즐겨찾기 목록에 이미 상당수가 들어 있다는 것은, 이 문서의 스택 선정이 사용자가 평소 추적하는 범위와 크게 어긋나지 않는다는 뜻이다.

부록 D. 이미지·그림 출처

번호	그림	출처·제작 방식	비고
-	분석 대상 인포그래픽	Security Risks in AI Agents (Rushika Rai). 사용자 첨부	문서에 삽입하지 않음. 텍스트 항목만 인용
그림 1	원본 도식 재구성	자체 제작(matplotlib)	원본의 색·배치·아이콘을 복제하지 않고 항목만 재배열
그림 2	방어 관문 재배치	자체 제작(matplotlib)	도식 항목을 관문 기준으로 재배치한 해석도
그림 3	표준 매핑 매트릭스	자체 제작(matplotlib)	OWASP 2026 저장소 매핑 파일 근거
그림 4	운용 3모드	자체 제작(matplotlib)	-
그림 5	참조 아키텍처	자체 제작(matplotlib)	-
그림 6	에이전트 배치도	자체 제작(matplotlib)	-
그림 7	저장소 스타 로그 막대	자체 제작(matplotlib)	GitHub REST API 2026-09-17 실측값
그림 8	로드맵·성숙도	자체 제작(matplotlib)	-

부록 E. 한계

1. **원본 도식의 출처를 확인하지 못했다.** 이미지 내부에 URL·게시 일자가 없어 판본과 수정 이력을 알 수 없다. 따라서 도식이 어느 시점의 표준을 참조했는지는 내용으로 추정했다(2025 판 기준으로 보인다).
2. **성능 수치는 목표값이지 실측값이 아니다.** 7.2 절의 지연 예산과 15.1 절의 지표는 설계 목표다. 구현 전에 측정할 방법이 없으므로, 3자 벤치마크 수치를 빌려 오지 않고 측정 방법만 규정했다.
3. **오탐·미탐률의 기준선이 없다.** 13.5 절의 권장 임계는 경험적 출발점이며, 조직별 트래픽 특성에 따라 재조정해야 한다. 골든셋 없이 임계만 복사하면 의미가 없다.
4. **오픈소스 기능 검증은 문서·메타데이터 수준이다.** 245개 저장소의 스타·라이선스·활성도는 API 로 실측했지만, 각 도구를 설치해 탐지 성능을 비교하지는 않았다. 10장의 기본 엔진 선정은 후보 제시이며, 실제 채택은 조직 데이터로 평가한 뒤 결정해야 한다.
5. **법률 판단이 아니다.** 4.4 절의 규제 매핑은 설계 참고용이다. 적용 여부와 의무 범위는 법무 검토를 거쳐야 한다.
6. **표준은 계속 바뀐다.** 이 문서가 확인한 OWASP LLM Top 10 만 해도 2026-08-04 개정에서 열 항목 중 여덟 개의 번호가 흔들렸다. 4.5 절이 매핑을 코드로 유지하라고 요구하는 이유이며, 이 문서 자체도 판본 기준일(2026-09-17)에 매인다.
7. **한국어 자원의 공백.** 개인정보 탐지를 제외하면 한국어 전용 공격 코퍼스·평가셋이 사실상 없다. 영문 코퍼스로 측정한 미탐률은 한국어 환경에서 그대로 적용되지 않는다. 골든셋 자체 축적이 필요하다.